Université Cheikh Anta DIOP de Dakar

Faculté des Sciences et Techniques

Département Mathématiques et Informatique

Laboratoire d'Algèbre de Cryptologie de Géométrie Algébrique et Applications

LACGAA

Master Transmission de Données et Sécurité de l'Information

Thème :

Étude et mise en place d'une solution de sécurité basée sur la gestion centralisée des logs et des événements

Présenté et soutenu par :
M. Pathé Djibril DIOUF

Encadreurs : Dr Abdoulaye THIOUNE & M. Ibrahima DIAW
Sous la supervision de :
Dr. Demba Sow

Jury :

Président(e) : Dr. Laila MESMOUDI	FST/UCAD
Membres : Dr. Amadou TALL	FST/UCAD
Dr. Abdoulaye THIOUNE	FASTEF/UCAD
M. Ibrahima DIAW	

Année Académique 2021 – 2022

DEDICACES

Je dédie ce mémoire à mes **parents** en signe de gratitude pour tout ce que vous avez fait pour moi. Votre dévouement et votre amour inconditionnel m'ont donné la force et la confiance nécessaires pour surmonter les obstacles et réussir dans mes études.

À mes **frères et sœurs**, pour leur soutien, leur inspiration et leur amitié inébranlables.

À mes amis, pour leur soutien, leur amitié et leur motivation tout au long de ce parcours.

À tous mes promotionnaires du MASTER IDSI, pour leur collaboration, leur soutien durant cette formation.

À tous ceux qui ont contribué de près ou de loin à la réalisation de ce travail, merci infiniment.

REMERCIEMENTS

Après avoir rendu grâce à Dieu pour m'avoir donné la force et la volonté pour achever ce modeste travail.

Je tiens à exprimer mes sincères remerciements à toutes les personnes qui ont contribué de près ou de loin à la réalisation de ce travail de recherche.

Tout d'abord, je tiens à remercier mes encadreurs, **Mr Ibrahima Diaw** et **Dr Abdoulaye Thioune** pour leurs soutiens, leurs orientations et leurs conseils.

Je remercie également les responsables de la formation IDSI-LACGAA, le **Pr Oumar Diankha**, le **Pr Cheikh Thiécoumba Gueye** et le **Pr Djiby Sow** pour leur disponibilité.

Enfin, mes remerciements vont aussi à l'endroit du corps professoral et administratif du laboratoire LACGAA pour ces deux années de formation qui m'ont permis d'acquérir des connaissances nécessaires à la réalisation de ce mémoire.

TABLE DES MATIÈRES

DEDICACES ii
REMERCIEMENTS iii
TABLE DES MATIÈRES iv
GLOSSAIRE vii
LISTE DES FIGURES ix
AVANT-PROPOS xi
RESUME xii
ABSTRACT xiii
INTRODUCTION GÉNÉRALE 1
CHAPITRE I : CADRE THÉORIQUE ET MÉTHODOLOGIQUE 2
I. Cadre théorique 2
I.1 – Introduction 2
I.2 – Problématique 2
I.3 – Objectifs 3
I.4 – Pertinence du sujet 3
II. Cadre méthodologique 3
II.1 – Délimitation du champ d'étude 3
II.2 – Méthodes d'investigation 3
II.3 – Difficultés rencontrées 4
CHAPITRE II : GÉNÉRALITÉS SUR LES RÉSEAUX ET LA SÉCURITÉ INFORMATIQUE 4
III.1 – Introduction 4
III.2 – Réseaux informatiques 4
a) Définition d'un réseau informatique 4
b) Avantages d'un réseau 5
c) Fonctionnement d'un réseau informatique 5
d) Les différents types de réseau informatique 5
III.3 – Les dispositifs de protection 6
a) L'antivirus 6
b) Le pare-feu 7
c) Les systèmes de détection et de prévention d'intrusions 8
III.4 – Sécurité informatique 10
a) Définition 10

b) Aspects de la sécurité informatique 10
c) Objectifs de la sécurité informatique 11
d) La politique de sécurité 11
e) Les frameworks de sécurité 12
III.5 – Présentation de quelques attaques 12
a) Le ransomware 13
b) L'attaque par déni de service (DoS) 13
c) L'attaque de type « zero-day » 13
d) L'attaque par les objets connectés 14
e) Le phishing (ou l'hameçonnage) 14
f) L'injection SQL 14
g) Le cross-site scripting (XSS) 15
III.6 – Importance de la gestion des logs et leurs limites 15
a) Généralités sur les logs 15
b) Le format des logs 15
c) Les différentes catégories de logs 18
d) La gestion des logs 19
e) L'utilité de la gestion des logs 19
CHAPITRE III : PRÉSENTATION DES SIEM 20
IV.1 – Historique des SIEM 20
IV.2 – Rôles et fonctionnement 21
a) Rôles d'un SIEM 21
b) Fonctionnement d'un outil SIEM 21
IV.3 – Les avantages et les limites des SIEM 23
a) Les avantages 23
b) Les limites 23
IV.4 – SIEM et SOC 24
a) Définition d'un SOC 24
b) Rôle du SIEM dans le SOC 24
IV.5 – Les recommandations pour la mise en place d'un SIEM 25
a) Les caractéristiques d'un SIEM 25
b) Les meilleurs pratiques pour l'implémentation d'un SIEM 27
IV.6 – Étude comparative de quelques solutions SIEM 28
a) IBM QRadar 28
b) Splunk Enterprise Security 30

c) ELK (Elastic Logstash Kibana) ... 32
d) LogRhythm ... 35
e) Graylog ... 37
f) AlienVault OSSIM ... 39
g) Datadog ... 41
h) Wazuh ... 42
IV.7 – Tableau récapitulatif des solutions SIEM ... 45
IV.8 – Choix de la solution ... 46
CHAPITRE IV : MISE EN PLACE DE LA SOLUTION ET TESTS ... 46
V.1 – Présentation de l'environnement de travail ... 46
a) Architecture de déploiement ... 46
b) Les prérequis ... 47
V.2 – Composants WAZUH ... 48
a) L'indexeur Wazuh ... 48
b) Le serveur Wazuh ... 49
c) Le tableau de bord Wazuh ... 51
d) Les agents Wazuh ... 52
V.3 – Mode de deploiement ... 55
a) Déploiement All-in-One ... 55
b) Déploiement distribué ... 55
V.4 – Déploiement ... 56
a) Installation de Wazuh OVA ... 56
b) Installation des agents ... 60
V.5 – Les tests ... 61
a) Surveillance des événements Sysmon avec Wazuh ... 61
b) Détection des techniques courantes de persistance Linux avec Wazuh ... 67
CONCLUSION ET PERSPECTIVES ... 71
BIBLIOGRAPHIE ... 72
WEBOGRAPHIE ... 72

GLOSSAIRE

API : Application Programming Interface

CTI : Cyber Threat Intelligence

DNS : Domain Name Service

Dos/DDoS : Denial of Service / Distributed Denial of Service

EDR/XDR : Endpoint Detection Response / eXtended Detection Response

FIM : File Integrity Monitoring

FTP : File Transfert Protocol

IA : Intelligence Artificielle

IDS/IPS : Intrusion Detection System / Intrusion Prevention System

IoC : Indicators of Compromise

IoT : Internet of Things

IT : Information Technology

LAN : Local Area Network

MAN : Metropolitan Area Network

NIDS/HIDS : Network Intrusion Detection System / Host-based Intrusion Detection System

NLP : Natural Language Processing

OSI : Open Systems Interconnection

OSSEC : Open Source Security

OWASP : Open Web Application Security Project

PAN : Private Area Network

PCI-DSS : Payment Card Industry Data Security Standard

RBAC : Role-Based Access Control

RGPD : Règlement Général sur la Protection des Données

SaaS : Software as a Service

SCA : Security Configuration Assessment

SEM : Security Event Management

SI : Système d'Information

SIEM : Security Information and Event Management

SIM : Security Information Management

SOAR : Security Orchestration, Automation and Response

SOC : Security Operations Center

SSH : Secure Shell

SSO : Single Sign-On

TCP/IP : Transmission Control Protocol / Internet Protocol

TLS/SSL : Transport Layer Security / Secure Sockets Layer

UDP : User Datagram Protocol

UEBA : User and Entity Behavior Analytics

VPN : Virtual Private Network

WAF : Web Application Firewall

WAN : Wide Area Network

WLAN : Wireless Local Area Network

LISTE DES FIGURES

Figure 1 : Fonctionnement d'un firewall

Figure 2 : Fonctionnement d'un IDS

Figure 3 : Log au format JSON

Figure 4 : Log sous Windows

Figure 5 : Common log du NCSA

Figure 6 : Fichier log au format W3C

Figure 7 : Fichier log au format CEF

Figure 8 : Logo d'IBM QRadar

Figure 9 : Architecture de QRadar

Figure 10 : Logo de Splunk

Figure 11 : Architecture de Splunk

Figure 12 : Logo de ELK

Figure 13 : Architecture de ELK

Figure 14 : Logo de LogRhythm

Figure 15 : Architecture de LogRhythm

Figure 16 : Logo de Graylog

Figure 17 : Architecture basique de Graylog

Figure 18 : Logo d'AlienVault OSSIM

Figure 19 : Architecture d'AlienVault OSSIM

Figure 20 : Logo de Datadog

Figure 21 : Logo de Wazuh

Figure 22 : Architecture de Wazuh

Figure 23 : Architecture de déploiement

Figure 24 : Tableau des exigences matérielles pour déployer Wazuh

Figure 25 : Architecture et composants du serveur Wazuh

Figure 26 : Tableau de bord de Wazuh

Figure 27 : Architecture et composants de l'agent Wazuh

Figure 28 : Authentification sur Wazuh OVA

Figure 29 : Récupération de l'adresse IP de l'interface réseau de Wazuh

Figure 30 : Authentification sur l'interface Web de Wazuh

Figure 31 : Interface de Wazuh

Figure 32 : OpenSearch Dashboard

Figure 33 : Exemple de fichier log

Figure 34 : Tableau de bord des événements de sécurité

Figure 35 : Interface de configuration de l'agent Wazuh sous Windows

Figure 36 : Installation de l'agent Wazuh sous Linux

Figure 37 : Activation de l'agent Wazuh sous Linux

Figure 38 : Fichier de configuration sysconfig.xml

Figure 39 : Installation de Sysmon

Figure 40 : Exécution de mimikatz

Figure 41 : Événement de sécurité au format XML

Figure 42 : Configuration de l'agent pour surveiller les événements Sysmon

Figure 43 : Configuration du gestionnaire Wazuh

Figure 44 : Redémarrage du gestionnaire Wazuh

Figure 45 : Injection d'un module dans le processus lsass.exe de Windows

Figure 46 : Collecte des différents événements de sécurité

Figure 47 : Alerte générée au format JSON

Figure 48 : Configuration du endpoint Linux

Figure 49 : Redémarrage de l'agent Wazuh

Figure 50 : Authentification en tant que superutilisateur sur le manager Wazuh

Figure 51 : Création du fichier de règle comm_persist_tech_rules.xml

Figure 52 : Création des règles de détection

Figure 53 : Redémarrage du gestionnaire Wazuh

Figure 54 : Alertes générées par le tableau de bord Wazuh

AVANT-PROPOS

La sécurité des systèmes d'information est une préoccupation majeure pour les entreprises de toutes tailles et de tous secteurs d'activité. Les cyberattaques se multiplient, devenant de plus en plus sophistiquées et difficiles à détecter. Face à cette menace grandissante, les entreprises ont besoin de solutions efficaces pour protéger leurs données et leurs systèmes.

C'est dans ce contexte que depuis 2004, le LABORATOIRE D'ALGEBRE, DE CRYPTOLOGIE, DE GEOMETRIE ALGEBRIQUE ET APPLICATIONS (L.A.C.G.A.A) s'est spécialisé dans la recherche et la formation en cryptographie et dans les domaines de la sécurité de l'information, devenant ainsi le seul laboratoire de la sous-région à le faire. Le laboratoire L.A.C.G.A.A a lancé une licence, un master et une formation doctorale pour consolider son expertise.

En vue de l'obtention du Diplôme de MASTER II en Transmission de Données et Sécurité de l'Information au sein du laboratoire, il nous a été demandé de réaliser un projet de mémoire de fin d'étude portant sur **l'Étude et la mise en place d'une solution de sécurité basée sur la gestion centralisée des logs et des événements.**

Les SIEM offrent de nombreux avantages, notamment la détection précoce des menaces, l'analyse de la cause première des incidents de sécurité, la conformité réglementaire, la visibilité en temps réel de l'état de sécurité de l'ensemble du système d'information, et la réduction des coûts liés à la gestion de la sécurité.

Dans ce document, nous allons explorer en détail les SIEM, leur fonctionnement, leurs avantages et leurs limites. Nous verrons également comment choisir le SIEM qui convient le mieux à votre entreprise, comment le déployer et l'optimiser pour une sécurité maximale. Enfin, nous aborderons les tendances actuelles et futures en matière de SIEM, ainsi que les défis à relever pour assurer une sécurité optimale des systèmes d'information.

RESUME

Le présent mémoire vise à étudier l'efficacité des SIEM dans la détection et la réponse aux menaces de sécurité informatique. Nous avons mené une analyse approfondie des fonctionnalités des SIEM ainsi que des meilleures pratiques de déploiement et de configuration. Nous avons également examiné différents scénarios d'attaques et évalué la capacité des SIEM à détecter et à répondre à ces attaques.

Avant l'apparition du SIEM, les experts en sécurité informatique manquaient de visibilité sur les activités se déroulant dans leurs environnements IT. Mais les SIEM offrent aux équipes IT une visibilité en temps réel permettant de traiter et centraliser un nombre conséquent d'alertes de sécurité et d'aider à mieux comprendre certains évènements préoccupants présents sur le SI.

Nos résultats ont montré que les SIEM sont des outils très efficaces pour la détection des menaces de sécurité. Cependant, leur efficacité dépend fortement de la qualité de la configuration et de la gestion des règles de détection.

C'est dans ce contexte que de nos jours, les SIEM sont devenus des outils indispensables pour la sécurité des systèmes d'information.

ABSTRACT

This thesis aims to study the effectiveness of SIEMs in detecting and responding to cybersecurity threats. We conducted a thorough analysis of SIEM functionalities as well as best deployment and configuration practices. We also examined different attack scenarios and evaluated the capability of SIEMs to detect and respond to these attacks.

Prior to the emergence of SIEM, IT security experts lacked visibility into activities taking place in their IT environments. However, SIEMs provide real-time visibility to IT teams, enabling them to handle and centralize a significant number of security alerts and help better understand certain concerning events present on the SI.

Our results have shown that SIEMs are highly effective tools for detecting security threats. However, their effectiveness strongly depends on the quality of configuration and management of detection rules.

In this context, SIEMs have become essential tools for information system security nowadays.

INTRODUCTION GÉNÉRALE

Avec l'avénement des objets connectés, le développement rapide des technologies et des réseaux de communication et la pandémie au cours de ces dernières années, les organisations ont dû faire face à des nouveaux défis à savoir répondre aux besoins de sécurité avec le recours massif et précipité au télétravail tout en réorganisant leurs politiques. Certes, on peut directement dire que cette transition a eu un rôle important dans leur processus de transformation digitale, cependant les entreprises ont dû tout de même revoir leur politique de sécurité interne augmentant de ce fait les vecteurs d'attaques et les risques pour leurs données. En effet, les trois catégories de cyberattaques les plus rencontrées durant la pandémie ont été les ransomwares, les vols de données et les accès non autorisées. Ainsi, la sécurité informatique est devenue primordiale et très importante dans le domaine du numérique.

La sécurité informatique, d'une manière générale, consiste à s'assurer que les ressources matérielles ou logicielles d'une organisation sont uniquement utilisées dans le cadre prévu.

Pour pallier à ce besoin de sécurité au sein de ces réseaux et systèmes d'informations, les organisations et entreprises se basent sur des outils et technologies comme l'utilisation de pare-feux, la collecte de fichiers logs, la mise en place de VPN, les détecteurs d'intrusions tels que les IDS/IPS, etc.… Et également par la mise en place d'un SOC qui est une équipe d'experts chargée de la supervision de la sécurité du SI pour détecter des événements de sécurité comme par exemple les intrusions, les élevations de privilèges, etc…

En effet, il faut noter que la plupart des systèmes, services et équipements tels que les pare-feux ou encore les applications générent des données qui jouent un rôle crucial sur le fonctionnement d'un système, son comportement et dans la détection des activités suspectes sur un réseau. Ces données sont appelées les logs ou les fichiers de journalisation.

Et c'est ainsi que les SIEM pour *Security Information and Event Management* interviennent en permettant non seulement aux équipes de sécurité de pouvoir collecter les fichiers journaux mais aussi de détecter les menaces connues et inconnues en temps réel via du machine learning et de l'analyse comportementale des utilisateurs et des entités (UEBA). Grâce à l'analyse de ces données, les SIEM peuvent identifier les activités suspectes et les comportements malveillants.

Cependant, l'utilisation de SIEM n'est pas une panacée et comporte également des défis et des limites, tels que le coût, la complexité, la configuration et la maintenance, ainsi que la dépendance à la qualité des sources de données.

C'est dans ce contexte actuel de sécurité que la mise en place d'une solution de sécurité basée sur la gestion centralisée des logs et des événements de sécurité apporte aujourd'hui une solution réelle dans l'optimisation de la sécurité informatique au sein d'un environnement IT.

CHAPITRE I : CADRE THÉORIQUE ET MÉTHODOLOGIQUE

I. Cadre théorique

I.1 – Introduction

De nos jours, les SIEM jouent un rôle important dans la gestion de la sécurité à travers le monitoring des logs. En effet, les logs sont souvent stockés et accessibles sur des fichiers spécifiques sur les machines concernées.

L'analyse et la gestion de ces logs consistera à les journaliser d'une part en mettant en place un système permettant la remontée automatique des logs de sources disparates et à les centraliser d'autre part en mettant un point central où seront envoyer tous les logs les rendant ainsi simple d'accès et d'exploitation.

C'est ainsi que dans ce monde numérique ultra connecté, que la mise en place d'un SIEM évolutif offrant la possibilité de collecter des informations à partir de diverses sources de données, de conserver les données sur une longue période, d'enrichir les différents événements, de corréler entre ces événements, d'analyser les données et les surveiller tout en fournissant des tableaux de bords est nécessaire pour optimiser la sécurité d'un SI.

I.2 – Problématique

Aujourd'hui, l'un des principaux problèmes de la mise en place d'une solution SIEM constitue le choix du SIEM adéquat en fonction des besoins de sécurité de l'entreprise, en termes de prix, de compatibilité, de fonctionnement et des types de données dont disposent l'entreprise.

En effet, cela soulève plusieurs questions à savoir :

Comment les solutions SIEM peuvent-elles aider les entreprises à faire face à l'évolution rapide des menaces de sécurité informatique ?

Quelles sont les capacités clés des SIEM pour répondre aux besoins actuels de la sécurité des systèmes d'information ?

Comment mesurer l'efficacité d'un SIEM et justifier son investissement pour l'organisation ?

Cette problématique met l'accent sur les capacités des SIEM à s'adapter aux nouveaux types de menaces de sécurité informatique, qui évoluent rapidement. Le travail de recherche pourrait se concentrer sur les différentes fonctionnalités des SIEM qui permettent de détecter et de répondre à des menaces sophistiquées telles que les attaques de type *zero-day* ou les attaques avancées persistantes.

La problématique pourrait également aborder la manière dont les SIEM peuvent aider les entreprises à respecter les réglementations de conformité telles que le RGPD ou le PCI-DSS. Les études de cas pourraient également être utilisées pour illustrer les résultats obtenus avec l'utilisation de SIEM dans des contextes spécifiques, voir les avantages et les limites de ces solutions et de mettre en évidence les meilleures pratiques à suivre pour les entreprises qui souhaitent déployer une solution SIEM.

I.3 – Objectifs

Le présent mémoire a pour objectif de voir comment la mise en place d'une solution SIEM favorise le renforcement de la sécurité informatique face à la variété et l'efficacité des attaques de nos jours. C'est dans ce cadre, que nous avons choisi comme sujet de mémoire, l'étude et la mise en place d'une solution de sécurité basée sur la gestion centralisée des logs et des événements.

Pour l'atteinte de cet objectif, nous allons faire une étude théorique et générale des systèmes de gestion des événements et des informations, ensuite une étude comparative des différentes solutions proposées sera faite et enfin finir par une implémentation de la solution choisie dans un environnement virtuel.

I.4 – Pertinence du sujet

En général, la sécurité au sein des entreprises est très bien gérée. Mais dans un souci d'adopter une surveillance proactive au vu des menaces qui deviennent de plus en plus sophistiquées, l'utilisation d'un outil SIEM devient une nécessité pour la prise de mesures défensives rapides et une meilleure gouvernance de la sécurité.

En effet de par l'automatisation de ce qui se faisait manuellement, de par le passage à l'echelle des volumes de logs générés par le SI et de la détection des incidents de sécurité en temps réel, le SIEM offre une visibilité de bout-en-bout sur l'ensemble de l'environnement informatique.

C'est dans ce cadre que le sujet de mémoire s'intitule : l'étude et la mise en place d'une solution de sécurité basée sur la gestion centralisée des logs et des événements.

II. Cadre méthodologique

II.1 – Délimitation du champ d'étude

Dans le cadre de ce mémoire, notre travail de recherche se focalise sur la manière dont la sécurité pourrait être assurée au niveau des entreprises ou des organisations et surtout sur l'apport d'une solution SIEM à travers la gestion des informations et des événements de sécurité pour optimiser la sécurité face aux menaces actuelles.

II.2 – Méthodes d'investigation

Pour bien mener notre travail, ce rapport est structuré en quatre chapitres. Nous allons aborder la méthodologie suivante concernant la suite de notre travail :

- **Chapitre 1** : nous allons y aborder la problématique, les objectifs ainsi que les raisons pour lesquelles portant sur le choix d'un tel sujet.
- **Chapitre 2** : ce chapitre va porter sur quelques généralités de la sécurité informatique. Ensuite, on présentera les attaques les plus récurrentes au cours de ces dernières années. Pour enfin finir par montrer l'importance de la gestion des logs.

- **Chapitre 3** : c'est ici que nous allons faire l'historique outils SIEM tout en montrant leur fonctionnement. En mettant en exergue les avantages de l'utilisation d'un SIEM, nous allons faire une étude comparative des différentes solutions proposées et faire une étude théorique de la solution choisie.
- **Chapitre 4** : c'est dans ce chapitre que nous serons faites les tests et le déploiement de la solution choisie et déterminer quel est le meilleur moyen d'assurer la sécurité d'un SI.

II.3 – Difficultés rencontrées

Pendant mes recherches pour la rédaction de ce mémoire, j'ai dû faire face à de nombreuses difficultés. Tout d'abord, j'ai constaté un manque de formation spécialisée dans les SIEM ainsi qu'un manque de documentation et de personnes ressources pour m'aider dans mes recherches. En outre, j'ai rencontré des difficultés liées au manque d'environnement adapté pour effectuer des tests approfondis, ainsi qu'aux limites de la virtualisation.

CHAPITRE II : GÉNÉRALITÉS SUR LES RÉSEAUX ET LA SÉCURITÉ INFORMATIQUE

III.1 – Introduction

De nos jours, les systèmes d'informations sont de plus en plus ouverts à Internet. Cette ouverture comporte des avantages mais également des inconvénients. En effet, avec l'élargissement des périmètres pour interconnecter les sites distants dans le but de transférer des données nécessite la mise en place d'un réseau sécurisé.

Afin d'assurer la sécurité au sein d'un réseau de manière générale, des architectures de réseaux informatiques et des protocoles de communication, les uns plus sécurisés que les autres, ont été élaborées au fil des années.

III.2 – Réseaux informatiques

En technologie de l'information, un réseau est défini en connectant au moins deux systèmes informatiques avec des câbles ou des liaisons sans fil. Le réseau le plus simple est constitué de deux ordinateurs reliés par des câbles. Dans ce cas, on parle aussi de réseaux *peer-to-peer* (P2P), ou pair à pair en français. Ce type de réseau n'a pas de hiérarchie. Deux participants sont au même niveau. Chaque ordinateur peut accéder aux données de l'autre et partager des ressources telles que des lecteurs de stockage, des programmes et des périphériques (tels que des imprimantes).

a) Définition d'un réseau informatique

Par définition, un réseau informatique est un ensemble d'équipements (ordinateurs, imprimantes, scanners, modems, routeurs, ...) reliés entre eux pour échanger des informations (messageries, transfert de fichiers, interrogation de base de données, …).

Exemple de réseau :

Un réseau local sans fil (WLAN) domestique est un bon exemple de petit réseau client/serveur. Divers appareils de votre maison sont connectés sans fil à un routeur qui agit comme un nœud central (serveur) dans votre maison. Le routeur est alors connecté à un réseau beaucoup plus vaste, Internet.

b) Avantages d'un réseau

La fonction principale du réseau est de fournir aux participants une plate-forme d'échange de données et de partage de ressources. Cette fonction est si importante que les réseaux sont devenus partie intégrante de notre vie quotidienne et de la société d'aujourd'hui.

Ainsi, les principaux avantages du réseau sont :

- La transmission de données
- Le partage de données
- La gestion centralisée des données et des programmes
- Le stockage et la sauvegarde centralisés des données
- Partager la puissance de calcul et la capacité de stockage
- Simple administration des permissions et des responsabilités

c) Fonctionnement d'un réseau informatique

Le fonctionnement d'un réseau informatique repose sur la communication entre les différents équipements qui le composent. Les éléments clés d'un réseau informatique sont :

- **Les périphériques réseau** : ces derniers permettent aux ordinateurs et autres dispositifs de communiquer entre eux. Les périphériques réseau comprennent notamment les commutateurs, les routeurs, les pare-feux et les points d'accès sans fil.
- **Les protocoles réseau** : les protocoles réseau sont des règles et des normes qui régissent la communication entre les différents équipements du réseau. Les protocoles réseau les plus courants sont TCP/IP, HTTP, FTP, SMTP, etc.
- **La topologie du réseau** : la topologie du réseau détermine la façon dont les différents équipements sont connectés entre eux. Il existe plusieurs types de topologies réseau, notamment la topologie en étoile, la topologie en anneau, la topologie en bus, la topologie en arbre, etc.
- **Les adresses IP** : chaque ordinateur et chaque périphérique du réseau est identifié par une adresse IP unique. Cette adresse permet aux équipements de se connecter entre eux et de communiquer via le réseau.

d) Les différents types de réseau informatique

Il existe plusieurs manières de catégoriser un réseau selon sa portée :

- Le réseau personnel (**PAN** : *Personal Area Network*) relie des appareils électroniques personnels.

- Le réseau local (**LAN** : *Local Area Network*) relie les ordinateurs ou postes téléphoniques situés dans la même pièce ou le même batiment. Il est adapté à la taille d'un site d'entreprise.
- Le réseau métropolitain (**MAN** : *Metropolitan Area Network*) est un réseau à l'échelle d'une ville.
- Le réseau étendu (**WAN** : *Wide Area Network*) est un réseau à grande échelle qui relie plusieurs sites ou des ordinateurs du monde entier.

III.3 – Les dispositifs de protection

Les ordinateurs connectés à Internet sont vulnérables aux attaques. Malgré la fréquence de formes nombreuses et plus puissantes de malveillance informatique, les utilisateurs ne sont pas sans défense.

a) L'antivirus

Un antivirus est un programme capable de détecter la présence d'un logiciel malveillant encore appelé malware sur un ordinateur, et si possible de désinfecter ce dernier.
Un malware est un fichier destiné à perturber, altérer ou détruire tout ou une partie d'un système informatique.

❖ Principe de fonctionnement

Pour la détection de malwares, l'antivirus peut procéder par :

- **Recherche de signatures** :

La signature virale d'un virus informatique est une partie identifiable de son code, qui permet à un antivirus de le détecter en se basant sur des comportements spécifiques, des fichiers générés ou des hachages.

- **Contrôleur d'intégrité** :

Certains programmes antivirus utilisent des vérificateurs d'intégrité pour détecter les modifications inhabituelles des fichiers exécutables qui peuvent être assimilées à une contamination par un virus.

- **Analyse des comportements** :

Cette méthode analyse le comportement de l'application pour détecter une activité similaire à des logiciels malveillants connus, comme par exemple la tentative d'accès en écriture à des fichiers de programmes exécutables.

❖ Limites des antivirus

L'antivirus reste un garde-fou indispensable dans les systèmes d'information. Mais ce n'est ni suffisant ni infaillible. L'évolution des cybermenaces montre qu'il est important de reconnaître leurs limites et que la sécurité ne peut pas compter uniquement sur elles.

b) Le pare-feu

Un pare-feu encore appelé *firewall*, est un système logiciel qui agit comme intermédiaire entre votre ordinateur local (ou réseau d'ordinateurs) et des réseaux tiers, en particulier Internet.
Il filtre les flux de communication échangés dans un réseau et possède au moins deux interfaces : une pour le réseau interne à protéger et une autre pour le réseau externe.

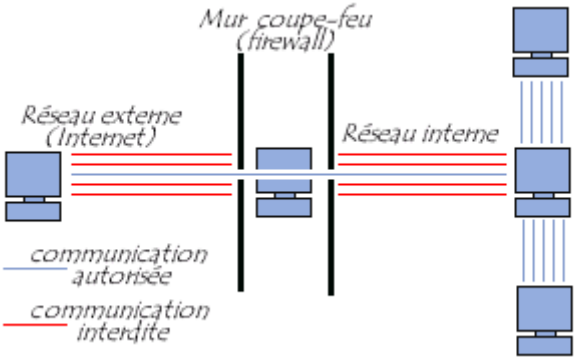

Figure 1 : Fonctionnement d'un firewall [W1]

❖ Principe de fonctionnement

Un système de pare-feu contient un ensemble de règles prédéfinies permettant de :

- **D'autoriser la connexion** (*allow*)
- **De bloquer la connexion** (*deny*)
- **Rejeter la demande de connexion sans avertir l'émetteur** (*drop*)

Toutes ces règles de filtrage dépendent de la politique de sécurité adoptée par l'entrepirse. Il existe en général deux politiques de sécurité permettant :

- Soit d'autoriser uniquement les communications ayant été explicitement autorisées.
- Soit pour empêcher des échanges expressément interdits.

On distingue plusieurs types de *firewall* en fonction de leur mode de fonctionnement :

- **Le filtrage simple de paquets** :

Un système de pare-feu fonctionne sur le principe du filtrage simple des paquets (*stateless packet filtering*). Il analyse les en-têtes de tous les paquets de données échangés entre les machines du réseau interne et les machines du réseau externe.

- **Le filtrage dynamique** :

Le filtrage dynamique des paquets est basé sur la vérification des couches 3 et 4 du modèle OSI pour assurer un suivi des transactions entre client et serveur.

- **Le filtrage applicatif** :

Ce type de filtrage permet de filtrer les communications par application. Le filtrage applicatif opère donc au niveau 7 du modèle OSI. Le filtrage applicatif nécessite donc une connaissance préalable des applications disponibles sur le réseau, notamment des types d'échanges de données (ports...).

Il faut noter qu'il éxiste également des pare-feu WAF.

Les pare-feu WAF :
Un Web Application Firewall (WAF) protège le serveur d'applications Web dans le backend des multiples attaques (phishing, ransomware, attaque DDOS, malware). La fonction du WAF est de garantir la sécurité du serveur Web en analysant les paquets de requête HTTP / HTTPS et les modèles de trafic.

❖ **Limites du pare-feu**

Le pare-feu est un premier niveau de protection pour un système informatique, mais il ne peut pas garantir une sécurité totale. Il offre une protection en contrôlant les communications vers l'extérieur, mais il ne peut pas empêcher les accès contournant le pare-feu. Les connexions internes, les supports de stockage externes et les ordinateurs portables peuvent également compromettre la sécurité du réseau.

c) Les systèmes de détection et de prévention d'intrusions

❖ **IDS *(Intrusion Detection System)* :**

Un IDS permet d'écouter le trafic réseau de manière furtive afin d'identifier des activités anormales ou suspectes, réduisant ainsi le risque d'intrusion.

De manière générale, il existe deux catégories d'IDS :

- Les **NIDS** (Network-Based Intrusion Detection System) qui assurent la sécurité au niveau du réseau. Il nécessite un matériel dédié et constitue un système capable de contrôler les paquets circulant sur un ou plusieurs liens réseaux afin de découvrir tout acte malveillant.
  Le NIDS place une ou plusieurs cartes d'interface réseau du système dédié en mode promiscuité (*promiscuous mode*), elles sont alors en mode furtif afin qu'elles n'aient pas d'adresse IP.

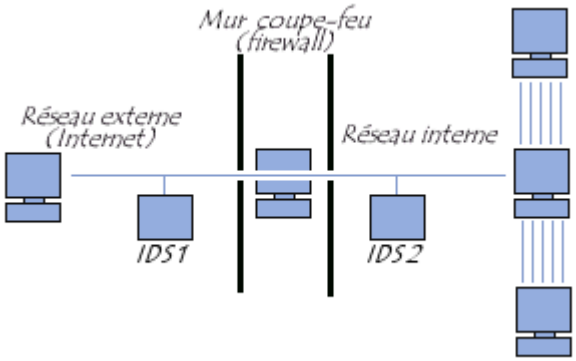

Figure 2 : Fonctionnement d'un IDS [W2]

- Les **HIDS** (Host-Based Intrusion Detection System) qui eux assurent la sécurité au niveau des hôtes. Il réside sur un hôte particulier et la gamme de ces logiciels couvre dans une grande partie des systèmes d'exploitation tels que Windows, Solaris, Linux, HP-UX, Aix, etc…
  Le HIDS se comporte comme un démon ou un service standard sur un système hôte. Habituellement, le HIDS analyse des informations particulières dans les journaux de logs et capture aussi les paquets réseaux entrant/sortant de l'hôte pour y repérer des signaux d'intrusions (déni de services, backdoors, chevaux de Troie, tentatives d'accès non autorisés, etc…).

- **Techniques de détection** :

Un NIDS est capable de capturer les paquets lorsqu'ils circulent sur les liaisons physiques sur lesquelles il est connecté. Pour reconnaître les intrusions, il peut appliquer les techniques suivantes :

- **Vérification de la pile protocolaire** : les intrusions tels que *ping of death* ou encore *TCP stealth scanning* ont tendance à attaquer les ordinateurs en utilisant les violations des protocoles IP, TCP, UDP et ICMP. Dans ce cas, une simple vérification du journal pour mettre en évidence les paquets non valides et signaler ces techniques est suffisante.

- **Vérification de protocoles applicatifs :** cela implique de vérifier que les messages échangés entre les différents composants de l'application respectent le format attendu, que les données sont correctement encodées et décodées, que les erreurs sont gérées de manière appropriée, etc.

- **Reconnaissance des attaques par *pattern matching*** : c'est la plus ancienne des méthodes d'analyse des NIDS et est toujours utilisée.
  Cette technique peut être utile en plus du filtrage de l'adresse IP source, de la destination utilisée dans la connexion et des ports source et/ou destination.

- **IPS (*Intrusion Prevention System*) :**

L'IPS est un système qui vise à prévenir et protéger contre les intrusions, plutôt que simplement les détecter et les signaler comme c'est le cas avec la plupart des IDS. L'IPS signale les événements aux administrateurs système et prend des mesures de précaution telles que la fermeture des points d'accès et la reconfiguration des firewalls pour empêcher de futures attaques. Les IPS analysent tout le trafic réseau pour identifier les différentes menaces, ce qui les rend particulièrement efficaces pour la prévention des intrusions. Il existe de nombreuses menaces différentes pour lesquelles IPS est particulièrement efficace :

- Attaque par déni de service (DDoS)
- Attaque par déni de service distribué
- Ver
- Virus

- **Techniques de détection**

Les IPS sont généralement configurés pour utiliser une variété d'approches pour protéger votre réseau contre les accès non autorisés, notamment :

- **Approche basée sur les signatures** : cette méthode utilise des signatures prédéfinies de menaces réseau déjà connues. Lorsque qu'on a une correspondance entre une attaque et une de ces signatures, le système prend toutes les mesures nécessaires.
- **Approche basée sur les anomalies** : cette approche permet de surveillance tout comportement anormal ou inattendu sur le réseau. Si une anomalie est détectée, le système bloque immédiatement l'accès à l'hôte cible.
- **Approche basée sur les politiques :** nécessite que les administrateurs configurent les politiques de sécurité organisationnelles et de l'infrastructure du réseau. Lorsque qu'une activité viole une politique de sécurité, une alerte est déclenchée et envoyée aux administrateurs.

III.4 – Sécurité informatique

a) Définition

La sécurité informatique peut être défini comme étant un dispositif vaste et multiforme visant à protéger un réseau informatique et ses données contre toute violation, fuite, publication d'informations privées ou contre tout type d'attaque. Elle s'applique aux réseaux, à Internet, aux points de terminaison, aux API, au Cloud, aux applications, aux conteneurs et à bien d'autres ressources.

b) Aspects de la sécurité informatique

La sécurité d'un SI est souvent comparée à une chaîne, car elle ne peut être considérée comme solide que si tous les maillons qui la composent sont sûrs. Autrement dit, le niveau de sécurité d'un système est équivalent à celui du maillon le plus faible. Il est donc crucial de prendre en compte les différents aspects de la sécurité dans un contexte global. Parmi ces aspects, on peut citer :

- **La sécurité physique** : l'objectif est de sécuriser l'accès aux infrastructures matérielles comme les salles serveurs, les postes de travail des personnels et les routeurs à travers un contrôle d'accès.
- **La sécurité logique** : ici, le but sera de sécuriser les données afin que seules les personnes habilitées à les consulter y accèdent.
- **La sécurité des télécommunications** : technologies réseau, serveurs de l'entreprise, réseaux d'accès, etc.
- **La sécurité personnelle** : elle consistera à former les utilisateurs sur les notions de sécurité et les impacts d'une compromission sur le SI. Cela permettrait de limiter les comportements à risque.
- **La sécurité organisationnelle :** c'est au responsable de sécurité d'analyser et de vérifier que chaque règle associée à la politique de sécurité de l'entreprise est correctement appliquée.

c) Objectifs de la sécurité informatique

La sécurité informatique vise généralement cinq objectifs principaux liés aux types de menaces ainsi qu'aux types de ressources. On peut citer :

- **La confidentialité** : le but est de garantir que l'information n'est accessible qu'à ceux dont l'accès est autorisé. Pour toute personne non concernée par une transaction, l'information doit être inintelligible.
- **L'authentification :** vise à s'assurer de la légitimité de la demande d'accès faite par une entité afin d'autoriser ou non son accès à des ressources du SI.
- **L'intégrité :** garantir que les données sont bien celles que l'on croit être. Les données, durant leur traitement, ne doivent subir aucune altération de façon volontaire ou accidentelle.
- **La non-répudiation :** est le fait de veiller à ce qu'une entité ne peut nier son implication dans telle ou telle transaction à laquelle elle a participée (après authentification).
- **La disponibilité :** c'est le processus garantissant l'accès aux ressources d'un système d'informations de manière permanente pour les utilisateurs finaux ou application quand ils en auront besoin.

d) La politique de sécurité

La sécurité du système informatique est généralement limitée à l'accès aux données et aux ressources de système en mettant en œuvre un mécanisme d'authentification et de contrôles qui nous permettent d'assurer les utilisateurs des ressources possèdent seulement les droits qui leur ont été attribués.

Il est important d'étudier la sécurité informatique de manière à ne pas restreindre les utilisateurs dans le développement des utilisations qui leur sont nécessaires, tout en leur permettant d'utiliser le SI en toute confiance. Pour cette raison, il est crucial de commencer par définir une politique de sécurité, qui peut être mise en œuvre en suivant les quatre étapes suivantes :

- **Identifier les besoins** en termes de sécurité, les risques informatiques pesant sur l'entreprise et leurs éventuelles conséquences.
- **Élaborer des règles et des procédures** à mettre en œuvre dans les différents services de l'organisation pour les risques identifiés.
- **Surveiller et détecter les vulnérabilités** du système d'information et se tenir informé des failles sur les applications et matériels utilisés.
- **Définir les actions** à entreprendre et les personnes à contacter en cas de détection d'une menace.

La politique de sécurité est l'ensemble des directives adoptées par une organisation en matière de sécurité. Elle doit être élaborée au niveau de la direction de l'organisation concernée, car elle affecte tous les utilisateurs du système.

La politique de sécurité informatique a pour objectifs principaux de protéger les systèmes d'information et les données sensibles contre les menaces externes et internes, de garantir la disponibilité, l'intégrité et la confidentialité de l'information, et de minimiser les risques de pertes financières, de réputation et de responsabilité légale pour l'organisation. Elle vise également à assurer la conformité aux lois et réglementations en matière de sécurité informatique, ainsi qu'à sensibiliser les utilisateurs aux risques de sécurité et à promouvoir les bonnes pratiques en matière de sécurité informatique.

e) Les frameworks de sécurité

Un **framework de sécurité** est un ensemble de protocoles et de normes documentés qui définissent les meilleures pratiques de sécurité pour gérer les risques, réduire l'exposition aux vulnérabilités et protéger les données contre les menaces potentielles. Les entreprises de toutes tailles et de tous les secteurs peuvent rencontrer des difficultés à protéger leurs systèmes et leurs données sensibles. Pour y remédier, de nombreuses entreprises se tournent vers des frameworks de sécurité pour organiser leur approche. Il offre un plan complet et standardisé qui prévoit de nombreux défis tout en réduisant les incertitudes liées à la protection des données et de l'infrastructure critiques. Dans de nombreux cas, les entreprises peuvent adapter un framework de sécurité existant à leurs propres besoins et exigences en matière de conformité.

Il existe plusieurs frameworks de sécurité qui peuvent être utilisés pour améliorer la sécurité des systèmes d'information, voici quelques exemples :

- **OWASP** : *L'Open Web Application Security Project* est un projet collaboratif qui vise à améliorer la sécurité des applications Web. OWASP fournit des outils, des guides et des formations pour aider les développeurs à créer des applications plus sûres.
- **Série ISO 27000** : cette norme est pour les systèmes de gestion de la sécurité de l'information dans le but de permettre aux responsables de rester au fait des mesures et des contrôles de cybersécurité.
- **HITRUST** : créé pour les organismes de santé, elle couvre tout système d'information qui héberge des données médicales protégées, qu'elles soient en transit ou au repos. Le cadre offre des conseils concrets pour protéger les informations de santé et assurer la conformité avec les réglementations telles que HIPAA.
- **Mitre ATT&CK Framework** (*Adversarial Tactics, Techniques* & Common *Knowledge*) : c'est un modèle de référence pour les tactiques, techniques et procédures utilisées par les attaquants pour compromettre des systèmes informatiques. Il aide les organisations à comprendre les tactiques des attaquants et à renforcer leur sécurité.
- **ANSI/ISA 62443 :** ce framework de sécurité est développé pour les systèmes d'automatisation et de contrôle industriels. Celui-ci s'avère de plus en plus pertinent avec le développement rapide de l'IoT dans la grande consommation comme dans le domaine de la fabrication.

III.5 – Présentation de quelques attaques

À mesure que les entreprises se digitalisent de plus en plus, la surveillance des infrastructures devient encore plus difficile. Résultat, les hackers ayant à leur disposition des technologies de plus en plus sophistiquées, améliore sans cesse l'efficacité de leurs attaques.

Une attaque informatique est tout type d'action volontaire et malveillante menée au moyen d'un réseau informatique dans le but de causer des dommages.

a) Le ransomware

Considérée comme l'une des attaques les plus courantes en 2022, le rançongiciel ou *ransomware* en anglais est une attaque informatique qui bloque l'accès à l'appareil ou aux fichiers d'une victime et exige le paiement d'une rançon en échange de la restauration de l'accès.

Un appareil peut être infecté de plusieurs manières :

- Après avoir ouvert une pièce jointe malveillante ou un lien malveillant reçu dans un e-mail.
- Lorsque vous visitez des sites Web compromis.
- Après que l'ordinateur a pénétré le système de la victime.

Dans la plupart des cas, les cybercriminels exploitent les vulnérabilités connues des logiciels, mais les victimes ne mettent pas à jour leurs correctifs**.**

b) L'attaque par déni de service (DoS)

Une **attaque DoS** est une attaque visant à rendre un service indisponible afin d'empêcher les utilisateurs légitimes du service d'utiliser le service. Il peut s'agir de :

- Inonder le réseau pour entraver son fonctionnement
- Rompre la connexion entre les deux machines et empêcher l'accès à certains services
- Interférer avec l'accès de toute personne au service

Par exemple, une attaque par déni de service peut bloquer un serveur de fichiers, rendre un serveur Web inaccessible ou empêcher la distribution de courrier électronique au sein d'une entreprise.
Les attaques peuvent également être orchestrées depuis plusieurs dispositifs infectés pour lancer une attaque sur un système cible. On parlera dans ce cas, d'une attaque par déni de service distribué (**DDoS**).

c) L'attaque de type « zero-day »

Une vulnérabilité « ***zero-day*** » est une faille dans un code informatique qui peut être exploitée par des pirates avant qu'un correctif ou une solution ne soit mis en œuvre. En fait, après qu'une vulnérabilité rendue publique, les chercheurs en sécurité disposent de "zero day" pour résoudre le problème et les attaquants tentent de voler des informations.

Par exemple, Microsoft Word a subi un exploit zero-day qui a compromis les comptes bancaires personnels en 2017. Les victimes ici étaient des personnes ordinaires qui ont ouvert un document Word malveillant qui affichait une invite pour charger du contenu distant et demandait un accès externe à un autre programme.

d) L’attaque par les objets connectés

Alors que la popularité des objets connectés ne cesse de croître en 2022, les objets comme les enceintes intelligentes et les visiophones, les pirates tentent de les exploiter afin de récupérer de données précieuses. Il existe plusieurs raisons pour lesquelles les pirates ciblent les appareils connectés.

Tout premièrement, la plupart de ces objets n'ont pas assez d'espace de stockage pour installer les mesures de sécurité appropriées. Ils contiennent souvent des données tels que des mots de passe et des identifiants de connexions, facilement accessibles que les pirates peuvent utiliser pour se connecter et voler des comptes d'utilisateurs et dérober des données précieuses telles que les coordonnées bancaires.

Les pirates peuvent également utiliser des microphones et des caméras attachés à vous pour vous espionner et communiquer avec vous.
Ces appareils peuvent également agir comme des vulnérabilités au sein de votre réseau.

e) Le phishing (ou l’hameçonnage)

Autre procédé très utilisé par les attaquants, le ***phising*** ou l’**hameçonnage**.
Il s'agit d'une technique utilisée par les fraudeurs pour obtenir des informations personnelles et usurper l'identité.

Cette technique consiste à faire croire aux victimes qu'elles s'adressent à un tiers de confiance (banque, administration, etc.) pour lui soutirer des données personnelles : mots de passe, numéros de cartes bancaires, numéros ou copies de cartes d'identité, date de naissance, etc.

En effet, le plus souvent, une copie exacte d'un site internet est réalisée dans l'optique de faire croire à la victime qu'elle se trouve sur le site internet officiel où elle pensait se connecter.

f) L’injection SQL

L’attaque par injection SQL vise les sites Web qui proposent des transactions mal construites dont les résultats sont emmagasinés dans une base de données relationnelle. Elle consiste en ceci : SQL est un langage de qui permet d’interroger et de mettre à jour une base à données relationnelle ; les requêtes sont soumises au moteur de la base de données en format texte, sans être compilées. Une requête typique est construite à partir de champs de formulaire remplis par l’internaute. Si l’auteur du site a été paresseux, il aura construit ses requêtes en insérant directement les textes rédigés par l’internaute, sans en contrôler la longueur ni le format et le contenu.
Ainsi un utilisateur malveillant qui soupçonnerait cette faille peut confectionner un texte tel qu’une fois incorporé à une requête SQL il ait des effets néfastes sur la base de données, par exemple en y insérant directement des ordres du langage, de telle sorte qu’ils soient interprétés.

g) Le cross-site scripting (XSS)

Les attaques de type XSS (*Cross-Site Scripting*) sont des attaques qui visent les sites web affichant du contenu utilisateur sans effectuer de contrôle et d'encodage des informations saisies. Ces attaques consistent à forcer un site web à afficher du code HTML ou des scripts saisis par l'utilisateur, qui sont ensuite inclus dans le site web vulnérable de manière malveillante.

Les sites web affichent souvent des messages d'information qui reprennent directement les paramètres entrés par les utilisateurs, comme les pages d'erreur 404. Certains sites modifient également le comportement du site web pour afficher un message d'erreur personnalisé lorsque la page demandée n'existe pas, ce qui permet à un pirate informatique de faire afficher ce qu'il souhaite en remplaçant la page inexistante par une autre chaîne de caractères.

Si aucun contrôle n'est effectué sur le contenu fourni par l'utilisateur, il est possible d'afficher du code HTML arbitraire sur une page web, de changer son apparence, son contenu ou son comportement. De plus, la plupart des navigateurs ont la capacité d'interpréter des scripts contenus dans les pages web, ce qui permet à un pirate informatique d'injecter du code arbitraire dans la page web pour qu'il soit exécuté sur le poste de l'utilisateur.

III.6 – Importance de la gestion des logs et leurs limites

a) Généralités sur les logs

Un fichier log peut être défini comme un enregistrement des événements survenus sur un serveur, un ordinateur ou bien une application. Ce fichier journal présenté sous forme de fichier ou équivalent, répertorie et horodate toutes les informations relatives à un événement spécifique qui s’est produit au sein d’un système ou d’un réseau.
Par exemple, les journaux incluent les connexions réseau, les actions de création ou de suppression de fichiers, les tentatives d'accès, etc., ainsi que les messages entre différents utilisateurs du logiciel de communication.
Ces informations incluses vous aident à mieux comprendre l'utilisation et à résoudre les erreurs.
Donc un fichier log est un ensemble d’informations enregistrées sous un format spécifique.

b) Le format des logs

Un fichier log contient au moins les éléments suivants :

- **Événement survenu**
- **Date et heure de l’événement**
- **Identifiant de l’utilisateur, le plus souvent une adresse IP**

Pour une exploitation facile des fichiers logs, ils doivent avoir un format commun bien reconnu par la majeure partie des outils d’analyse de logs. En effet, Les formats de journal varient considérablement selon le système, l'application et l'outil, mais il existe des formats de journal couramment utilisés.

JSON

JavaScript Object Notation (**JSON**) est l'un des formats de journaux les plus couramment utilisés. Les journaux JSON sont semi-structurés et contiennent plusieurs paires clé-valeur. Il permet au fichier log d'imbriquer des données à différents niveaux tout en conservant un format facilement lisible par les humains. JSON fournit également des moyens de gérer les types de données tels que les chaînes, les nombres, les booléens, les valeurs nulles/vides, les objets et les tableaux.

Il n'y a pas de limite au nombre ou aux types de champs que vous pouvez inclure. Cela fonctionne bien avec les bases de données NoSQL, mais peut nécessiter un travail supplémentaire de la part de l'auteur du journal pour assurer la cohérence du type de champ entre l'application et la source du journal.

Exemple de fichier log au format JSON

```
{
  "horodatage": "2022-07-29T02:03:45.293Z" ,
  "message": "L'utilisateur Jane.Doe s'est connecté" ,
  "journal": {
    "niveau": "infos" ,
    "fichier": "auth.c" ,
    "ligne": 66 ,
  } ,
  "utilisateur": {
    "name": "jane.doe" ,
    "identifiant": 235
  } ,
  "événement": {
    "succès": vrai
  }
}
```

Figure 3 : Log au format JSON [W3]

Journaux d'événements Windows

Les journaux d'événements Windows contiennent des données sur les événements qui se produisent dans le système d'exploitation Windows. Les événements de sécurité, d'application, de système et DNS sont des exemples de journaux d'événements Windows et utilisent tous le même format de journal.

Ces logs sont souvent utilisés par les administrateurs système pour résoudre les erreurs système ou d'application, enquêter sur les incidents de sécurité ou suivre les connexions des utilisateurs. Ils sont généralement très détaillés et contiennent des informations telles que l'horodatage, l'identifiant de l'événement, le nom d'utilisateur, le nom d'hôte, le message et la catégorie de tâche.

Exemple de fichier log sous Windows

```
Nouvelle connexion :
    ID de sécurité : AzureAD\RandyFranklinSmith
    Nom du compte : rsmith@montereytechgroup. com
    Domaine du compte : AzureAD
    ID de connexion : 0xFD5113F
    ID de connexion lié : 0xFD5112A
    Nom du compte réseau : -
    Domaine du compte réseau : -
    GUID de connexion : { 00000000 - 0000 - 0000 - 0000 - 000000000000 }

Traitement de l'information:
    ID de processus : 0x30c
    Nom du processus : C:\Windows\System32\lsass. exe

Informations réseau :
    Nom du poste de travail : DESKTOP-LLHJ389
    Adresse réseau source : -
    Port d'origine : -
```

Figure 4 : Log sous Windows [W4]

CLF (Common Log Format)

Le format de journal commun NCSA (CLF) est l'un des plus anciens formats de journal utilisés par les serveurs Web. Il s'agit d'un fichier journal de texte normalisé au format fixe. Cela signifie que les champs ne peuvent pas être personnalisés. Chaque ligne du fichier journal contient :

- Adresse de l'hôte distant
- Nom du journal distant
- Nom d'utilisateur
- Horodatage
- Demande et version du protocole
- Code d'état HTTP
- Octets envoyés

Un trait d'union est utilisé pour représenter les champs qui ne contiennent pas de données pour cet événement, et un signe plus (+) représente un caractère non pris en charge.

Exemple de common log du NCSA :

```
127. 0 . 0.1 - frank [ 10 /Oct/ 2000 : 13 : 55 : 36 -0700 ] "GET /apache_pb.gif HTTP/1.0" 200 2326
```

Figure 5 : Common log du NCSA [W5]

W3C

Le format de fichier journal étendu du W3C est un format de journal hautement personnalisable utilisé par les serveurs Windows IIS. Vous pouvez configurer les champs à inclure pour réduire la taille de vos fichiers journaux et conserver uniquement les informations pertinentes. Les champs disponibles sont :

- Horodatage

- IP du client
- IP du serveur
- Racine URI
- Code d'état HTTP
- Octets envoyés
- Octets reçus
- Temps pris
- Version

Exemple de log du W3C

```
#Logiciel : Internet Information Services 6.0
#Version : 1.0
#Date : 2001-05-02 17:42:15
#Champs : heure c-ip cs-method cs-uri-stem sc-status cs-version
17 : 42 : 15 172.16 . 255 . 255 GET /par défaut. htm 200 HTTP/ 1.0
```

Figure 6 : Fichier log au format W3C [W6]

CEF (Common Format Log)

Le Common Event Format (CEF) est un format de journal ouvert basé sur du texte utilisé par les appareils et les applications liés à la sécurité. Développé par ArcSight Enterprise Security Manager, CEF est utilisé dans la collecte et l'agrégation de données par les systèmes SIEM et de gestion des journaux.

Le journal CEF utilise le codage UTF-8 et inclut un préfixe commun, un en-tête CEF et une extension de variable contenant une liste de paires clé-valeur.

Le préfixe contient l'horodatage et le nom d'hôte de l'événement. Les en-têtes incluent la version du logiciel CEF, le fabricant de l'appareil, le produit de l'appareil, la version de l'appareil, l'ID de classe d'événement de l'appareil, le nom et la gravité. Le reste du message de journal contient des champs personnalisés supplémentaires pour l'enrichissement.

Exemple d'entrée qui utilise le CEF

```
CEF : 0 |Trend Micro|Deep Security Manager| < Version DSM > | 600 |Utilisateur connecté | 3 |src=
10.52 . 116 . 160 suser=admin target=admin msg=Utilisateur connecté depuis 2001 : db8 :: 5
```

Figure 7 : Fichier log au format CEF [W7]

c) Les différentes catégories de logs

Les logs sont des enregistrements des événements qui se produisent dans un système informatique. Ils sont souvent classés en niveaux de gravité pour aider les administrateurs système à identifier rapidement les problèmes et les erreurs. Les niveaux de gravité les plus courants sont les suivants :

- **DEBUG** : ce niveau de gravité est utilisé pour les messages de débogage qui sont destinés aux développeurs et ne sont généralement pas pertinents pour les administrateurs système.
- **INFO** : ce niveau de gravité est utilisé pour les messages d'information qui indiquent que tout fonctionne normalement dans le système.
- **WARNING** : ce niveau de gravité est utilisé pour les messages d'avertissement qui indiquent des situations potentiellement problématiques, mais qui ne sont pas critiques.
- **ERROR** : ce niveau de gravité est utilisé pour les messages d'erreur qui indiquent des problèmes qui doivent être résolus.
- **CRITICAL** : ce niveau de gravité est utilisé pour les messages critiques qui indiquent des problèmes graves qui nécessitent une intervention immédiate.

d) La gestion des logs

Avant de pouvoir utiliser les logs, il faudrait d'abord les collecter. Pour optimiser cette collecte, il est nécessaire d'identifier les logs d'intérêts en fonction des systèmes.
En effet pour assurer la sécurité au niveau d'un environnement IT, l'identification des logs qui permettent la détection d'événements suspects, serait un premier pas. Comme par exemple les **logs Web**, les **logs systèmes** et les **logs réseau**.
L'ANSSI recommande d'ailleurs des logs d'intérêts à gérer dans le cadre d'une surveillance de la sécurité d'un SI :

- **Authentification**
- **Gestion des comptes et des droits**
- **Accès aux ressources**
- **Modification des stratégies de sécurité**
- **Activité des processus**
- **Activité des systèmes**

La gestion de la collecte de logs consistera à mettre en place la journalisation et la centralisation. La **journalisation** sera la mise en place d'un système permettant la remontée des logs de manière automatique. Et quant à la **centralisation,** elle permettra l'envoi des fichiers journaux en un endroit central sûr et accessible rapidement, ce qui nous permettra d'avoir une vue de bout en bout sur tous les événements du SI.

e) L'utilité de la gestion des logs

Les fichiers logs peuvent servir à de nombreuses choses comme à titre d'exemple de remontée à la source de vols ou de tentatives d'accès frauduleuses. C'est pourquoi les logs constituent un composant essentiel de tout système informatique.
La gestion des logs permet également :

- **De surveiller les performances de l'infrastructure.**
- **De détecter les intrusions à travers des règles de SIEM ou d'IDS/IPS**
- **Suivre le comportement des utilisateurs**
- **Anticiper et mettre en place les mesures de gestion d'incident**
- **De pouvoir suivre l'historique et les actions d'un attaquant dans le cadre d'une investigation forensic.**

- **Enquêter sur les incidents de sécurité**

La collecte et le stockage constituent une première étape importante dans la gestion des logs. Mais la véritable valeur ajoutée commence à émerger avec l'analyse des logs grâce aux outils SIEM.

CHAPITRE III : PRÉSENTATION DES SIEM

IV.1 – Historique des SIEM

Le SIEM existe depuis plus de dix ans et a considérablement évolué depuis que Gartner a inventé le terme en 2005. Il ne fait peut-être pas couler autant d'encre que les technologies d'IA, mais il reste crucial pour la détection des menaces dans un paysage IT et de sécurité toujours plus complexe et en progression.

Les solutions de gestion des informations et des événements de sécurité aident les organisations à détecter, analyser et répondre aux menaces de sécurité avant qu'elles ne nuisent à leur activité professionnelle. Ces outils SIEM offrent une nouvelle génération de fonctionnalité de détection, d'analyse et de réponse. Les SIEM combine à la fois, la gestion des informations de sécurité (**SIM**) et la gestion des événements de sécurité (**SEM**) pour analyser les alertes de sécurité générées par les applications et le matériel réseau en temps réel.

Le **SIM** (Security Information Management) offre la possibilité de stocker et d'indexer toutes les traces du système à des fins d'analyse et de création de rapports. Ils sont capables d'une simple corrélation en partant de ce qui vient après et sont souvent orientés "conformité" (par exemple, PCI-DSS). Les SIM sont également connus sous le nom d'outil de « *Log Management* ».

Le **SEM** (Security Event Management) fournit un traitement des événements en temps réel pour extraire les alertes, les normaliser, les corréler et notifier les opérateurs en temps réel des menaces dans la console d'administration.

Ils comparent les événements avec les règles et les moteurs d'analyse, puis les indexent pour effectuer des recherches instantanées pour la détection et l'analyse avancées des menaces à l'aide d'une Threat Intelligence issue du monde entier.

Ainsi, les solutions SIEM offrent aux organisations une visibilité sur l'activité du réseau afin qu'elles puissent réagir rapidement aux cyberattaques potentielles et répondre aux exigences de conformité. Au cours de la dernière décennie, la technologie SIEM a évolué. La détection des menaces et la réponse aux incidents sont désormais plus intelligentes et plus rapides grâce à l'intelligence artificielle.

IV.2 – Rôles et fonctionnement

Compte tenu du nombre d'événements générés par les composants du système d'information, ils sont difficiles à traiter à la volée. On a besoin de pouvoir les récupérer, traiter les données brutes, les analyser pour intervenir si nécessaire, et enfin archiver le tout comme preuve.

Un SIEM est un outil de sécurité informatique qui permet de collecter, centraliser et analyser les données relatives à la sécurité de l'ensemble d'un système d'information.

a) Rôles d'un SIEM

Le rôle principal d'un SIEM est de fournir une vue d'ensemble de la sécurité du système d'information en permettant la corrélation et l'analyse des événements de sécurité provenant de diverses sources telles que les pare-feux, les systèmes de détection d'intrusion (IDS), les systèmes de prévention d'intrusion (IPS), les antivirus, les serveurs, les applications, etc… Le SIEM permet ainsi de détecter les menaces et les attaques potentielles en temps réel ou de manière différée en effectuant des analyses de données historiques.

Le SIEM permet également de générer des alertes et des rapports en cas d'incidents de sécurité, de faciliter la réponse aux incidents de sécurité et de soutenir les activités d'investigation et de forensics.

b) Fonctionnement d'un outil SIEM

Le logiciel **SIEM** collecte les données des journaux et des événements générées par les applications, les dispositifs de sécurité et les systèmes hôtes et les consolide en une seule plate-forme centrale. Il collecte les données des antivirus, des journaux de pare-feu et d'autres systèmes et les classe en différentes catégories (activité malveillante, échecs de connexion, succès de connexion, etc…). Lorsque les outils SIEM identifient des menaces sur votre réseau, ils génèrent des alertes et attribuent des niveaux de gravité en fonction de règles prédéfinies.

De plus, les SIEM ont évolué pour inclure l'analyse du comportement des utilisateurs et des entités (**UEBA**) de la même façon que l'orchestration de la sécurité et réponse automatisée (**SOAR**).

La conformité aux normes de sécurité des données de l'industrie des cartes de paiement (PCI DSS) a conduit à l'adoption du SIEM dans les grandes entreprises.

Aujourd'hui, la plupart des organisations déploient plusieurs collections d'agents de manière hiérarchique pour collecter les événements liés à la sécurité du système. Des serveurs et périphériques réseau aux pare-feu, antivirus ou autres systèmes de prévention des intrusions. Par conséquent, les collecteurs envoient des événements à la console de gestion centrale. Là, les analystes de la sécurité les trient, hiérarchisent les incidents de sécurité et relient les points. Ainsi, la quantité d'informations communiquées et stockées peut être réduite. Les progrès de l'apprentissage automatique nous permettent d'identifier les anomalies avec plus de précision, mais les analystes doivent encore fournir des commentaires. Améliorant ainsi, le système de protection de l'environnement IT.

Les SIEM assurent donc :

- **La collecte des données :**

Le logiciel SIEM prend en entrée les événements collectés par le SI, les logs système des équipements (firewalls, routeurs, serveurs, bases de données, etc.). Différents formats (*syslog*, trap SNMP, fichier plat, OPSEC, formats propriétaires) peuvent être envisagés ou le format natif IDMEF (Intrusion Detection Message Exchange Format) spécifiquement développé et validé par l'IETF.
Une collecte peut être **passive** en écoutant simplement les échanges sur le réseau, ou elle peut être **active** en installant un agent directement ou à distance sur l'appareil. La solution permet également de développer des collecteurs pour les nouveaux formats de journaux système (API, expressions régulières, etc.).

- **Leur normalisation :**

Les traces brutes sont stockées sans altération pour préserver leur valeur légale. On parle de preuves. Ces traces sont généralement copiées puis normalisées dans un format plus lisible. En effet, la normalisation permet de rechercher par plusieurs critères, champs ou dates. Ces événements sont enrichis d'autres données et envoyés au moteur de corrélation.

- **Leur agrégation :**

On applique plusieurs règles de filtrage. Ils sont ensuite agrégés selon la solution et envoyés au moteur de corrélation.

- **La recherche de corrélation :**

Les règles de corrélation permettront d'identifier un événement qui a provoqué la génération de plusieurs autres événements, tels qu'un pirate pénétrant dans votre réseau et altérant un tel appareil. Les alertes peuvent également être déclenchées par des traps, des emails, des SMS ou l'ouverture d'un ticket si votre solution SIEM est connectée à un outil de gestion de tickets.

- **Le reporting :**

Les SIEM permettent également la création et la génération de tableaux de bord et de rapports. Ainsi, différents acteurs du SI, RSSI, administrateurs et utilisateurs peuvent avoir un aperçu du SI (nombre d'attaques, nombre d'alertes par jour, etc.).

- **L'archivage :**

Les solutions SIEM sont également utilisées pour des raisons légales et réglementaires. Les archives factuelles permettent de garantir l'intégrité des traces.
Cette solution vous permet d'utiliser des disques en RAID, de calculer des empreintes digitales, d'utiliser le cryptage et bien plus encore pour garantir l'intégrité des pistes**.**

- **Le rejeu des événements :**

La plupart des solutions permettront également de rejouer d'anciens événements pour une enquête post-incident. On peut également modifier les règles et rejouer l'événement pour voir comment cela fonctionne.

IV.3 – Les avantages et les limites des SIEM

a) Les avantages

Les outils SIEM présentent de nombreux avantages qui peuvent aider à renforcer la posture de sécurité globale au sein d'une organisation, notamment :

- **Une vue centralisée des menaces potentielles** :
  Les solutions SIEM aident les organisations à détecter les menaces internes et externes en surveillant les événements de sécurité en temps quasi réel, en émettant des alertes automatisées et en analysant l'activité des applications ou des utilisateurs.
- **Une détection et réponse aux menaces en temps réel** :
  Les solutions SIEM permettent d'effectuer des recherches dans les données historiques, afin de réagir aux incidents de sécurité et de réaliser des analyses forensiques.
- **Conservation des journaux** :
  Le stockage à long terme des journaux est souvent nécessaire à des fins de forensique et pour se conformer aux normes sectorielles. En général, les organisations génèrent quotidiennement un volume important de données de journaux, et les solutions SIEM peuvent les accompagner dans leur conservation.
- **Audits et rapports de conformité réglementaire** :
  Au-delà des exigences de sécurité, les organisations peuvent également utiliser la technologie SIEM pour répondre aux exigences de reporting imposées par les normes de conformité telles que HIPAA, PCI-DSS, SOX, FERPA et HITECH.
- **Une visibilité accrue sur la façon dont les utilisateurs, applications et appareils sont surveillés** : parcourir les pools de journaux et générer des rapports est l'utilisation la plus simple d'un SIEM. Les organisations peuvent obtenir des réponses à des questions telles que "Qui s'est connecté au système pendant ces heures ?".

b) Les limites

Le SIEM présente en effet des limites qu'il est important de prendre en compte avant de l'adopter dans une stratégie de sécurité. Les principales limites sont :

- Les SIEM sont des outils **complexes et coûteux** qui nécessitent un haut niveau de maturité en matière de sécurité informatique, ainsi qu'une expertise spécialisée de l'équipe IT. Ils nécessitent également des ajustements fréquents et d'autres formes de gestion pour suivre l'évolution constante des environnements IT et du paysage des menaces.
- Comme mentionné précédemment, les SIEM se basent sur des règles de corrélation qui sont appliquées sur de nombreuses sources de logs. Cela peut entraîner la génération de nombreux **faux positifs**, ce qui peut rapidement submerger les équipes chargées de la gestion des alertes. Le risque est alors que de véritables incidents ne soient pas traités dans cette masse d'alertes erronées. Il est donc urgent de développer des approches analytiques qui permettent de réduire au moins le taux de faux positifs, afin de garantir une meilleure détection des incidents réels.
- Le SIEM se repose sur des règles de corrélation pour identifier d'éventuelles attaques. Cependant, il est incapable d'anticiper des événements malveillants, car sa capacité à détecter dépend étroitement des règles établies par les administrateurs, et ne peut donc pas identifier des événements inconnus par l'administrateur. Étant donné que les menaces et les attaques sont en constante évolution, il devient crucial de pouvoir attribuer un score de

sécurité à chaque événement survenant dans un SI, afin de déterminer si cet événement présente un risque potentiel pour une attaque future ou non.

- Les SIEM se basent sur les journaux provenant de différents équipements de sécurité pour détecter des événements malveillants. Toutefois, la journalisation n'est pas encore largement adoptée ni mature pour certains équipements de sécurité, ce qui empêche les SIEM (à l'exception des formats SYSLOG) d'exploiter les journaux d'événements pour ces équipements. Cela rend impossible la surveillance du périmètre couvert par ces équipements. Ainsi, des modifications doivent être apportées dès la source de la génération du log pour permettre leur exploitation par les SIEM.

Il est donc important pour les organisations de comprendre ces limites et de prendre des mesures pour y remédier, par exemple en investissant dans une expertise spécialisée, en paramétrant correctement les SIEM, ou en utilisant des outils supplémentaires pour compléter les lacunes des SIEM.

IV.4 – SIEM et SOC

a) Définition d'un SOC

Un **SOC** (*Security Operations Center*) est un centre de sécurité informatique chargé de la détection, de l'analyse et de la réponse aux incidents de sécurité. Il s'agit d'une entité organisée qui regroupe des experts en sécurité informatique, des analystes et des techniciens qui travaillent ensemble pour protéger le Si d'une organisation contre les menaces.

Le SOC a pour mission de surveiller en permanence le système d'information de l'entreprise, de détecter les incidents de sécurité, de les analyser et de les traiter de manière appropriée. Les activités du SOC incluent la surveillance de l'infrastructure de sécurité, l'analyse des alertes de sécurité, la réponse aux incidents, la gestion des vulnérabilités, l'application des politiques de sécurité et la coordination avec d'autres équipes de l'entreprise.

Le SOC peut utiliser divers outils et technologies de sécurité, tels que les SIEM, les systèmes de détection d'intrusion, les antivirus, les firewalls, les scanners de vulnérabilités et les outils d'analyse de sécurité.

b) Rôle du SIEM dans le SOC

Si la technologie de surveillance et de processus est essentielle pour la sécurité, l'analyse approfondie des données provenant du **SIEM** est effectuée par des analystes experts travaillant au sein d'un **SOC** mutualisé qui surveille les infrastructures tout le temps. Le SOC ajoute une couche organisationnelle en intégrant des processus de gestion des incidents et une valeur ajoutée humaine avec une équipe d'experts capables de mener des investigations numériques ou forensiques et de mettre en place des plans de réponse aux incidents, tout en respectant les règles et règlements en vigueur (RGPD, NIS, ...).

Bien que le SIEM utilise l'intelligence artificielle et le Machine Learning pour l'analyse comportementale, les équipes apportent une expertise qui va bien au-delà du logiciel. Les analystes SOC analysent en profondeur les incidents (analyse du signal remonté par le SIEM et de la technique utilisée par l'attaquant), utilisent des méthodes d'analyse syntaxique appelées ***parsing***, développent des règles et des cas d'utilisation spécifiques à chaque secteur d'activité, puis proposent des pistes d'amélioration. Leur connaissance des menaces est

constamment enrichie par les incidents traités pour d'autres personnes dans le cas d'un SOC mutualisé, ce qui améliore la pertinence des analyses et des recommandations, ainsi que par une cellule CTI (*Cyber Threat Intelligence*) qui fournit des informations de valeur ajoutée provenant de la communauté mondiale de la cybersécurité.

Les processus mutualisés et éprouvés du SOC renforcent la gouvernance de la sécurité de l'entreprise, en complément du SIEM. Toutefois, cela nécessite que les entreprises soient capables de modéliser les risques.

Ainsi, le SIEM est un élément central du SOC, permettant aux équipes de sécurité de surveiller de manière proactive les systèmes d'information de l'entreprise, de détecter rapidement les incidents de sécurité et de les traiter de manière efficace.

IV.5 – Les recommandations pour la mise en place d'un SIEM

a) Les caractéristiques d'un SIEM

Afin de simplifier l'évaluation des outils, voici les principales caractéristiques à considérer lors de la mise en place d'une solution SIEM :

- **Supervision en temps réel**

Les attaques surviennent rapidement et leur prise en charge tardive peut causer des dommages considérables. C'est pourquoi votre SIEM doit fournir une vue globale en temps réel de ce qui se passe sur votre réseau, en incluant les activités associées aux utilisateurs, appareils et applications, ainsi que toute activité qui n'est pas spécifiquement liée à une identité. Il est important d'avoir des fonctions de surveillance applicables à tous les groupes de données stockés localement, dans le cloud ou de manière hybride.

En plus de la surveillance, il est crucial de pouvoir synthétiser les informations dans un format utilisable. Il est donc recommandé de choisir un outil SIEM accompagné d'une bibliothèque de règles de corrélation personnalisables et prédéfinies, d'une console d'événements de sécurité présentant en temps réel les incidents et les événements de sécurité, ainsi que de tableaux de bord affichant des visualisations en direct des activités menaçantes.

- **Réponse aux incidents**

Il est essentiel qu'un SIEM axé sur l'analyse comprenne des capacités de réponse automatique pour interrompre les cyberattaques en cours. En outre, il doit être capable d'identifier les événements importants et leur état, de déterminer la gravité des événements notables, de lancer un processus de correction et de fournir un audit complet du processus entourant l'incident.

- **Supervision des utilisateurs**

Les menaces internes sont une préoccupation croissante pour les entreprises car elles peuvent être causées par des utilisateurs malveillants ou simplement par des erreurs humaines. Les outils de SIEM peuvent aider à détecter ces menaces en surveillant les données d'accès et d'authentification des utilisateurs, en établissant le contexte de l'utilisateur et en produisant

des alertes en cas de comportement suspect ou d'infraction aux politiques de l'entreprise et aux directives réglementaires.

Il est important de surveiller de près les utilisateurs privilégiés, qui ont souvent un accès plus étendu aux systèmes et aux données sensibles. Les réglementations de conformité dans certaines industries réglementées, telles que la finance et la santé, imposent souvent des exigences spécifiques en matière de surveillance des utilisateurs privilégiés.

- **Intelligence des menaces**

Votre système de gestion des informations et événements de sécurité devrait être capable d'identifier les principales menaces externes, telles que les exploits "zero-day" et les menaces persistantes avancées. En utilisant des informations sur les menaces, vous pourrez non seulement détecter des activités suspectes, mais également identifier les vulnérabilités dans votre stratégie de sécurité avant qu'elles ne soient exploitées, et planifier des mesures de réponse et de correction.

- **Analyse avancée et machine learning**

Il est important de noter que l'outil SIEM ne suffit pas à lui seul pour comprendre toutes les données du monde. Il est crucial d'obtenir des informations claires à partir de ces données. L'analyse avancée utilise des méthodes quantitatives sophistiquées, telles que les statistiques, l'analyse descriptive et prédictive des données, la simulation et l'optimisation, pour produire des informations plus détaillées.

Les outils SIEM qui utilisent le machine learning peuvent apprendre au fil du temps à distinguer un comportement normal d'une anomalie, améliorant ainsi leur précision. Cette précision est d'une importance cruciale aujourd'hui, où la technologie, les vecteurs d'attaque et la sophistication des hackers évoluent plus rapidement que jamais.

- **Détection des menaces avancées**

La plupart des pare-feux et des systèmes de protection contre les intrusions ne sont pas suffisamment adaptés aux nouvelles menaces avancées en termes de sécurité. C'est pourquoi le SIEM doit remplir plusieurs fonctions, telles que la surveillance du réseau, la détection des points de terminaison, l'isolation des problèmes et l'analyse des comportements pour identifier et mettre en quarantaine les nouvelles menaces potentielles. Il ne s'agit pas simplement de détecter les menaces. Il est également important de comprendre la gravité de la menace, ses mouvements une fois qu'elle a été détectée et comment la contenir.

- **Gestion transparente des logs**

Il est important de souligner que votre SIEM doit être capable non seulement de collecter des données à partir de centaines ou de milliers de sources, mais également de proposer une interface conviviale et intuitive pour gérer et obtenir les données de journalisation.

- **Évolutivité**

Lorsque vous choisissez votre SIEM, il est essentiel de veiller à ce qu'il réponde à la fois à vos besoins actuels et futurs, en anticipant la croissance de votre entreprise et l'expansion de votre empreinte informatique.

b) Les meilleurs pratiques pour l'implémentation d'un SIEM

Pour tirer le meilleur parti des SIEM, les organisations doivent suivre les meilleures pratiques pour l'implémentation et l'utilisation de ces solutions. Voici quelques-unes des meilleures pratiques pour les SIEM :

- **Évaluation des besoins** : avant de mettre en place un SIEM, il est important d'effectuer une évaluation des besoins pour déterminer les exigences de sécurité et les besoins opérationnels de l'organisation.
- **Planification de la mise en œuvre** : la planification de la mise en œuvre du SIEM doit inclure la définition des objectifs, l'identification des sources de données, la configuration des paramètres de sécurité et la formation des utilisateurs.
- **Collecte de données** : les SIEM doivent être configurés pour collecter des données à partir de sources clés telles que les journaux de sécurité, les appareils réseau, les applications et les bases de données.
- **Corrélation des données** : la corrélation des données de sécurité à partir de différentes sources est essentielle pour détecter les menaces potentielles. Les organisations doivent configurer les règles de corrélation pour s'assurer que les alertes sont pertinentes et précises.
- **Analyse des données** : les organisations doivent être en mesure d'analyser les données de sécurité pour identifier les tendances, les modèles et les anomalies, ainsi que pour détecter les menaces potentielles.
- **Intégration avec d'autres outils de sécurité** : les SIEM doivent être intégrés avec d'autres outils de sécurité tels que les solutions de détection d'intrusion et les scanners de vulnérabilités pour améliorer la détection des menaces.
- **Formation des utilisateurs** : les utilisateurs du SIEM doivent être formés à l'utilisation de la solution pour s'assurer qu'ils sont en mesure de tirer le meilleur parti de la solution.
- **Gestion des incidents** : les entreprises doivent mettre en place des processus de gestion des incidents pour répondre rapidement aux alertes de sécurité et minimiser les perturbations dans les opérations commerciales.
- **Révision régulière** : il est important d'effectuer des révisions régulières de l'efficacité du SIEM pour s'assurer que la solution est toujours en mesure de répondre aux exigences de sécurité de l'organisation.

Les SIEM sont donc des solutions essentielles pour améliorer la sécurité des systèmes informatiques. Pour tirer le meilleur parti des SIEM, les entreprises doivent suivre les meilleures pratiques pour l'implémentation et l'utilisation de ces solutions. Les SIEM doivent être configurés correctement, intégrés avec d'autres outils de sécurité, les utilisateurs doivent être formés à leur utilisation, et les processus de gestion des incidents doivent être en place pour minimiser les perturbations dans les opérations commerciales. Les révisions régulières de l'efficacité du SIEM sont également nécessaires pour s'assurer que la solution est toujours en mesure de répondre aux exigences de sécurité de l'organisation.

IV.6 – Étude comparative de quelques solutions SIEM

Les solutions SIEM sont conçues pour aider les organisations à collecter, stocker, analyser et signaler les données de sécurité de leurs systèmes informatiques. Il existe de nombreuses solutions SIEM sur le marché, chacune avec ses propres fonctionnalités et avantages. Dans cette étude comparative, nous allons comparer les principales solutions SIEM les plus utilisées sur le marché actuellement :

a) IBM QRadar

Figure 8 : Logo d'IBM QRadar

IBM QRadar est une solution SIEM qui offre une plate-forme d'analyse de données en temps réel pour les entreprises de toutes tailles. QRadar collecte et analyse les données de sécurité en temps réel et offre une visualisation en temps réel des événements de sécurité. QRadar offre également une solution d'analyse de sécurité, qui permet aux utilisateurs de créer des tableaux de bord personnalisés pour visualiser les données de sécurité et les événements de sécurité.

Caractéristiques

IBM QRadar offre une gamme complète de fonctionnalités pour aider les organisations à détecter, analyser et répondre aux menaces de sécurité. Voici quelques-unes des principales fonctionnalités de QRadar :

- **Corrélation des événements** : QRadar collecte des événements de sécurité à partir de différentes sources, les corrèle et les analyse en temps réel pour identifier les menaces potentielles.
- **Analyse comportementale** : il intègre l'analyse comportementale pour identifier les anomalies et les comportements inhabituels sur les réseaux et les systèmes.
- **Surveillance du réseau** : il surveille le trafic réseau pour détecter les activités suspectes et les attaques potentielles.
- **Gestion des vulnérabilités** : ce SIEM intègre des fonctionnalités de gestion des vulnérabilités pour identifier les vulnérabilités critiques dans les systèmes et les applications.
- **Analyse des journaux d'audit** : il collecte et analyse les journaux d'audit pour identifier les activités suspectes et les violations de la politique de sécurité.
- **Gestion des incidents** : permet aux équipes de sécurité de suivre et de gérer les incidents de sécurité de manière centralisée.
- **Tableau de bord et rapports** : offre des tableaux de bord personnalisables et des rapports de sécurité pour aider les organisations à suivre leur posture de sécurité et à répondre aux exigences réglementaires.
- **Intégration de tiers** : QRadar offre une intégration avec des centaines de solutions de sécurité tierces pour une visibilité et une réponse plus rapide aux menaces.

Architecture et composants

IBM QRadar est un système qui collecte, traite, agrège, corrèle, stocke et présente les données de tous les terminaux abonnés en temps réel. Ces données sont nettoyées pour vous fournir des informations et des alertes pour surveiller votre infrastructure informatique. Les alertes et les réponses aux menaces sont prises en flagrant délit pour une intervention rapide.

En plus des modules de base, vous pouvez ajouter des modules pour renforcer votre déploiement. Par exemple, le module Incident Forensics vous permet d'analyser rapidement les mesures prises par un acteur malveillant et de tirer des conclusions basées sur les artefacts laissés derrière. Cela permet de réduire considérablement le temps nécessaire à une équipe d'intervention pour mener une enquête sur les infractions signalées par QRadar. De plus, cela vous aide à résoudre les violations, à prévenir les pertes de données et les attaques futures.

L'architecture de QRadar fonctionne de la même manière, quelle que soit la taille de votre organisation et le nombre de composants dans un déploiement.

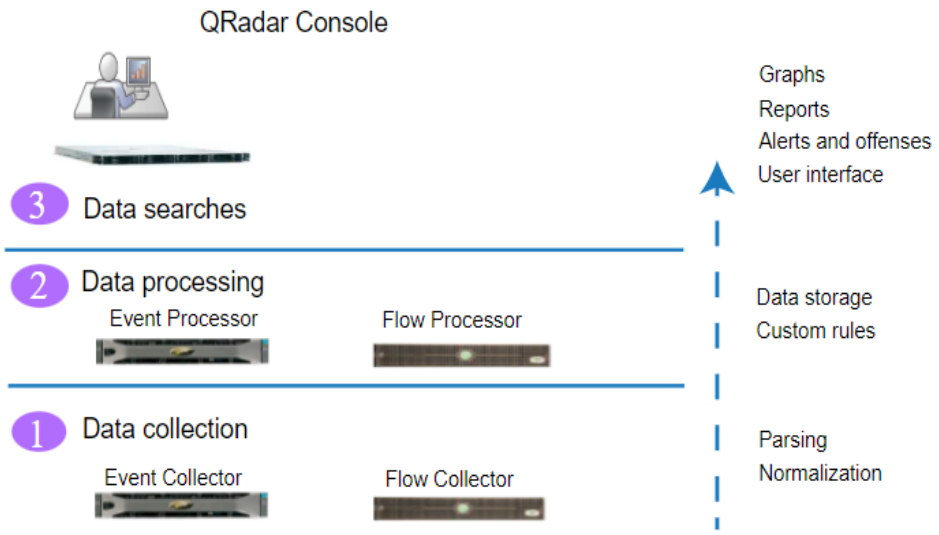

Figure 9 : Architecture de QRadar [W8]

QRadar suit également le concept de superposition architecturale et se compose de trois couches principales, à travers lesquelles les informations sont acheminées des terminaux vers l'agent.

- **Collecte de données**

Cette couche a pour mission de collecter toutes les données de votre réseau, y compris les événements, les fichiers journaux, les flux, l'IPS, le pare-feu, les fichiers de configuration, les captures de paquets, etc. Les données sont généralement collectées à l'aide du protocole Syslog à partir de votre réseau ou de vos applications. Vous pouvez utiliser des collecteurs pour agréger les données d'événement et de flux. Les informations collectées sont ensuite analysées généralement par l'éditeur ***Device Support Model*** **(DSM).** L'étape suivante consiste à normaliser les données pour les présenter dans un format utilisable avant de les traiter. Les fonctions clés de QRadar se concentrent principalement sur la collecte de données de flux et la collecte de données d'événements.

- **Traitement de l'information**

Une fois que les données sont collectées, elles sont acheminées vers la couche de traitement de QRadar. Cette couche utilise un moteur de règles personnalisées (**CRE**) pour filtrer et analyser les événements, et générer des alertes en cas de correspondance avec des règles personnalisées créées par les utilisateurs sur la console. Les événements sont stockés pour la persistance et diffusés en temps réel vers la console, permettant aux analystes de sécurité de surveiller les menaces en cours.

- **Recherche de données**

Les données traitées dans la troisième couche sont mises à disposition des utilisateurs pour des activités telles que la recherche, la création de rapports, l'analyse, l'alerte ou l'enquête sur des infractions. Dans les systèmes répartis, la console n'est pas utilisée pour le traitement des événements et des flux, mais plutôt comme une interface utilisateur principale. Les utilisateurs peuvent effectuer des tâches d'administration nécessaires pour leur réseau à partir de l'interface utilisateur sur la console QRadar. Tous les faits et chiffres sont collectés, traités et stockés sur l'Appliance tout-en-un.

b) Splunk Enterprise Security

Figure 10 : Logo de Splunk

En plus d'être une plateforme logicielle permettant de chercher, d'analyser et de visualiser des données générées à partir des sites Web, d'applications, de capteurs, et d'appareils en tout genre. Splunk est également commercialisé en tant que SIEM pour analyser en temps réel les alertes de sécurité générées par les applications et les matériels réseaux.

La plateforme Splunk utilise une architecture distribuée pour permettre une collecte et une analyse des données en temps réel à grande échelle. Elle est également dotée d'une interface utilisateur conviviale et de fonctionnalités de recherche et de visualisation avancées pour permettre aux utilisateurs de mieux comprendre leurs données et de prendre des décisions éclairées.

Splunk est utilisé dans de nombreux secteurs, notamment l'informatique, la sécurité, l'analyse des données, la gestion des opérations et la conformité réglementaire. La plateforme Splunk est disponible sous forme de logiciel sur site ou dans le cloud, ainsi que sous forme de service géré. En outre, Splunk comporte d'autres produits complémentaires comme :

- **Splunk Enterprise** : s'agit du produit principal de Splunk, qui permet de collecter, d'indexer et de rechercher des données provenant de différents systèmes et applications. Splunk Enterprise offre des fonctionnalités avancées telles que la recherche en temps réel, l'analyse de données volumineuses, la génération de rapports et la surveillance de la sécurité.

- **Splunk Cloud** : c’est une version cloud de Splunk Enterprise, qui permet de collecter, d'analyser et de visualiser des données à partir d'un environnement de cloud privé ou public.
- **Splunk User Behavior Analytics (UBA)** : il s'agit d'un produit de sécurité qui permet de détecter les menaces internes en surveillant les comportements des utilisateurs et en identifiant les anomalies dans les activités de l'utilisateur.
- **Splunk Phantom** : il s'agit d'une plateforme d'automatisation de la sécurité qui permet d'automatiser les processus de sécurité, de réduire le temps de réponse aux incidents de sécurité et d'améliorer la coordination entre les équipes de sécurité.

Il convient de noter que Splunk propose également d'autres produits et solutions, tels que ***Splunk Infrastructure Monitoring***, ***Splunk Connected Experiences, Splunk Data Stream Processor, Splunk Mission Control, Splunk On-Call***, etc…

Caractéristiques

Splunk offre de nombreuses fonctionnalités pour collecter, indexer, analyser et visualiser des données provenant de différents systèmes et applications. Voici les principales fonctionnalités de Splunk :

- **Collecte de données** : Splunk peut collecter des données à partir de différents types de sources, notamment des fichiers journaux, des données de capteurs IoT, des bases de données, des applications web, des services de cloud, etc.
- **Indexation et recherche** : il indexe les données collectées pour permettre une recherche rapide et efficace. Les utilisateurs peuvent effectuer des recherches en temps réel, des recherches par mots clés, des recherches avancées, etc.
- **Visualisation de données** : cet outil offre des fonctionnalités de visualisation de données avancées, telles que des tableaux de bord personnalisables, des graphiques, des cartes, des visualisations en temps réel, etc.
- **Analyse de données** : Splunk offre des fonctionnalités d'analyse de données avancées, telles que l'analyse prédictive, l'analyse de comportement, l'analyse de tendances, l'analyse de corrélation, etc.
- **Sécurité** : Splunk offre des fonctionnalités de sécurité avancées, telles que la surveillance de la sécurité en temps réel, la détection de menaces, la gestion des incidents, la conformité réglementaire, etc.
- **Intégration** : ce SIEM peut s'intégrer à de nombreuses applications et technologies tierces, telles que les plateformes de cloud, les outils de développement, les outils de gestion des services informatiques, les outils de sécurité, etc.
- **Automatisation** : il offre des fonctionnalités d'automatisation avancées, telles que l'automatisation des workflows, la création de règles d'alerte, l'automatisation des tâches, etc.
- **Gestion de données** : Splunk offre des fonctionnalités avancées de gestion de données, telles que la compression des données, la sauvegarde et la récupération, la gestion des versions, la gestion des droits d'accès, etc.

Cependant, il n'y a pas de dispositif ETL, ce qui rend difficile la correction des données et l'effectuation de jointures. Ainsi, il est nécessaire d'avoir un intermédiaire pour effectuer ce travail et fournir des événements en entrée. De plus, l'apprentissage d'un nouveau langage s'ajoute aux autres langages existants. Enfin, le coût par gigaoctet de données traitées est un facteur important à prendre en compte.

Architectures et composants

L'architecture de Splunk se compose de plusieurs composants qui travaillent ensemble pour collecter, indexer, interroger et visualiser les données. Voici une liste des composants clés de l'architecture Splunk :

- **Splunk Forwarder** : c'est un agent léger installé sur les serveurs et les équipements réseau qui collecte les données et les envoie à l'instance *Splunk Indexer*.
- **Splunk Indexer** : il s'agit d'un serveur qui reçoit, traite et stocke les données envoyées par les *Splunk Forwarders*. Les données sont indexées pour permettre une recherche et une analyse rapide.
- **Splunk Search Head** : il s'agit de l'interface utilisateur Web de Splunk qui permet aux utilisateurs de rechercher et d'analyser les données stockées dans Splunk Indexer. Le *Search Head* envoie les requêtes aux *Indexers*, récupère les résultats et les affiche dans l'interface utilisateur.
- **Splunk Deployment Server** : il s'agit d'un serveur qui permet de gérer et de déployer des configurations sur les *Forwarders*. Les administrateurs peuvent utiliser le *Deployment Server* pour déployer des mises à jour de configuration et des applications sur les *Forwarders*.
- **Splunk Universal Forwarder** : il s'agit d'une version légère de *Splunk Forwarder* qui peut être utilisée pour collecter des données à partir de sources non-Splunk telles que des fichiers journaux, des événements système, etc.
- **Splunk Heavy Forwarder** : c'est un agent plus puissant que le Forwarder qui permet de filtrer, de transformer et de normaliser les données avant de les envoyer à *l'Indexer*.
- **Splunk Add-ons** : il s'agit de modules supplémentaires qui permettent de collecter des données à partir de sources spécifiques telles que des applications cloud, des équipements de sécurité, des outils DevOps, etc…

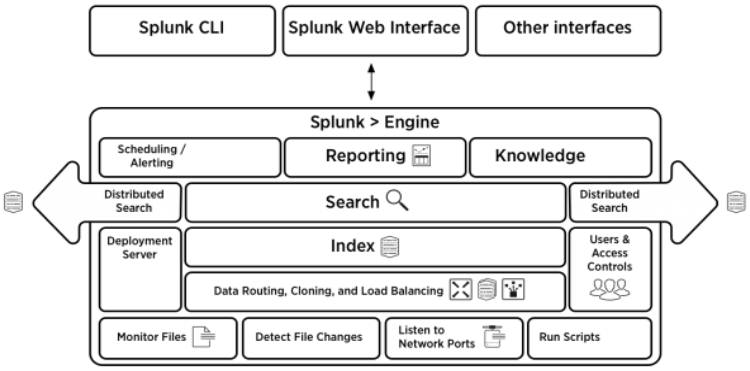

Figure 11 : Architecture de Splunk [W9]

c) ELK (Elastic Logstash Kibana)

Figure 12 : Logo de ELK

ELK est une pile logicielle open source utilisée pour collecter, traiter, stocker et visualiser des données en temps réel. ELK est un acronyme qui représente les trois principaux composants de la pile :

- **Elasticsearch**

Elasticsearch est un moteur de recherche et d'analyse de données open source basé sur Apache Lucene. Il permet de stocker, de rechercher et d'analyser rapidement de grandes quantités de données structurées, semi-structurées et non structurées. Il est souvent utilisé pour l'indexation de données provenant de plusieurs sources et pour fournir des résultats de recherche en temps réel. Il est également utilisé pour l'analyse de données, la surveillance et la visualisation en temps réel.

Il utilise une architecture distribuée pour fournir une haute disponibilité et une extensibilité horizontale. Il peut être déployé sur un cluster de serveurs pour gérer de grandes quantités de données avec une répartition de charge équilibrée. Elasticsearch est également compatible avec plusieurs langages de programmation et offre des bibliothèques de clients pour les développeurs.

Le système de recherche de texte intégré à Elasticsearch est très performant et prend en charge les recherches de texte intégral, les recherches de phrases, les recherches à facettes, les suggestions de termes et les recherches géospatiales. Il est également doté d'un langage de requête appelé ***Query* DSL** pour permettre aux utilisateurs de créer des requêtes complexes.

- **Logstash**

Logstash est un outil open-source de traitement des données qui permet d'ingérer, de traiter et de transférer des données d'une source vers une destination. Il peut être utilisé pour collecter des données à partir de diverses sources telles que les journaux système, les bases de données, les fichiers de données et les files d'attente de messages, et les transférer vers des systèmes de stockage tels qu'Elasticsearch, Kafka ou d'autres systèmes de gestion de logs.

Il utilise une architecture de plug-in modulaire, qui permet aux utilisateurs de personnaliser leur pipeline de traitement des données en ajoutant des plug-ins qui répondent à leurs besoins spécifiques. Il dispose également d'une grande variété de filtres et de codecs qui permettent de manipuler les données en temps réel pour les rendre exploitables et pertinentes.

Logstash peut être déployé de manière autonome ou dans le cadre d'une pile ELK (Elasticsearch, Logstash, Kibana) pour l'analyse de logs.

Dans une pile ELK, Logstash est utilisé pour l'ingestion de données, Elasticsearch pour l'indexation et la recherche, et Kibana pour la visualisation et l'analyse. Logstash peut également être déployé dans le cloud ou dans des conteneurs tels que Docker.

- **Kibana**

Kibana est un outil open-source de visualisation et d’analyse de données qui fonctionne avec Elasticsearch et qui permet de créer des tableaux de bord, des graphiques et des visualisations à partir des données stockées dans Elasticsearch.

Il permet aux utilisateurs de créer des tableaux de bord personnalisés en sélectionnant les types de visualisations et les données qu'ils souhaitent afficher, tels que des graphiques à barres, des nuages de mots ou des cartes géographiques. Les tableaux de bord peuvent également être partagés avec d'autres utilisateurs ou être intégrés dans d'autres applications.

En plus de créer des visualisations, Kibana dispose également de fonctionnalités d'analyse de données qui permettent de **filtrer**, **trier** et **agréger** les données en temps réel pour obtenir des informations plus précises et plus exploitables. Il peut également être utilisé pour suivre les performances des applications, surveiller les erreurs et les anomalies, et effectuer des analyses de tendances. Kibana est facile à installer et à configurer, et il peut être déployé sur site ou dans le cloud.

Il existe également un autre composant nommé **Beats :**

- **<u>Beats</u>**

Beats est une famille de logiciels open-source développée par Elastic pour la collecte de données. Les Beats sont conçus pour être légers, faciles à installer et à configurer, et ils peuvent être utilisés pour collecter une variété de types de données tels que les logs, les métriques système et les données de sécurité.

Les Beats sont souvent utilisés en combinaison avec Elasticsearch et Logstash dans une pile ELK (Elasticsearch, Logstash, Kibana) pour l'analyse de logs et de métriques. Les Beats communiquent directement avec Elasticsearch ou Logstash pour envoyer les données collectées.

Il existe différents types de Beats, chacun étant conçu pour collecter un type de données spécifique :

- **Filebeat** : pour la collecte de logs de fichiers
- **Metricbeat** : pour la collecte de métriques système et de performances
- **Packetbeat** : pour la collecte de données réseau
- **Winlogbeat** : pour la collecte de logs Windows
- **Auditbeat** : pour la collecte de données de sécurité et d'audit

Les Beats sont faciles à configurer et peuvent être déployés à grande échelle. Ils sont également extensibles et peuvent être personnalisés pour répondre à des besoins spécifiques. La documentation de Elastic fournit des guides détaillés pour l'installation et la configuration de chaque type de Beat.

Elastic Stack permet donc :

- La collecte des données au travers de **Logstash** (ou des **Beats**) ;
- Le stockage des données dans le moteur d'indexation **Elasticsearch** ;
- L'exploitation et l'analyse des données au travers de **Kibana**

<u>Caractéristiques</u>

La stack ELK présente de nombreuses fonctionnalités comme :

- **Collecte de données en temps réel** : Logstash permet de collecter des données en temps réel à partir de différentes sources telles que des fichiers de logs, des bases de données, des messages système, etc.
- **Stockage et indexation de données** : Elasticsearch permet de stocker et d'indexer les données collectées par Logstash. Les données peuvent être recherchées et analysées en temps réel.
- **Analyse et visualisation de données** : Kibana est une interface utilisateur graphique qui permet de visualiser et d'analyser les données stockées dans Elasticsearch. Kibana offre des fonctionnalités telles que des tableaux de bord personnalisés, des graphiques, des diagrammes, des cartes, etc.
- **Recherche de texte intégrale** : Elasticsearch offre des fonctionnalités de recherche de texte intégrale qui permettent aux utilisateurs de trouver rapidement les données qu'ils cherchent.
- **Agrégation de données** : Elasticsearch offre des fonctionnalités d'agrégation de données qui permettent aux utilisateurs de créer des statistiques sur les données stockées.
- **Sécurité** : ELK offre des fonctionnalités de sécurité telles que l'authentification, l'autorisation et le chiffrement pour protéger les données et les utilisateurs.
- **Extensibilité** : Les logiciels ELK sont extensibles et peuvent être facilement intégrés à d'autres outils et systèmes.

Donc, ELK offre une plateforme complète pour la collecte, le stockage, l'analyse et la visualisation de données en temps réel.

Architecture et composants

Elasticsearch, Logstash et **Kibana** sont les principaux composants de la stack ELK. Ils sont souvent utilisés ensemble pour la surveillance des systèmes, l'analyse des performances, la surveillance de la sécurité et la surveillance des applications, entre autres cas d'utilisation.

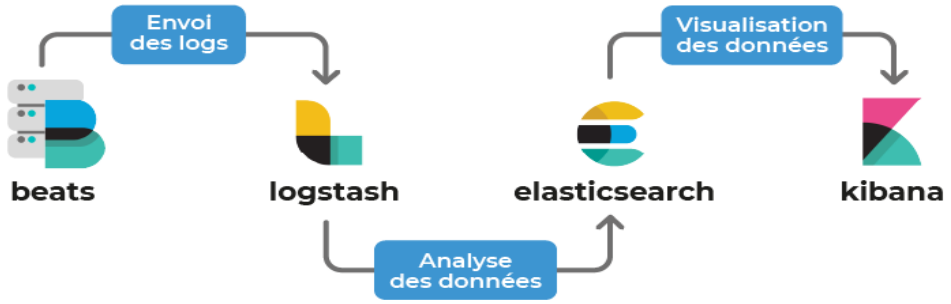

Figure 13 : Architecture de ELK [W10]

d) LogRhythm

Figure 14 : Logo de LogRhythm

LogRhythm est une entreprise de cybersécurité fondée en 2003 qui fournit une plateforme complète de gestion et de sécurité des réseaux d'entreprise. La plateforme LogRhythm comprend une gamme de fonctionnalités, notamment la gestion des journaux, la gestion des informations et événements de sécurité, l'analyse des comportements des utilisateurs et des entités (UEBA), l'analyse du trafic réseau et la détection et réponse des terminaux (EDR). La plateforme utilise des analyses avancées et de l'apprentissage automatique pour détecter et répondre aux menaces en temps réel et offre une vue unifiée de la sécurité dans l'ensemble de l'organisation.

La technologie SIEM de LogRhythm permet aux organisations de collecter et d'analyser des données liées à la sécurité de l'ensemble de leur réseau, notamment les journaux, les événements et les alertes provenant de différentes sources telles que les pare-feux, les systèmes de détection et de prévention des intrusions et les logiciels antivirus. La plateforme utilise des analyses avancées et de l'apprentissage automatique pour détecter et répondre aux incidents de sécurité potentiels en temps réel.

En plus de sa plateforme de cybersécurité, **LogRhythm** offre également une vue globale de la sécurité de l'ensemble de l'organisation, ce qui permet aux équipes de sécurité de mieux comprendre les menaces et d'y répondre plus rapidement.

Caractéristiques

LogRhythm offre une large gamme de fonctionnalités pour aider les équipes de sécurité à détecter, répondre et remédier rapidement aux menaces de sécurité. Voici quelques-unes des principales fonctionnalités de LogRhythm :

- **Collecte de données de sécurité** : LogRhythm peut collecter des données de sécurité à partir de différentes sources, y compris les journaux, les événements et les alertes provenant de pare-feu, de logiciels antivirus et de nombreux autres outils de sécurité.
- **Analyse comportementale** : il utilise des techniques d'analyse comportementale pour identifier les comportements anormaux des utilisateurs ou des systèmes qui peuvent indiquer une attaque de sécurité en cours. Cette fonctionnalité permet aux équipes de sécurité de détecter les menaces plus rapidement et d'y répondre plus efficacement.
- **Corrélation des événements** : LogRhythm utilise des algorithmes de corrélation avancés pour identifier les relations entre les événements de sécurité apparemment non liés. Cette fonctionnalité permet de détecter les attaques complexes et de les analyser plus rapidement.
- **Gestion des incidents** : permet aux équipes de sécurité de suivre et de gérer les incidents de sécurité de bout en bout, depuis leur détection jusqu'à leur résolution. La plateforme fournit des workflows automatisés pour accélérer la réponse aux incidents et des outils de collaboration pour permettre aux équipes de travailler ensemble de manière plus efficace.
- **Conformité réglementaire** : aide les organisations à suivre les normes de conformité réglementaires, telles que PCI-DSS, HIPAA et GDPR, en fournissant des rapports de sécurité et en automatisant les tâches de collecte de données nécessaires à la conformité.
- **Analyse des menaces** : il utilise des algorithmes d'apprentissage automatique pour analyser les données de sécurité en temps réel et détecter les menaces connues et inconnues. Cette fonctionnalité permet aux équipes de sécurité de détecter les menaces plus rapidement et de les neutraliser avant qu'elles ne causent des dommages importants.

Architecture et composants

LogRhythm est une plateforme dotée d'une architecture modulaire flexible qui offre différentes fonctionnalités clés via des logiciels ou services distincts. Sur un réseau, une multitude d'appareils génèrent des milliers de journaux bruts en permanence. Les journaux générés par ces appareils sont en différents formats et contiennent des informations telles que la santé du système, l'interaction de l'utilisateur avec une application, etc... Toutes ces données sont de niveaux d'importance variables, certaines étant liées à des activités courantes, tandis que d'autres sont liées à des menaces potentielles à la sécurité.

LogRhythm Enterprise est une solution entièrement intégrée qui permet de traiter les données de journal brutes pour les présenter sous forme d'informations significatives et uniformes. Pour cela, LogRhythm utilise différents composants clés, notamment les **agents**, le **processeur de données**, le **moteur d'intelligence artificielle** et **le gestionnaire de plate-forme**.

Les **agents** sont chargés de collecter les données de journal brutes à partir des différents appareils du réseau.

Le **processeur de données** est responsable de leur traitement et de leur normalisation pour permettre une analyse efficace.

Le **moteur d'intelligence artificielle (moteur IA)** utilise des algorithmes sophistiqués pour identifier les événements potentiellement dangereux et les alertes sont ensuite gérées par le gestionnaire de plate-forme.

Et c'est le **gestionnaire de plate-forme** qui permet d'avoir également une vue d'ensemble sur l'ensemble du système pour une gestion efficace des alertes et des événements.

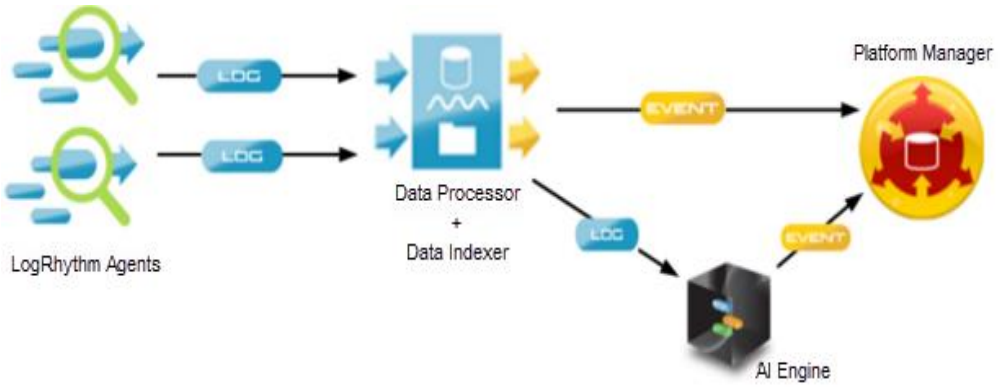

Figure 15 : Architecture de LogRhythm [W11]

e) Graylog

Figure 16 : Logo de Graylog

Graylog est une plate-forme **open source** de gestion des journaux et de l'analyse de données. Il permet aux entreprises de collecter, d'indexer et d'analyser des données à partir de plusieurs sources telles que des serveurs et des applications, pour fournir une visibilité sur les performances, la sécurité et les activités de l'entreprise.

Il est conçu pour être hautement extensible et personnalisable, offrant une variété d'options de configuration et de personnalisation pour répondre aux besoins spécifiques de chaque entreprise. Les fonctionnalités clés de Graylog incluent l'agrégation de journaux, la recherche de texte intégral, la corrélation de données, la visualisation de données et la prise en charge de nombreuses sources de données.

Caractéristiques

Graylog est une plate-forme de gestion de logs et d'analyse des données qui offre plusieurs fonctionnalités. Voici quelques-unes de ces fonctionnalités les plus importantes :

- **Collecte des logs** : Graylog permet de collecter des logs à partir de diverses sources telles que des fichiers journaux, des services de cloud, des bases de données, des équipements réseau, etc.
- **Agrégation des logs** : Graylog peut agréger plusieurs logs provenant de différentes sources en un seul endroit, ce qui facilite la recherche et l'analyse.
- **Recherche de logs** : permet de rechercher facilement des logs en utilisant différents critères tels que le temps, l'application, le niveau de gravité, etc…
- **Analyse des logs** : il dispose d'outils d'analyse de logs avancés pour détecter les tendances, les anomalies et les erreurs dans les logs.
- **Tableau de bord** : il permet de créer des tableaux de bord personnalisés pour visualiser les données de logs et suivre les métriques clés.
- **Notification** : Graylog peut envoyer des notifications en temps réel en cas d'incident ou de défaillance de système.
- **Sécurité** : cette solution offre plusieurs fonctionnalités de sécurité telles que la gestion des utilisateurs et des rôles, l'authentification à deux facteurs, la gestion des certificats SSL/TLS, etc.
- **Intégration** : Graylog peut être intégré avec de nombreux outils et services tels que Elasticsearch, MongoDB, Kafka, Docker, etc…

Architecture et composants

Graylog est composée de plusieurs composants clés dont :

- **Graylog Server** : c'est le composant principal de Graylog. Il est responsable de la gestion des flux de logs et de la configuration de la plateforme. Il est également responsable de l'indexation et de la recherche de logs.
- **Elasticsearch** : Graylog utilise Elasticsearch comme moteur de recherche et d'indexation des logs.
- **MongoDB** : MongoDB est utilisé comme base de données pour stocker les configurations de Graylog. Il est également utilisé pour stocker les données de journalisation de configuration et de journalisation d'audit.
- **Graylog Web Interface** : c'est l'interface utilisateur de Graylog. Il permet aux utilisateurs de rechercher et de visualiser les logs, de configurer des alertes et des tableaux de bord et de gérer les utilisateurs et les autorisations.

- **Graylog Collector** : il s'agit d'un outil qui collecte les logs à partir de sources distantes et les envoie à Graylog pour indexation et recherche. Il prend en charge plusieurs protocoles de collecte de logs, y compris **SYSLOG**, **GELF** et **HTTP**.

- **Graylog Sidecar** : c'est un agent qui peut être installé sur des serveurs distants pour collecter des logs et les envoyer à Graylog Collector. Il prend en charge plusieurs sources de logs, y compris les **fichiers de logs**, **les journaux Windows Event** et les **journaux Docker**.

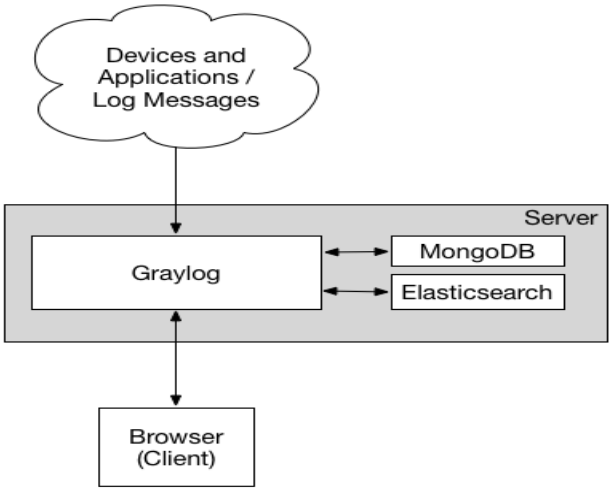

Figure 17 : Architecture basique de Graylog [W12]

f) AlienVault OSSIM

Figure 18 : Logo d'AlienVault OSSIM

AlienVault OSSIM (*Open Source Security Information Management*) est une solution de gestion de la sécurité open source conçue pour aider les organisations à gérer et à répondre aux menaces de sécurité. Il s'agit d'un système de gestion de l'information de sécurité qui collecte et analyse les journaux de sécurité à partir de diverses sources, tels que les applications, les pare-feux, les IDS/IPS et les commutateurs de réseau.

OSSIM dispose d'un système de corrélation des événements de sécurité qui analyse les journaux pour détecter des comportements suspects ou des attaques potentielles. Il dispose également de nombreuses fonctionnalités de gestion des incidents de sécurité, telles que la génération de rapports de sécurité, la visualisation des données de sécurité, la gestion des vulnérabilités et la gestion des incidents de sécurité.

En outre, AlienVault propose également une version commerciale de leur produit appelée "*Unified Security Management*" (**USM**), qui offre des fonctionnalités de sécurité supplémentaires telles que la détection de malware et la surveillance de l'intégrité des fichiers.

Caractéristiques

- **Collecte de données de sécurité** : OSSIM collecte des données de sécurité à partir de diverses sources telles que des journaux d'événements, des sondes de réseau, des scanners de vulnérabilités, des capteurs de sécurité, etc…
- **Corrélation d'événements de sécurité** : il analyse les données de sécurité collectées pour détecter des comportements suspects ou des attaques potentielles.
- **Gestion des vulnérabilités** : OSSIM peut identifier les vulnérabilités des systèmes et des applications et fournir des informations sur les correctifs disponibles.
- **Génération de rapports de sécurité** : il fournit des rapports détaillés sur les incidents de sécurité, les vulnérabilités identifiées et les tendances de sécurité.
- **Visualisation des données de sécurité** : cet outil fournit une interface graphique pour visualiser les données de sécurité collectées.
- **Gestion des incidents de sécurité** : ce SIEM fournit des fonctionnalités de gestion des incidents de sécurité pour aider les équipes de sécurité à suivre et à résoudre les incidents de sécurité.
- **Support multi-utilisateur** : OSSIM prend en charge plusieurs utilisateurs avec différents niveaux d'autorisation.
- **Open Source** : c'est un logiciel open source, ce qui signifie qu'il est gratuit et que son code source est disponible pour être modifié et amélioré par la communauté.
- **Intégration avec d'autres outils de sécurité** : il peut être intégré avec d'autres outils de sécurité tels que les scanners de vulnérabilités et les systèmes de prévention des intrusions.

Architecture et composants

OSSIM est composé de plusieurs composants, chacun ayant un rôle spécifique dans le processus de gestion de la sécurité. Voici une description de ces principaux composants :

- **OSSIM Server** : c'est le cœur de la plateforme OSSIM. Il sert de point central pour la collecte des données de sécurité, la corrélation d'événements, la surveillance en temps réel, la gestion des incidents et la génération de rapports de sécurité.
- **OSSIM Agents** : les agents OSSIM sont des programmes qui collectent des données de sécurité à partir de différents systèmes et les envoient au serveur OSSIM. Ils peuvent être utilisés pour collecter des données à partir de serveurs, de postes de travail, de pare-feux, etc…
- **OSSIM *Sensors*** : les capteurs OSSIM sont des appareils physiques qui sont installés sur le réseau pour collecter des données de sécurité. Ils peuvent être utilisés pour surveiller le trafic réseau, détecter les attaques de déni de service, surveiller les ports ouverts.
- **OSSIM *Logger*** : le *logger* OSSIM reçoit des données de journalisation à partir de différentes sources, les analyse pour en extraire des informations pertinentes, puis les stocke dans une base de données pour une analyse ultérieure. Le logger peut également corréler les événements provenant de différentes sources pour identifier des incidents de sécurité et fournir des alertes en temps réel aux analystes de sécurité.

- **OSSIM *Web UI*** : il s'agit d'une interface utilisateur basée sur le Web qui permet aux administrateurs de gérer la plateforme OSSIM. Elle permet de visualiser les données de sécurité, de gérer les incidents, de générer des rapports, etc.

- **OSSIM *Database*** : la base de données OSSIM stocke toutes les données de sécurité collectées par la plateforme OSSIM. Elle est utilisée pour stocker des informations sur les événements de sécurité, les incidents, les vulnérabilités, etc.

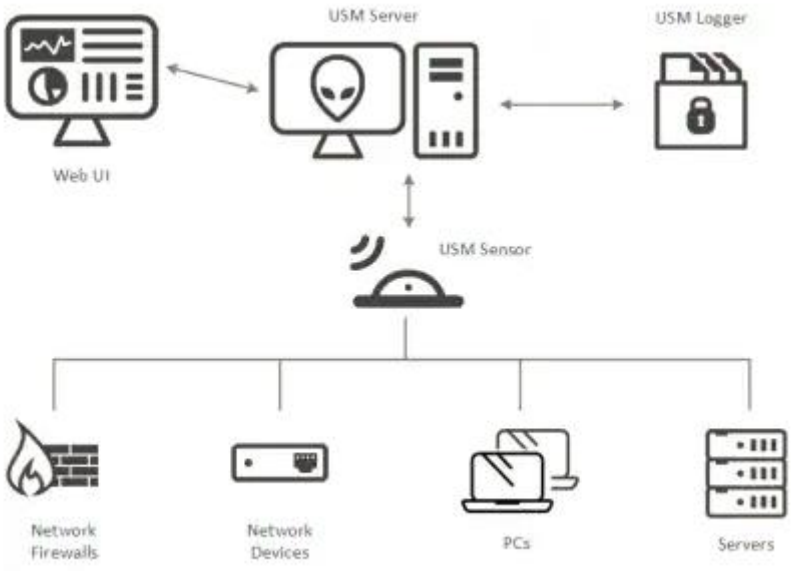

Figure 19 : Architecture d'AlienVault OSSIM [W13]

g) Datadog

Figure 20 : Logo de Datadog

Datadog est une plateforme de surveillance et d'analyse des performances des applications et des infrastructures. Elle permet aux équipes de développement et d'exploitation de surveiller les métriques, les traces, les journaux et les alertes provenant de différentes sources, telles que des serveurs, des conteneurs, des bases de données et des services cloud.

La plateforme de Datadog est conçue pour fournir une vue unifiée de l'ensemble de l'environnement de production, permettant aux équipes de suivre la performance de leurs applications, de détecter rapidement les problèmes et de résoudre les incidents plus rapidement. Elle dispose également d'une interface conviviale qui permet de créer des tableaux de bord personnalisés, d'analyser les tendances et de définir des alertes en fonction de critères spécifiques.

Datadog prend en charge un large éventail d'intégrations avec des technologies et des services populaires, tels que *Kubernetes*, *AWS*, *Docker*, *MySQL* et bien d'autres. Elle offre également

des fonctionnalités avancées, telles que la corrélation de traces, l'analyse des erreurs et la surveillance synthétique, qui permettent de résoudre les problèmes plus rapidement et d'améliorer la qualité des services.

Caractéristiques

Parmi les principales fonctionnalités de Datadog, on peut citer :

- **Surveillance des métriques** : Datadog permet de surveiller les métriques de performance des applications et des infrastructures, telles que l'utilisation des ressources, la latence, le taux d'erreurs et bien d'autres encore.
- **Analyse des journaux** : il permet d'analyser les journaux pour identifier les erreurs et les problèmes de performance, ainsi que pour comprendre les comportements des utilisateurs.
- **Corrélation des traces** : Datadog permet de suivre les transactions à travers les applications et les infrastructures, de manière à identifier rapidement les problèmes de performance.
- **Création de tableaux de bord** : il permet de créer des tableaux de bord personnalisés pour visualiser les données de performance de manière claire et concise.
- **Alertes** : ce SIEM permet de définir des alertes en fonction de critères spécifiques, tels que des seuils de métriques ou des modèles de journaux, pour être averti rapidement en cas de problèmes.
- **Infrastructure as code** : il permet d'intégrer la surveillance des performances directement dans les pipelines de déploiement, grâce à son support d'infrastructure as code.
- **Surveillance synthétique** : c'est outil SIEM permet de surveiller les performances des applications à partir de différents emplacements géographiques, pour comprendre comment les utilisateurs accèdent à l'application.
- **Analyse de l'impact** : Datadog permet d'identifier les dépendances entre les différents composants de l'infrastructure, pour comprendre comment les changements peuvent affecter la performance globale de l'application.

Architecture et composants

Elle se compose d'agents installés sur les serveurs, les machines virtuelles ou les conteneurs pour collecter des métriques et des traces de performances. Un tableau de bord personnalisable permet de visualiser et d'analyser les données collectées. Les métriques et les traces sont collectées à partir de différentes sources, telles que des agents, des intégrations et des API, et permettent de suivre le comportement d'un système ou d'une application. Datadog propose également une fonctionnalité de surveillance de l'infrastructure et un module d'APM pour surveiller et analyser la performance des applications en temps réel. Les utilisateurs peuvent également créer des intégrations personnalisées pour collecter des données à partir de sources spécifiques.

h) Wazuh

Figure 21 : Logo de Wazuh

Wazuh est une plateforme de gestion de la sécurité des informations open source. Il fournit des fonctionnalités de surveillance des journaux, de détection des intrusions, de conformité et de réponse aux incidents pour les environnements informatiques.

Wazuh est basé sur **OSSEC**, un système de détection d'intrusions open source populaire, et propose une gamme d'outils supplémentaires pour la gestion de la sécurité, tels que des agents pour la collecte de données, des outils de visualisation et de gestion des alertes, ainsi que des fonctionnalités pour l'analyse des logs et des événements de sécurité.

Wazuh rassemble des données à partir de différents types de sources, tels que des fichiers journaux, des données réseau et des événements de sécurité des systèmes d'exploitation, afin de détecter les menaces et les incidents de sécurité. Ensuite, il utilise l'analyse de sécurité pour identifier les modèles de comportement suspects ou malveillants et génère des alertes pour les incidents détectés.

Il permet également une réponse rapide en fournissant des moyens pour l'investigation, la quarantaine ou la suppression des menaces détectées. Wazuh possède les fonctionnalités clés d'une solution **XDR** car elle offre une approche globale de la sécurité qui combine la détection, l'investigation et la réponse à des incidents de sécurité.

Caractéristiques

Wazuh offre une large gamme de fonctionnalités pour aider les organisations à détecter, gérer et répondre aux menaces de sécurité.

- **Collecte de données** : Wazuh collecte des données à partir de sources variées telles que les fichiers journaux, les événements système, les flux de réseau, etc… pour une vue globale de l'environnement de sécurité.
- **Analyse de données** : il utilise des techniques d'analyse de sécurité pour identifier les menaces et les attaques en temps réel. Il peut détecter les attaques par intrusion, les tentatives de piratage, les comportements malveillants et d'autres anomalies.
- **Alertes** : il génère des alertes en temps réel pour signaler les incidents de sécurité détectés. Les alertes sont classées en fonction de leur gravité et sont accompagnées d'informations détaillées pour aider les équipes de sécurité à réagir rapidement.
- **Gestion des vulnérabilités** : cet outil peut détecter les vulnérabilités connues et inconnues dans les systèmes et les applications, permettant aux équipes de sécurité de corriger les problèmes avant qu'ils ne soient exploités.
- **Intégration avec d'autres outils de sécurité** : Wazuh s'intègre avec d'autres outils de sécurité tels que les pare-feux, les systèmes d'authentification, les outils de gestion de correctifs, entre autres pour offrir une vue globale de la sécurité.
- **Investigation et réponse aux incidents** : ce SIEM offre aussi des fonctionnalités d'investigation et de réponse pour aider les équipes de sécurité à enquêter sur les incidents détectés et à prendre des mesures pour les contenir et les éradiquer.

- **Tableaux de bord et rapports** : Wazuh propose des tableaux de bord et des rapports personnalisables pour aider les équipes de sécurité à visualiser les données et à surveiller les tendances de sécurité au fil du temps.

Architecture et composants

La plate-forme Wazuh fournit des fonctionnalités **XDR** et **SIEM** pour protéger vos charges de travail cloud, conteneur et serveur. Celles-ci incluent l'analyse des données de journal, la détection des intrusions et des logiciels malveillants, la surveillance de l'intégrité des fichiers, l'évaluation de la configuration, la détection des vulnérabilités et la prise en charge de la conformité réglementaire. La solution Wazuh est basée sur **l'agent Wazuh**, qui est déployé sur les terminaux surveillés, et sur trois composants centraux : le **serveur Wazuh**, **l'indexeur Wazuh** et le **tableau de bord Wazuh.**

- **L'indexeur Wazuh** est un moteur de recherche et d'analyse en texte intégral hautement évolutif. Ce composant central indexe et stocke les alertes générées par le serveur Wazuh.
- Le **serveur Wazuh** analyse les données reçues des agents. Il les traite via des décodeurs et des règles, en utilisant des informations sur les menaces pour rechercher des indicateurs de compromission (**IoC**) bien connus. Un seul serveur peut analyser les données de centaines ou de milliers d'agents et évoluer horizontalement lorsqu'il est configuré en cluster. Ce composant central est également utilisé pour gérer les agents, les configurer et les mettre à niveau à distance si nécessaire.
- Le **tableau de bord Wazuh** est l'interface utilisateur Web pour la visualisation et l'analyse des données. Il comprend des tableaux de bord prêts à l'emploi pour les événements de sécurité, la conformité réglementaire, les applications vulnérables détectées, les données de surveillance de l'intégrité des fichiers, les résultats de l'évaluation de la configuration, la surveillance de l'infrastructure cloud événements, et autres. Il est également utilisé pour gérer la configuration de Wazuh et surveiller son état.

- Les **agents Wazuh** sont installés sur des terminaux tels que des ordinateurs portables, des ordinateurs de bureau, des serveurs, des instances cloud ou des machines virtuelles. Ils fonctionnent sur des systèmes d'exploitation tels que Linux, Windows, MacOs, Solaris, AIX et HP-UX.

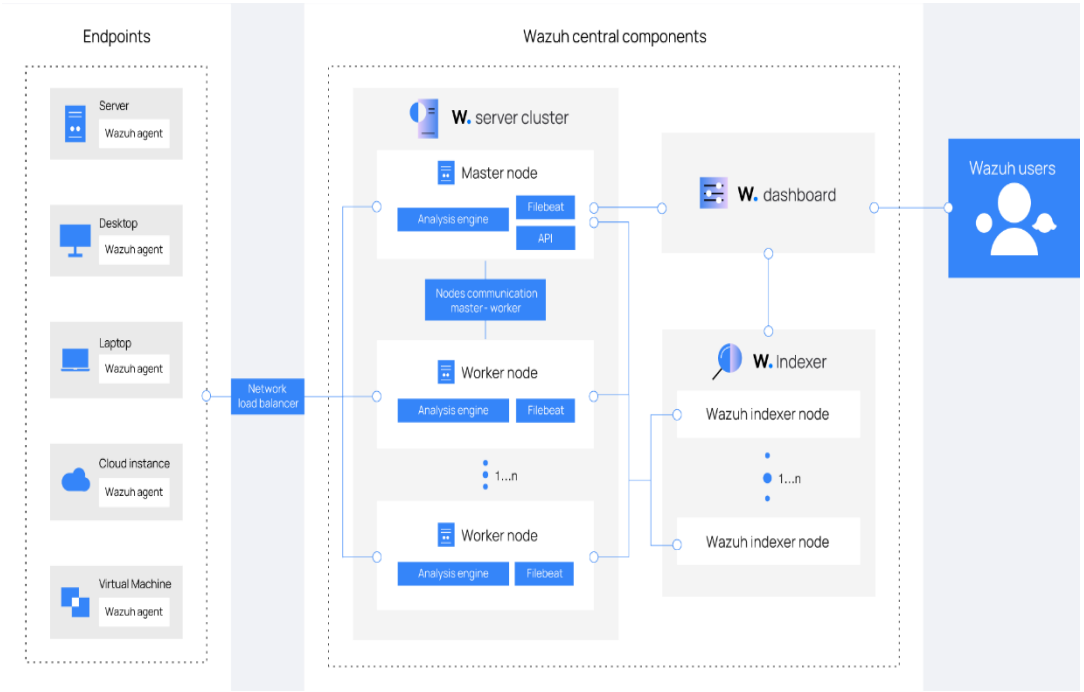

Figure 22 : Architecture de Wazuh [W14]

IV.7 – Tableau récapitulatif des solutions SIEM

Ce tableau résume les principales fonctionnalités des différentes solutions SIEM qui ont été étudiés au cours de ce mémoire :

SIEM	Fonctionnalités clés	Déploiement	Disponibilité
QRadar IBM	Analyse comportementale, détection d'anomalies, détection de fraudes, gestion de la conformité, intégration avec d'autres outils	Windows, Linux, Mac, Cloud, Conteneur SaaS, Web	Propriétaire
splunk>	Collecte, analyse et visualisation de données, détection des menaces, gestion de la conformité, automatisation des workflows	Windows, Linux, Mac, Cloud, Conteneur SaaS, Web	Propriétaire mais Splunk propose une version gratuite appelée "**Splunk Free**" qui est limitée.
ELK Stack	Analyse de logs, corrélation d'événements, visualisation	Windows, Linux, Mac, Cloud, Conteneur SaaS, Web	Open source mais peut nécessiter des coûts supplémentaires pour les licences commerciales ou les extensions premium.
LogRhythm	Détection des menaces, réponse automatisée aux incidents, intégration avec d'autres outils, gestion de la conformité, support de la conformité réglementaire	Windows, Linux, Mac, Cloud, Conteneur SaaS, Web	Propriétaire
graylog	Collecte, analyse et visualisation de données, surveillance de la sécurité, alertes personnalisées, journalisation centralisée, intégration avec d'autres outils	Windows, Linux, Cloud, Conteneur SaaS, Web	Open source

ALIEN VAULT OSSIM	Détection d'intrusion, analyse de vulnérabilités, analyse de logs, corrélation d'événements	Windows, Linux Cloud, SaaS, Web, Conteneur	Open source
DATADOG	Fournir une visibilité complète sur les performances de l'ensemble de votre environnement IT, Détection et la résolution des problèmes de performance et d'erreur.	Cloud SaaS Web	Propriétaire
WAZUH	Détection de menaces, surveillance de la conformité, intégration avec d'autres outils, analyse de vulnérabilités, réponse automatisée aux incidents	Windows, Linux, Mac, Cloud, Conteneur SaaS, Web	Open Source

IV.8 – Choix de la solution

De l'analyse récapitulatif précédent, on voit que **Wazuh** s'avère être un bon choix vu qu'il intègre un puissant HIDS **OSSEC** et la stack **ELK**. Wazuh est spécialement conçu pour la **sécurité**, ce qui signifie qu'il dispose de règles de détection préconfigurées pour identifier les activités suspectes et les comportements malveillants. De plus, Wazuh est plus facile à installer et à configurer, et dispose d'intégrations préconfigurées pour de nombreux outils de sécurité courants comme le framework **MITRE ATT&CK**. Il peut être utilisé pour surveiller les points de terminaison, les services Cloud et les conteneurs et pour agréger et analyser les données venant de sources externes. Wazuh est aussi un **XDR** (*eXtended Detection and Response*).

Notre choix se porte ainsi sur Wazuh par rapport aux autres solutions SIEM. Donc nous allons le déployer sur environnement virtuel.

CHAPITRE IV : MISE EN PLACE DE LA SOLUTION ET TESTS

V.1 – Présentation de l'environnement de travail

a) Architecture de déploiement

Nous allons déployer cette architecture dans GNS3 pour tester quelques cas d'utilisation de la solution SIEM choisie. On va travailler sur plusieurs environnements comme Linux et Windows.

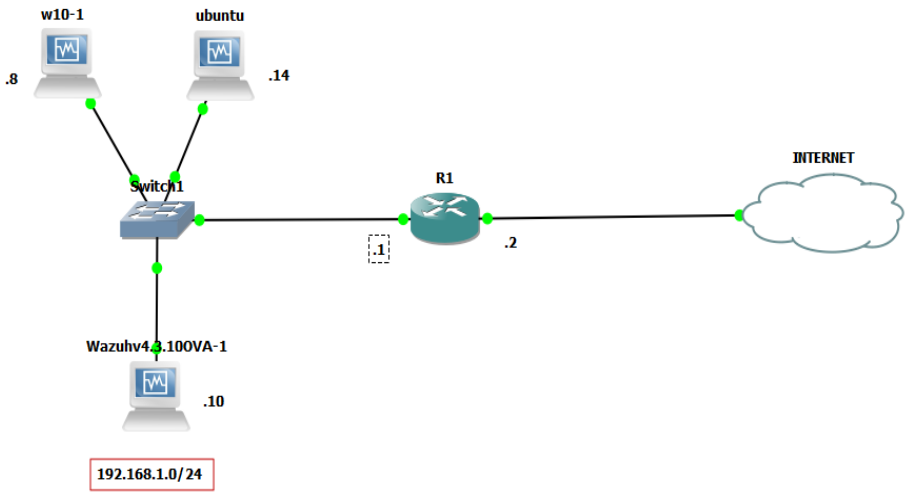

Figure 23 : Architecture de déploiement

b) Les prérequis

Pour la réalisation de ce projet, nous avons besoin :

- Un émulateur réseau tel que **GNS3 v2.2.33.1**
- Un **routeur** Cisco sur GNS3 pour connecter le WAN au LAN
- Un ***switch*** qui relie les machines au routeur
- Des environnements de machines virtuelles comme **VirtualBox** ou **VMWare**

Configuration matérielle requise

Les exigences matérielles dépendent fortement du nombre de terminaux protégés et de charges de travail cloud. Ce nombre peut aider à estimer la quantité de données qui seront analysées et le nombre d'alertes de sécurité qui seront stockées et indexées.

Déployer le serveur Wazuh, l'indexeur Wazuh et le tableau de bord Wazuh sur le même hôte, est généralement suffisant pour surveiller jusqu'à 100 terminaux et pour 90 jours de données d'alerte interrogeables/indexées. Le tableau ci-dessous indique le matériel recommandé pour un déploiement rapide :

Agents	CPU	RAM	Stockage (90 jours)
1-25	4 processeurs virtuels	8 Gio	50 Go
25-50	8 processeurs virtuels	8 Gio	100 Go
50-100	8 processeurs virtuels	8 Gio	200 Go

Figure 24 : Tableau des exigences matérielles pour déployer Wazuh [W15]

Pour les grands environnements, nous recommandons un déploiement distribué. La configuration de cluster à plusieurs nœuds est disponible pour le serveur Wazuh et pour l'indexeur Wazuh, offrant une haute disponibilité et un équilibrage de charge.

Il faut également noter que le **tableau de bord Wazuh** prend en charge les navigateurs Web suivants :

- Chrome 95 ou version ultérieure
- Firefox 93 ou ultérieur
- Safari 13.7 ou version ultérieure

D'autres navigateurs basés sur Chromium peuvent également fonctionner. Internet Explorer 11 n'est pas pris en charge.

V.2 – Composants WAZUH

La solution Wazuh utilise l'agent Wazuh comme base, qui est implanté sur les terminaux sous surveillance, et se compose également en plus de **l'agent Wazuh** de trois éléments clés : le **serveur Wazuh**, **l'indexeur Wazuh** et le **tableau de bord Wazuh**.

a) L'indexeur Wazuh

L'indexeur Wazuh est un moteur de recherche et d'analyse en texte intégral hautement évolutif. Ce composant central Wazuh indexe et stocke les alertes générées par le serveur Wazuh et fournit des capacités de recherche et d'analyse de données en temps quasi réel. L'indexeur Wazuh peut être configuré comme un cluster à un ou plusieurs nœuds, offrant évolutivité et haute disponibilité.

L'indexeur Wazuh stocke les données sous forme de documents JSON. Chaque document met en corrélation un ensemble de clés, de noms de champs ou de propriétés, avec leurs valeurs correspondantes qui peuvent être des chaînes, des nombres, des booléens, des dates, des tableaux de valeurs, des géolocalisations ou d'autres types de données.

Un index est une collection de documents liés les uns aux autres. Les documents stockés dans l'indexeur Wazuh sont répartis dans différents conteneurs appelés fragments. En répartissant les documents sur plusieurs fragments et en répartissant ces fragments sur plusieurs nœuds, l'indexeur Wazuh peut assurer la redondance.

Wazuh utilise quatre index différents pour stocker différents types d'événements :

Indice	Description
wazuh-alertes	Stocke les alertes générées par le **serveur Wazuh**. Ceux-ci sont créés à chaque fois qu'un événement déclenche une règle avec une priorité suffisamment élevée (ce seuil est paramétrable).
wazuh-archives	Stocke tous les événements (données d'archive) reçus par le **serveur Wazuh**, qu'ils déclenchent ou non une règle.
wazuh-surveillance	Stocke les données relatives au statut de **l'agent Wazuh** au fil du temps. Il est utilisé par l'interface Web pour indiquer quand des agents individuels sont ou ont été ***Active***, ***Disconnected*** ou ***Never connected***
wazuh-statistiques	Stocke les données relatives aux performances du serveur Wazuh. Il est utilisé par l'interface web pour représenter les statistiques de performances.

L'indexeur Wazuh convient parfaitement aux cas d'utilisation nécessitant une réponse rapide, tels que la surveillance de la sécurité et de l'infrastructure, car il offre une plateforme de recherche en temps quasi réel. Le délai entre l'indexation et la disponibilité des documents est très court, généralement inférieur à une seconde.

b) Le serveur Wazuh

Le composant **serveur Wazuh** analyse les données reçues des agents, déclenchant des alertes lorsque des menaces ou des anomalies sont détectées. Il est également utilisé pour gérer la configuration des agents à distance et surveiller leur état.

Le serveur Wazuh utilise des sources de renseignements sur les menaces pour améliorer ses capacités de détection. Il enrichit également les données d'alerte en utilisant le cadre **MITRE ATT&CK** et les exigences de conformité réglementaire telles que **PCI-DSS**, **GDPR**, etc… fournissant un contexte utile pour l'analyse de la sécurité.

De plus, le serveur Wazuh peut être intégré à des logiciels externes, y compris des systèmes de billetterie tels que **ServiceNow**, **Jira** et **PagerDuty**, ainsi que des plateformes de messagerie instantanée comme **Slack**. Ces intégrations sont pratiques pour rationaliser les opérations de sécurité.

❖ **Architecture serveur**

Le serveur Wazuh exécute le moteur d'analyse, l'API RESTful Wazuh, le service d'inscription d'agent, le service de connexion d'agent, le démon de cluster Wazuh et Filebeat. Le serveur est installé sur un système d'exploitation Linux et s'exécute généralement sur une machine physique autonome, une machine virtuelle, un conteneur Docker ou une instance cloud.

Le schéma ci-dessous représente l'architecture et les composants du serveur :

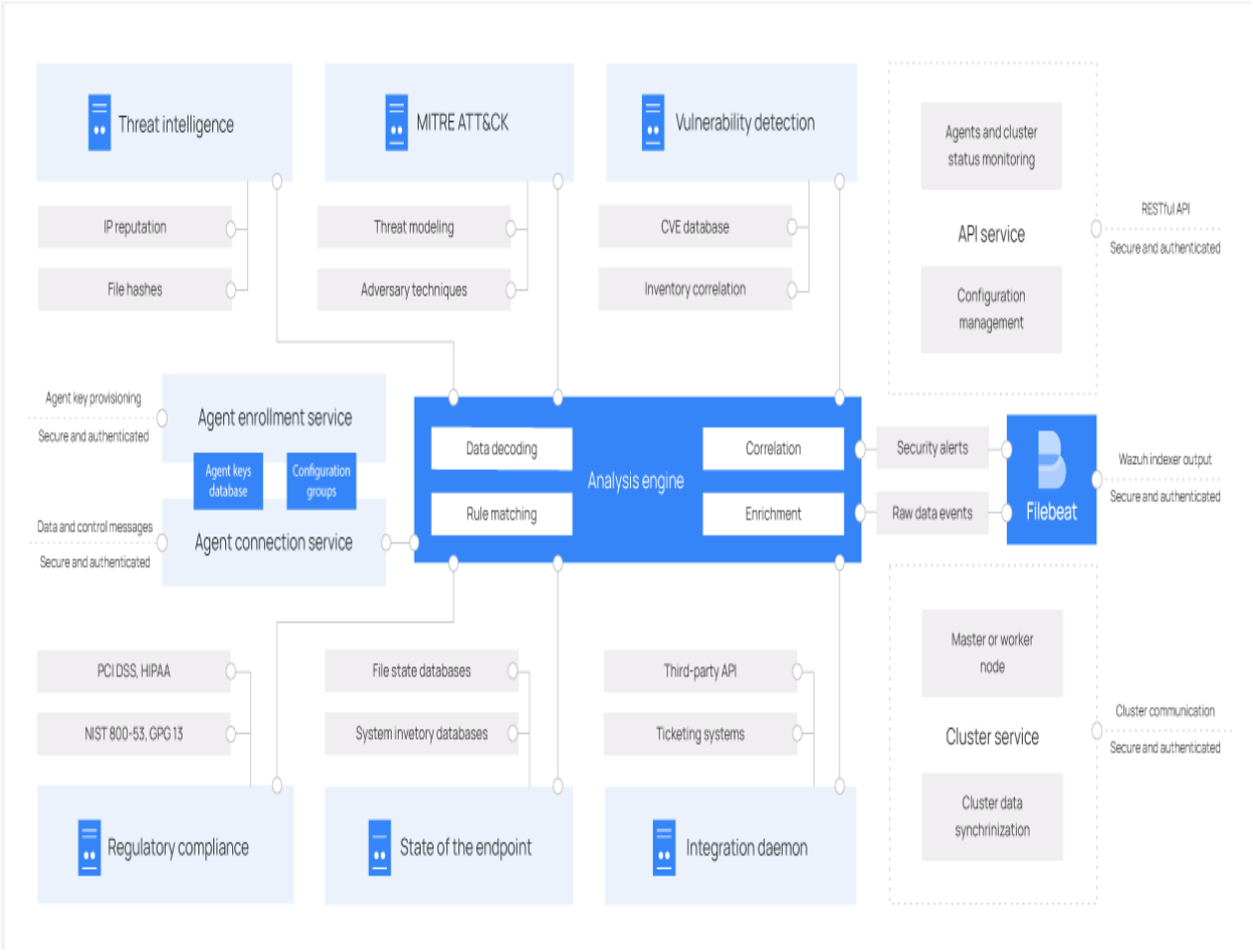

Figure 25 : Architecture et composants du serveur Wazuh [W16]

❖ **Composants du serveur**

Le serveur Wazuh comprend plusieurs composants répertoriés ci-dessous qui ont différentes fonctions, telles que l'inscription de nouveaux agents, la validation de l'identité de chaque agent et le cryptage des communications entre l'agent Wazuh et le serveur Wazuh.

- **Service d'inscription d'agent** : il est utilisé pour inscrire de nouveaux agents. Ce service fournit et distribue des clés d'authentification uniques à chaque agent. Le processus s'exécute en tant que service réseau et prend en charge l'authentification via des certificats TLS/SSL ou en fournissant un mot de passe fixe.
- **Service de connexion des agents** : ce service reçoit les données des agents. Il utilise les clés partagées par le service d'inscription pour valider l'identité de chaque agent et chiffrer les communications entre l'agent Wazuh et le serveur Wazuh. De plus, ce service fournit une gestion centralisée de la configuration, vous permettant de pousser à distance les nouveaux paramètres de l'agent.
- **Moteur d'analyse** : il s'agit du composant serveur qui effectue l'analyse des données. Il utilise des décodeurs pour identifier le type d'informations en cours de traitement (événements Windows, journaux SSH, journaux de serveur Web, etc.). Ces décodeurs extraient également les éléments de données pertinents des messages du journal, tels que l'adresse IP source, l'ID d'événement ou le nom d'utilisateur. Ensuite, en utilisant des règles, le moteur identifie des modèles spécifiques dans les événements décodés qui

pourraient déclencher des alertes et éventuellement même appeler des contre-mesures automatisées (par exemple, interdire une adresse IP, arrêter un processus en cours ou supprimer un artefact de logiciel malveillant).

- **API Wazuh RESTful** : ce service fournit une interface pour interagir avec l'infrastructure Wazuh. Il est utilisé pour gérer les paramètres de configuration des agents et des serveurs, surveiller l'état de l'infrastructure et la santé globale, gérer et modifier les décodeurs et les règles Wazuh, et interroger l'état des terminaux surveillés. Le tableau de bord Wazuh l'utilise également.
- **Démon de cluster Wazuh** : ce service est utilisé pour mettre à l'échelle horizontalement les serveurs Wazuh, en les déployant en tant que cluster. Ce type de configuration, associé à un équilibreur de charge réseau, offre une haute disponibilité et un équilibrage de charge. Le démon de cluster Wazuh est ce que les serveurs Wazuh utilisent pour communiquer entre eux et rester synchronisés.
- **Filebeat** : il est utilisé pour envoyer des événements et des alertes à l'indexeur Wazuh. Il lit la sortie du moteur d'analyse Wazuh et envoie les événements en temps réel. Il fournit également un équilibrage de charge lorsqu'il est connecté à un cluster d'indexeurs Wazuh multi-nœuds.

c) Le tableau de bord Wazuh

Le tableau de bord Wazuh est une interface utilisateur Web flexible et intuitive pour l'exploration, l'analyse et la visualisation des événements de sécurité et des données d'alerte. Il est également utilisé pour la gestion et le suivi de la plateforme Wazuh. En outre, il fournit des fonctionnalités de contrôle d'accès basé sur les rôles (RBAC) et d'authentification unique (SSO).

❖ **Visualisation et analyse de données**

L'interface Web aide les utilisateurs à naviguer à travers les différents types de données collectées par l'agent Wazuh, ainsi que les alertes de sécurité générées par le serveur Wazuh. Les utilisateurs peuvent également générer des rapports et créer des visualisations et des tableaux de bord personnalisés.

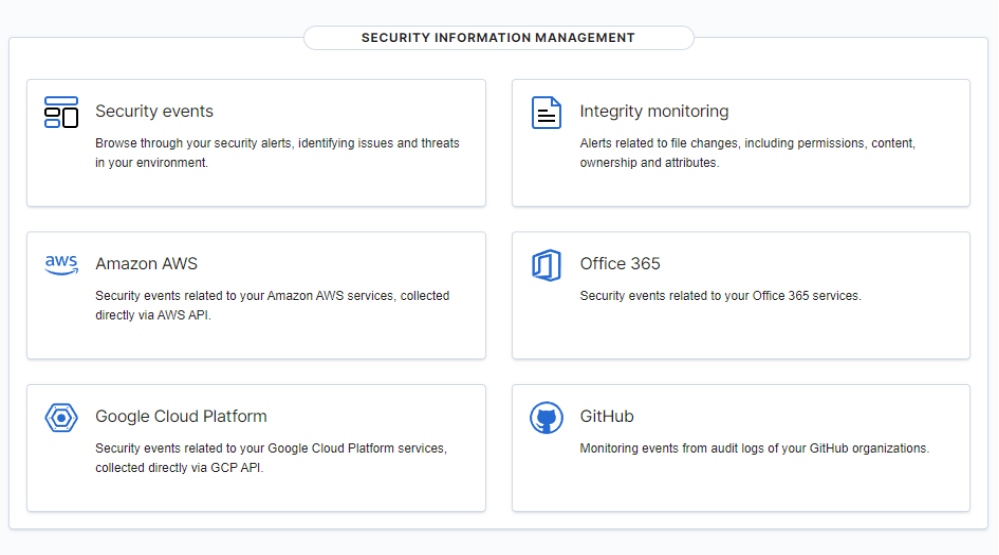

Figure 26 : Tableau de bord de Wazuh [W17]

❖ **Surveillance et configuration des agents**

Le tableau de bord Wazuh permet aux utilisateurs de gérer la configuration des agents et de surveiller leur statut. Par exemple, pour chaque *endpoint* surveillé, les utilisateurs peuvent définir quels modules d'agent seront activés, quels fichiers journaux seront lus, quels fichiers seront surveillés pour les modifications d'intégrité ou quelles vérifications de configuration seront effectuées.

❖ **Gestion de la plateforme**

Le tableau de bord Wazuh fournit une interface utilisateur dédiée à la gestion de votre déploiement Wazuh. Cela inclut la surveillance de l'état, des journaux et des statistiques des différents composants Wazuh. Il comprend également la configuration du serveur Wazuh et la création de règles et de décodeurs personnalisés pour l'analyse des journaux et la détection des menaces.

❖ **Outil de développement**

Le tableau de bord Wazuh comprend un outil de test d'ensemble de règles qui peut traiter les messages du journal pour vérifier comment il est décodé et s'il correspond ou non à une règle de détection des menaces. Cette fonctionnalité est particulièrement utile lorsque des décodeurs et des règles personnalisés ont été créés et que l'utilisateur souhaite les tester.

d) Les agents Wazuh

L'agent Wazuh s'exécute sur *Linux*, *Windows*, *macOS*, *Solaris*, *AIX* et d'autres systèmes d'exploitation. Il peut être déployé sur des ordinateurs portables, des ordinateurs de bureau, des serveurs, des instances cloud, des conteneurs ou des machines virtuelles. L'agent aide à protéger votre système en offrant des capacités de prévention, de détection et de réponse aux menaces. Il est également utilisé pour collecter différents types de données système et applicatives qu'il transmet au **serveur Wazuh** via un canal **crypté et authentifié**.

❖ **Architecture des agents**

L'agent Wazuh a une architecture modulaire. Chaque composant est responsable de ses propres tâches, notamment la surveillance du système de fichiers, la lecture des messages du journal, la collecte des données d'inventaire, l'analyse de la configuration du système et la recherche de logiciels malveillants. Les utilisateurs peuvent gérer les modules d'agent via les paramètres de configuration, en adaptant la solution à leurs cas d'utilisation particuliers.

Le schéma ci-dessous représente l'architecture et les composants de l'agent :

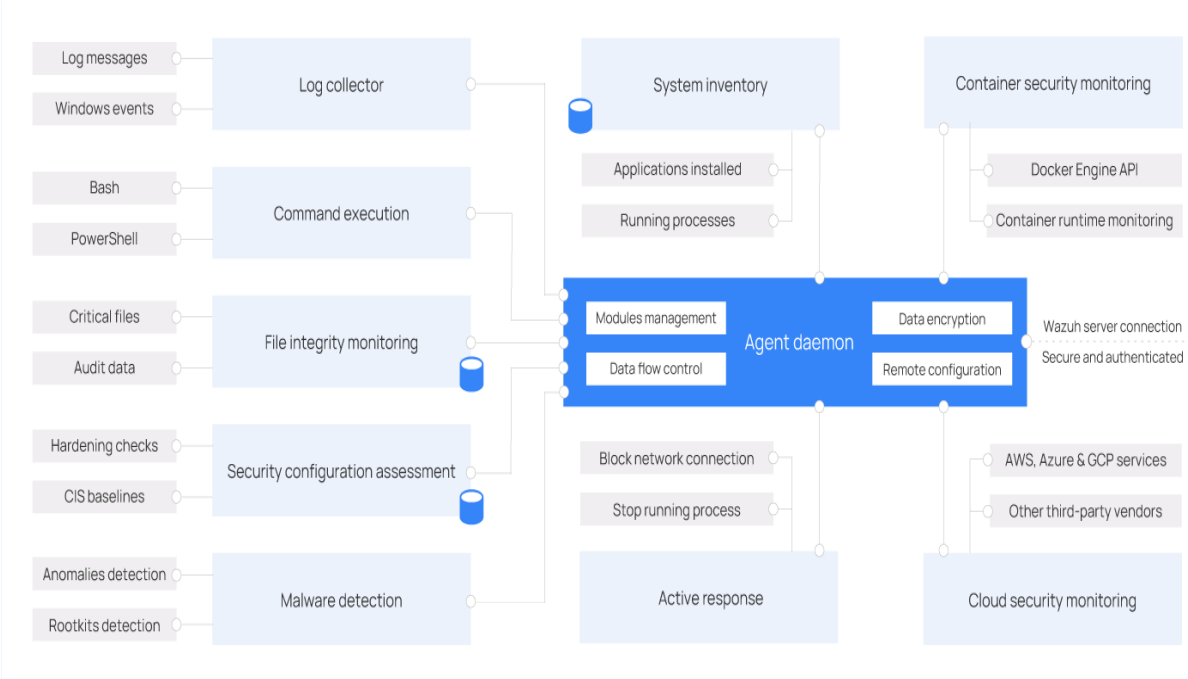

Figure 27 : Architecture et composants de l'agent Wazuh [W18]

❖ **Modules agents**

Chacun des modules d'agent peut être configuré individuellement pour accomplir diverses tâches de sécurité. Grâce à cette architecture modulaire, vous pouvez activer ou désactiver chaque composant selon vos besoins spécifiques en matière de sécurité. Vous trouverez ci-dessous une description détaillée des différents objectifs de chacun de ces modules d'agent.

- **Collecteur de journaux** :

Ce composant d'agent peut lire les fichiers journaux plats et les événements Windows, en collectant les messages du système d'exploitation et du journal des applications. Il prend en charge les filtres *XPath* pour les événements Windows et reconnaît les formats multilignes tels que les journaux d'audit Linux. Il peut également enrichir les événements JSON avec des métadonnées supplémentaires.

- **Exécution des commandes** :

Les agents exécutent périodiquement des commandes autorisées, collectent leur sortie et la signalent au serveur Wazuh pour une analyse plus approfondie. Vous pouvez utiliser ce module à différentes fins, telles que la surveillance de l'espace disque restant ou l'obtention d'une liste des derniers utilisateurs connectés.

- **Surveillance de l'intégrité des fichiers (FIM)** :

Ce module surveille le système de fichiers en temps réel pour signaler toute création, suppression ou modification de fichiers. Il suit également les modifications apportées aux attributs, aux autorisations, à la propriété et au contenu des fichiers. Les détails de l'événement sont capturés, y compris qui, quoi et quand. De plus, FIM crée et gère une base de données qui permet d'exécuter des requêtes à distance sur l'état des fichiers surveillés.

- **Évaluation de la configuration de sécurité (SCA)** :

Ce composant fournit une évaluation continue de la configuration, en utilisant des vérifications prêtes à l'emploi basées sur les références du Center of Internet Security (CIS). Les utilisateurs peuvent également créer leurs propres vérifications SCA pour surveiller et appliquer leurs politiques de sécurité.

- **Inventaire du système** :

Ce module d'agent exécute périodiquement des analyses, collectant des données d'inventaire telles que la version du système d'exploitation, les interfaces réseau, les processus en cours d'exécution, les applications installées et une liste des ports ouverts. Les résultats de l'analyse sont stockés dans des bases de données SQLite locales qui peuvent être interrogées à distance.

- **Détection des malwares** :

Utilisant une approche non basée sur les signatures, ce composant est capable de détecter les anomalies et la présence éventuelle de rootkits. En outre, il recherche les processus cachés, les fichiers cachés et les ports cachés lors de la surveillance des appels système.

- **Réponse active** :

Ce module exécute des actions automatiques lorsque des menaces sont détectées, déclenchant des réponses pour bloquer une connexion réseau, arrêter un processus en cours d'exécution ou supprimer un fichier malveillant. Les utilisateurs peuvent également créer des réponses personnalisées si nécessaire et personnaliser, par exemple, des réponses pour exécuter un binaire dans un bac à sable, capturer le trafic réseau et analyser un fichier avec un antivirus.

- **Surveillance de la sécurité des conteneurs** :

Ce module d'agent est intégré à *l'API Docker Engine* pour surveiller les modifications dans un environnement conteneurisé. Par exemple, il détecte les modifications apportées aux images de conteneur, à la configuration réseau ou aux volumes de données. En outre, il alerte sur les conteneurs s'exécutant en mode privilégié et sur les utilisateurs exécutant des commandes dans un conteneur en cours d'exécution.

- **Surveillance de la sécurité du cloud** :

Ce composant surveille les fournisseurs de cloud tels qu'Amazon AWS, Microsoft Azure ou Google GCP. Il communique nativement avec leurs API. Il est capable de détecter les modifications apportées à l'infrastructure cloud (par exemple, un nouvel utilisateur est créé, un groupe de sécurité est modifié, une instance cloud est arrêtée, etc.) et de collecter les données de journal des services cloud (par exemple, AWS *Cloudtrail*, AWS *Macie*, AWS *GuardDuty*, Azure *Active Directory*, etc.)

❖ **<u>Communication avec le serveur Wazuh</u>**

L'agent Wazuh communique avec le serveur Wazuh pour expédier les données collectées et les événements liés à la sécurité. En outre, l'agent envoie des données opérationnelles, signalant sa configuration et son état. Une fois connecté, l'agent peut être mis à niveau, surveillé et configuré à distance depuis le serveur Wazuh.

La communication de l'agent avec le serveur s'effectue via un canal sécurisé (**TCP** ou **UDP**), assurant le **cryptage** et la **compression** des données en temps réel. De plus, il inclut des

mécanismes de contrôle de flux pour éviter les inondations, mettre les événements en file d'attente si nécessaire et protéger la bande passante du réseau.

V.3 – Mode de deploiement

Pour déployer Wazuh, il existe principalement deux possibilités : le **déploiement "*all-in-one*",** ou le **déploiement distribué.**

Wazuh peut être aussi déployer sur des conteneurs tels que **Docker** et **Kubernetes.**

a) Déploiement All-in-One

Le **déploiement "*all-in-one*"** de Wazuh est une méthode qui permet d'installer tous les composants de Wazuh sur une seule machine, ce qui peut être utile pour des tests ou des déploiements de petite taille.

Voici les étapes à suivre pour déployer Wazuh en mode "all-in-one" :

- Assurez-vous que votre machine répond aux exigences minimales pour exécuter Wazuh. Vous pouvez consulter les exigences sur le site Web de Wazuh.
- Téléchargez le paquet d'installation de Wazuh pour votre système d'exploitation sur le site Web de Wazuh.
- Exécutez le paquet d'installation en tant qu'administrateur sur votre machine.
- Suivez les instructions de l'installateur pour installer tous les composants de Wazuh.

- Une fois l'installation terminée, redémarrez votre machine pour que les modifications prennent effet.
- Accédez à l'interface web de Wazuh en ouvrant un navigateur et en entrant l'adresse IP de votre machine suivie du port 5601.
- Connectez-vous à l'interface web en utilisant les informations d'identification que vous avez fournies lors de l'installation.

Notez que cette méthode est destinée à des fins de test et de développement et ne doit pas être utilisée pour un déploiement en production à grande échelle. Pour un déploiement de production, il est recommandé d'utiliser une architecture distribuée de Wazuh, qui permet de séparer les différents composants de Wazuh sur des machines différentes pour une meilleure scalabilité et une meilleure disponibilité.

b) Déploiement distribué

Le déploiement distribué de Wazuh est recommandé pour les déploiements de production à grande échelle, car il permet de répartir la charge de travail sur plusieurs machines et de garantir une meilleure disponibilité et une meilleure scalabilité. Voici les étapes à suivre pour déployer Wazuh en mode distribué :

- Évaluez les exigences matérielles et logicielles nécessaires pour exécuter les différents composants de Wazuh. Vous pouvez consulter les exigences sur le site Web de Wazuh.
- Déterminez la topologie de votre déploiement distribué, en identifiant les machines qui hébergeront chaque composant de Wazuh. Les composants de Wazuh comprennent le

serveur de gestion, les agents de sécurité, l'API RESTful, Elasticsearch, Kibana, Redis et Filebeat.

- Installez Elasticsearch, Kibana et Redis sur les machines dédiées qui hébergeront ces composants. Assurez-vous de suivre les instructions d'installation spécifiques à votre système d'exploitation.
- Installez le serveur de gestion sur la machine dédiée qui hébergera ce composant. Vous pouvez télécharger le paquet d'installation depuis le site Web de Wazuh.
- Installez l'API RESTful sur la machine dédiée qui hébergera ce composant. Vous pouvez télécharger le paquet d'installation depuis le site Web de Wazuh.
- Configurez les agents de sécurité sur les machines que vous souhaitez surveiller à l'aide de la documentation de Wazuh.
- Installez Filebeat sur les machines qui hébergeront les agents de sécurité. Filebeat est utilisé pour envoyer les journaux à Elasticsearch.
- Configurez les connexions entre les différents composants de Wazuh en suivant les instructions de la documentation de Wazuh. Vous devez vous assurer que les connexions entre les différents composants sont sécurisées et fiables.

Une fois que tous les composants sont installés et configurés, vous pouvez accéder à l'interface web de Kibana pour visualiser les données de sécurité collectées par Wazuh. Cette interface permet également d'accéder à toutes les fonctionnalités de Wazuh, telles que la recherche, la corrélation et la gestion des alertes.

Notez que cette méthode permet une meilleure scalabilité et une meilleure disponibilité que le déploiement "all-in-one" de Wazuh, mais nécessite une configuration plus complexe et une administration plus avancée.

V.4 – Déploiement

Pour le déploiement de la solution Wazuh, on a opté pour la déploiement **"all-in-one"** d'une machine OVA préconfigurée et prête à l'emploi.

a) Installation de Wazuh OVA

Après avoir télécharger l'OVA sur le site officiel de Wazuh, on importe la machine virtuelle dans l'environnement de machines virtuelles **VirtualBox.** Il faut s'authentifier avec le nom d'utilisateur **wazuh-user** et le mot de passe **wazuh** par défaut.

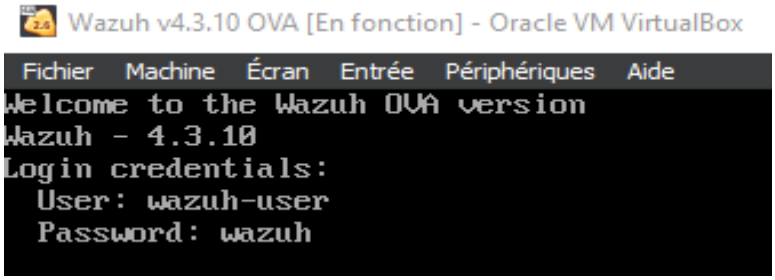

Figure 28 : Authentification sur Wazuh OVA

À partir de ce moment, on se connecte à l'instance Wazuh à travers l'adresse IP qui nous a été fourni.

```
        WAZUH Open Source Security Platform
                https://wazuh.com


[wazuh-user@wazuh-server ~]$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 100
0
    link/ether 08:00:27:c3:4f:df brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 brd 192.168.1.255 scope global dynamic eth0
       valid_lft 503sec preferred_lft 503sec
    inet6 fe80::a00:27ff:fec3:4fdf/64 scope link
       valid_lft forever preferred_lft forever
[wazuh-user@wazuh-server ~]$
```

Figure 29 : Récupération de l'adresse IP de l'interface réseau de Wazuh

Après cette étape, on s'authentifie à nouveau à travers l'interface Web de Wazuh avec le nom d'utilisateur et le mot de passe par défaut **admin/admin.**

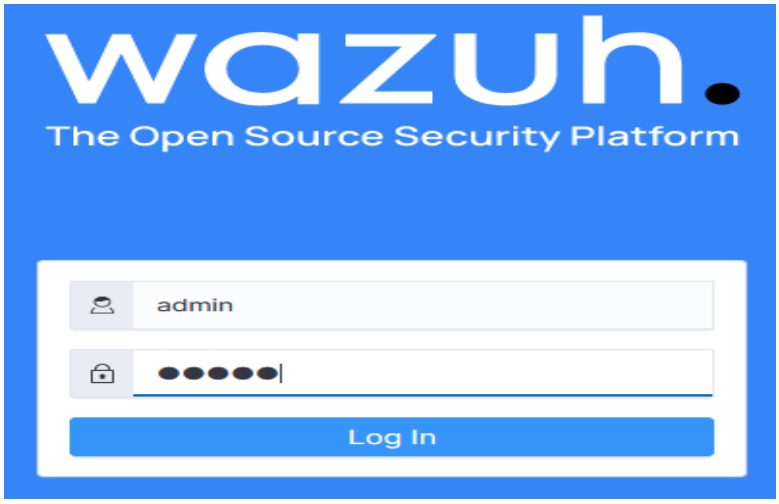

Figure 30 : Authentification sur l'interface Web de Wazuh

Voici une partie de l'interface de Wazuh :

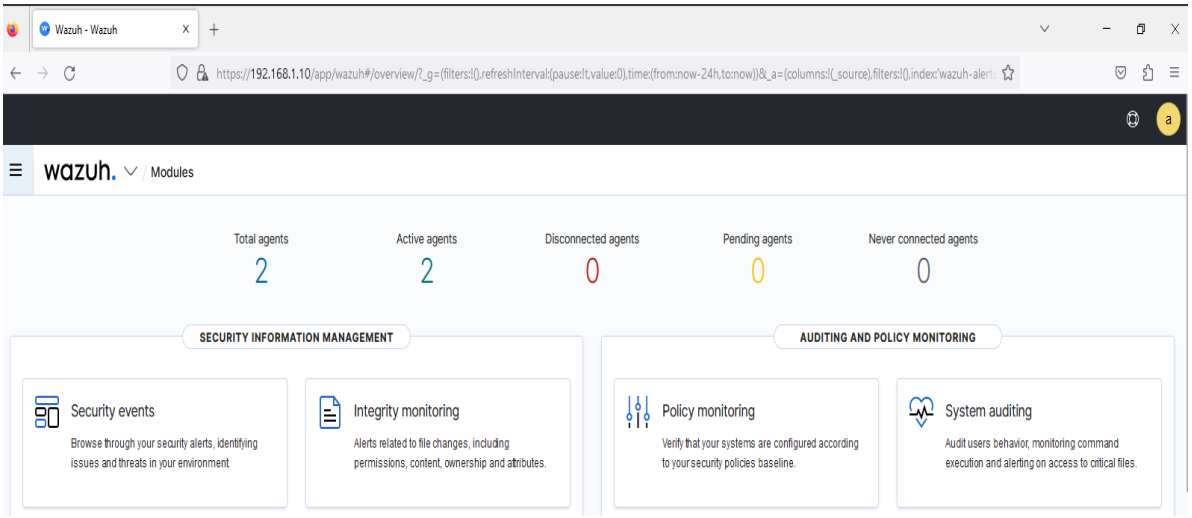

Figure 31 : Interface de Wazuh

On peut voir que Wazuh intègre également **OpenSearch** pour effectuer des recherches dans de grands volumes de données. Il peut être utilisé pour la recherche d'informations dans diverses applications, notamment dans les domaines de l'analyse de données, de la surveillance et de la recherche d'entreprise.

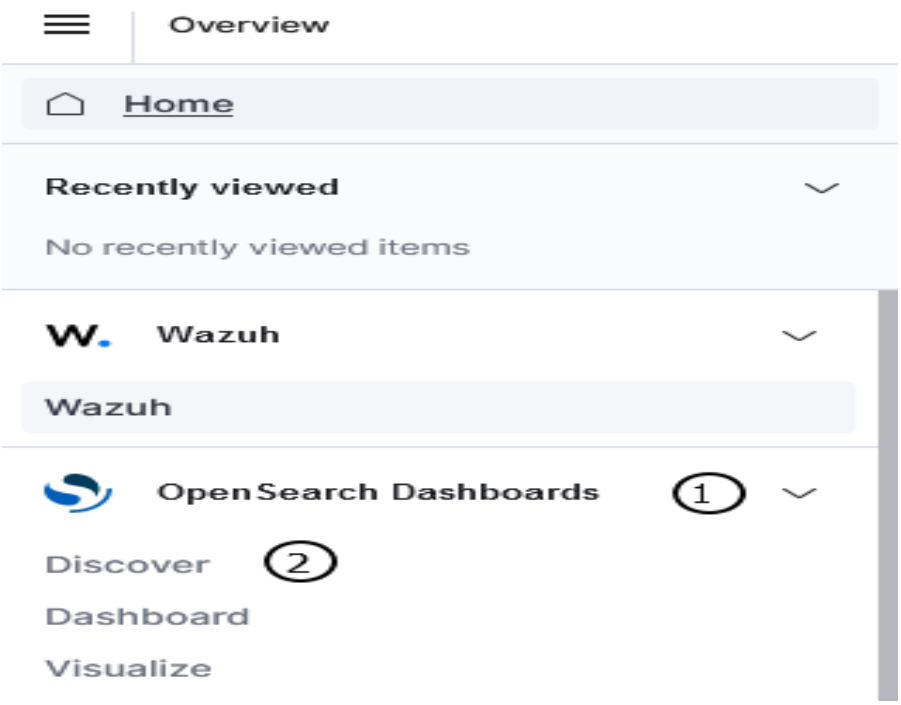

Figure 32 : OpenSearch Dashboard

On peut même y analyser les différents logs qui ont été remonté et c'est le langage **DQL** (*OpenSearch Dashboards Query Langague*) qui est utilisé.

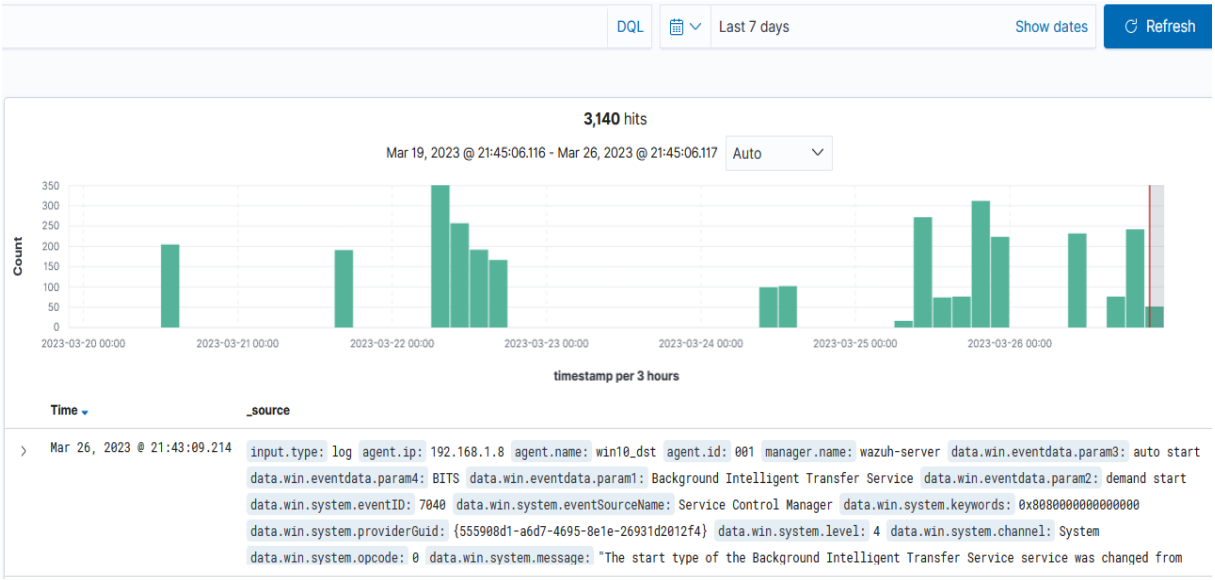

Figure 33 : Exemple de fichier log

Si on se penche sur un agent en particulier par exemple l'agent **win10_dst,** on peut voir tous les événements de sécurité relatifs à cet agent et voir les différentes alertes qui ont été remonté. Ces alertes pourront par la suite être analyser et des rapports générés.

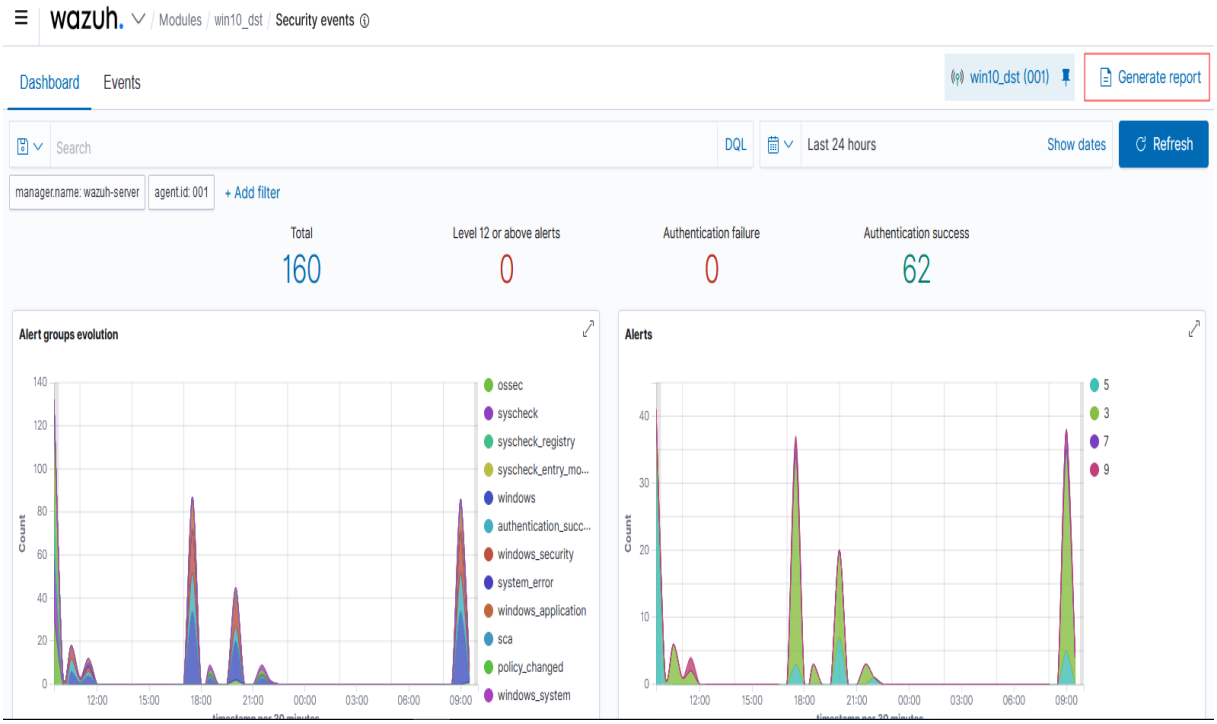

Figure 34 : Tableau de bord des événements de sécurité

b) Installation des agents

L'agent Wazuh est multiplateforme et s'exécute sur les terminaux que l'utilisateur souhaite surveiller. Il communique avec le serveur Wazuh, envoyant des données en temps quasi réel via un canal crypté et authentifié.

L'agent a été développé en tenant compte de la nécessité de surveiller une grande variété de terminaux différents sans affecter leurs performances. Il est pris en charge sur les systèmes d'exploitation les plus populaires et nécessite en moyenne 35 Mo de RAM.

❖ **Déploiement sur un endpoint Windows**

Pour déployer un agent sur un environnement Windows, on peut soit utiliser une invite de commandes, soit opter pour une installation avec une interface graphique. Cette dernière semble être la plus simple.

Pour installer l'agent Wazuh sur votre système, on exécute le programme d'installation de Windows en suivant les étapes de l'assistant d'installation. Une fois installé, l'agent utilise une interface graphique pour la configuration, l'ouverture du fichier journal et le démarrage ou l'arrêt du service.

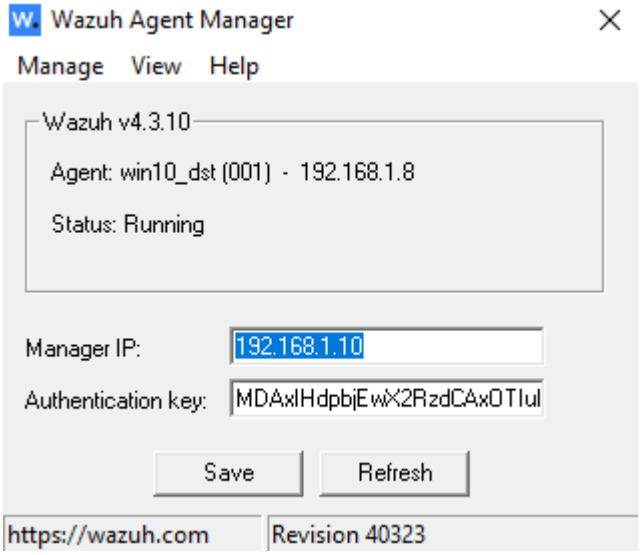

Figure 35 : Interface de configuration de l'agent Wazuh sous Windows

On peut voir l'agent est en cours d'exécution et que l'adresse du serveur Wazuh est **192.168.1.10**

❖ **Déploiement sur un endpoint Linux**

Le déploiement d'un agent Wazuh sur un système Linux utilise des variables de déploiement qui facilitent la tâche d'installation, d'enregistrement et de configuration de l'agent.

On va déployer notre agent sur une machine Ubuntu 22.04, pour cela il faut ouvrir un terminal et procéder comme suit :

```
diouf@diouf-VirtualBox:~$ curl -so wazuh-agent-4.3.10.deb https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agent_4.3
.10-1_amd64.deb && sudo WAZUH_MANAGER='192.168.1.10' WAZUH_AGENT_GROUP='default' dpkg -i ./wazuh-agent-4.3.10.deb
Sélection du paquet wazuh-agent précédemment désélectionné.
(Lecture de la base de données... 166254 fichiers et répertoires déjà installés.)
Préparation du dépaquetage de ./wazuh-agent-4.3.10.deb ...
Dépaquetage de wazuh-agent (4.3.10-1) ...
Paramétrage de wazuh-agent (4.3.10-1) ...
diouf@diouf-VirtualBox:~$
```

Figure 36 : Installation de l'agent Wazuh sous Linux

```
diouf@diouf-VirtualBox:~$
diouf@diouf-VirtualBox:~$ sudo systemctl daemon-reload
diouf@diouf-VirtualBox:~$ sudo systemctl enable wazuh-agent.service
Synchronizing state of wazuh-agent.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /lib/systemd/system/wazuh-agent.service.
diouf@diouf-VirtualBox:~$ sudo systemctl start wazuh-agent.service
diouf@diouf-VirtualBox:~$
diouf@diouf-VirtualBox:~$
```

Figure 37 : Activation de l'agent Wazuh sous Linux

Ainsi l'agent est installé et fonctionnel.

V.5 – Les tests

a) Surveillance des événements Sysmon avec Wazuh

Windows fournit un outil de collecte de journaux d'événements qui inclut tous les événements générés et est organisé en canaux. Les principaux canaux sont Système, Application et Sécurité. Dans ces canaux, les événements sont stockés selon qu'ils ont été créés par une action système, une stratégie d'audit active ou s'ils contiennent des informations relatives au logiciel installé sur le système.

Wazuh collecte les événements de ces canaux et est équipé d'un ensemble de règles Windows qui lui permet d'informer des événements importants qui se produisent sur nos serveurs Windows. La surveillance des journaux Sysmon est une application intéressante pour ce service. Sysmon est un outil Windows qui enregistre l'activité du système et les anomalies détectées dans le journal des événements.

Cet exemple détaille comment il est possible de surveiller l'activité des menaces à l'aide de Sysmon. Bien qu'ici l'agent Wazuh soit configuré pour surveiller les journaux dans le canal Sysmon, cette configuration pourrait être étendue à n'importe lequel des canaux disponibles.

Les messages de journal générés peuvent être extraits à l'aide de **l'Observateur d'événements Windows**. Cet outil nous permet une inspection indépendante de ces événements enregistrés. Chaque entrée de journal affiche toutes les informations sur l'événement par le biais d'un message qui décrit l'origine de l'événement ainsi que d'autres paramètres spécifiques pris en compte dans l'événement.

Collecte d'événements Sysmon

Afin de modifier la configuration par défaut de Sysmon, nécessaire aux fins de cet article, il est nécessaire de créer un fichier XML. Ci-dessous, vous pouvez voir une configuration XML qui fonctionnerait pour que Sysmon génère le bon journal lorsque Mimikatz est exécuté :

```xml
<Sysmon schemaversion="4.10">
  <HashAlgorithms>md5</HashAlgorithms>
  <EventFiltering>
    <!--SYSMON EVENT ID 1 : PROCESS CREATION-->
    <ProcessCreate onmatch="include">
      <Image condition="contains">mimikatz.exe</Image>
    </ProcessCreate>
    <!--SYSMON EVENT ID 2 : FILE CREATION TIME RETROACTIVELY CHANGED IN THE FILESYSTEM-->
    <FileCreateTime onmatch="include" />
    <!--SYSMON EVENT ID 3 : NETWORK CONNECTION INITIATED-->
    <NetworkConnect onmatch="include" />
    <!--SYSMON EVENT ID 4 : RESERVED FOR SYSMON STATUS MESSAGES, THIS LINE IS INCLUDED FOR DOCUMENTATION PURPOSES ONLY-->
    <!--SYSMON EVENT ID 5 : PROCESS ENDED-->
    <ProcessTerminate onmatch="include" />
    <!--SYSMON EVENT ID 6 : DRIVER LOADED INTO KERNEL-->
    <DriverLoad onmatch="include" />
    <!--SYSMON EVENT ID 7 : DLL (IMAGE) LOADED BY PROCESS-->
    <ImageLoad onmatch="include" />
    <!--SYSMON EVENT ID 8 : REMOTE THREAD CREATED-->
    <CreateRemoteThread onmatch="include">
      <SourceImage condition="contains">mimikatz.exe</SourceImage>
    </CreateRemoteThread>
    <!--SYSMON EVENT ID 9 : RAW DISK ACCESS-->
    <RawAccessRead onmatch="include" />
    <!--SYSMON EVENT ID 10 : INTER-PROCESS ACCESS-->
    <ProcessAccess onmatch="include">
      <SourceImage condition="contains">mimikatz.exe</SourceImage>
    </ProcessAccess>
    <!--SYSMON EVENT ID 11 : FILE CREATED-->
    <FileCreate onmatch="include" />
    <!--SYSMON EVENT ID 12 & 13 & 14 : REGISTRY MODIFICATION-->
    <RegistryEvent onmatch="include" />
    <!--SYSMON EVENT ID 15 : ALTERNATE DATA STREAM CREATED-->
    <FileCreateStreamHash onmatch="include" />
    <PipeEvent onmatch="include" />
  </EventFiltering>
</Sysmon>
```

Figure 38 : Fichier de configuration sysconfig.xml

Après avoir télécharger Sysmon, on crée un fichier XML comme indiqué ci-dessus. Ensuite on place ce dernier dans le dossier contenant les binaires Sysmon. Et après on lance CMD avec des privilèges d'administrateur pour installer le fichier comme suit :

```
C:\Users\saliou\Desktop\Sysmon>Sysmon64.exe -accepteula -i sysconfig.xml


System Monitor v14.13 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2022 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.10
Sysmon schema version: 4.83
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.

C:\Users\saliou\Desktop\Sysmon>_
```

Figure 39 : Installation de Sysmon

Dans le cadre de tests, on met en place **Mimikatz**, un outil de post-exploitation hautement performant qui permet de récupérer les mots de passe, les hachages, les codes PIN et les tickets Kerberos stockés en mémoire. Cependant, étant donné que Mimikatz peut être associé à des logiciels malveillants ou indésirables, il est considéré comme dangereux et ne doit pas être installé sur des environnements de production.

```
PS C:\Users\saliou\Desktop\mimikatz_trunk\x64> .\mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz #
```

Figure 40 : Exécution de mimikatz

L'événement Création de processus est le premier événement correspondant. L'exécution du binaire mimikatz.exe génère cet événement, et il peut être vu dans l'application Observateur d'événements dans la section Sysmon.

(Applications and Services Logs/Microsoft/Windows/Sysmon/Operational).

Event 1, Sysmon

General | Details

Friendly View | XML View


```
- <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  - <System>
      <Provider Name="Microsoft-Windows-Sysmon" Guid="{5770385F-C22A-43E0-BF4C-06F5698FFBD9}" />
      <EventID>1</EventID>
      <Version>5</Version>
      <Level>4</Level>
      <Task>1</Task>
      <Opcode>0</Opcode>
      <Keywords>0x8000000000000000</Keywords>
      <TimeCreated SystemTime="2023-03-29T15:33:13.510342000Z" />
      <EventRecordID>7457</EventRecordID>
      <Correlation />
      <Execution ProcessID="1992" ThreadID="716" />
      <Channel>Microsoft-Windows-Sysmon/Operational</Channel>
      <Computer>DESKTOP-54ASC73</Computer>
      <Security UserID="S-1-5-18" />
    </System>
  - <EventData>
      <Data Name="RuleName">-</Data>
      <Data Name="UtcTime">2023-03-29 15:33:13.504</Data>
      <Data Name="ProcessGuid">{03D086AD-5A39-6424-5501-000000004700}</Data>
      <Data Name="ProcessId">3204</Data>
      <Data Name="Image">C:\Users\saliou\Desktop\mimikatz_trunk\x64\mimikatz.exe</Data>
      <Data Name="FileVersion">2.2.0.0</Data>
      <Data Name="Description">mimikatz for Windows</Data>
      <Data Name="Product">mimikatz</Data>
```


Figure 41 : Événement de sécurité au format XML

Cet événement est composé de deux structures principales : ***System*** et ***EventData***. La première contient des métadonnées génériques, tandis que la seconde comprend des champs spécifiques à chaque type d'événement. Tous ces champs sont collectés et traités par Wazuh.

Configurons l'agent Wazuh pour collecter les événements Sysmon

Après l'installation et l'exécution de l'agent Wazuh sur l'ordinateur à surveiller, la configuration de l'agent doit être effectuée pour permettre la surveillance des événements Sysmon. Pour cela, il convient d'inclure le code suivant dans le fichier de configuration de l'agent : **(C:/Program Files(x86) /ossec_agent/)**

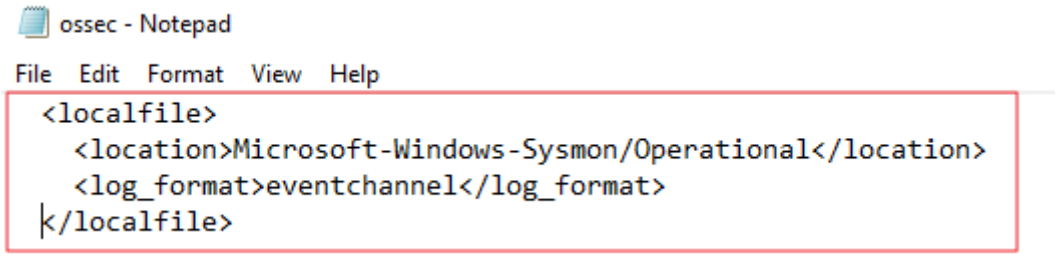

Figure 42 : Configuration de l'agent pour surveiller les événements Sysmon

Ensuite on redémarre l'agent pour que les dernières modifications soient prises en charge.

Configuration du gestionnaire Wazuh

Dans ce cas, la configuration du fichier XML spécifie que les événements à surveiller sont les événements ID 1 (Création de processus), ID 8 (Création de thread distant) et ID 10 (Accès au processus). Pour ce faire, il est possible d'utiliser les règles Sysmon génériques incluses dans l'ensemble de règles Wazuh comme base pour créer des règles personnalisées spécifiques à ce cas d'utilisation.

Pour surveiller ces événements, les règles suivantes sont ajoutées au fichier **local_rules.xml (/var/ossec/etc/rules/)**

```
<group name="windows, sysmon, sysmon_process-anomalies,">
   <rule id="100000" level="12">
     <if_group>sysmon_event1</if_group>
     <field name="win.eventdata.image">mimikatz.exe</field>
     <description>Sysmon - Suspicious Process - mimikatz.exe</description>
   </rule>

   <rule id="100001" level="12">
     <if_group>sysmon_event8</if_group>
     <field name="win.eventdata.sourceImage">mimikatz.exe</field>
     <description>Sysmon - Suspicious Process mimikatz.exe created a remote thread</description>
   </rule>

   <rule id="100002" level="12">
     <if_group>sysmon_event_10</if_group>
     <field name="win.eventdata.sourceImage">mimikatz.exe</field>
     <description>Sysmon - Suspicious Process mimikatz.exe accessed $(win.eventdata.targetImage)</description>
   </rule>
</group>
```

Figure 43 : Configuration du gestionnaire Wazuh

Après on redémarre le gestionnaire pour prendre en considération les modifications.

```
root@wazuh-server ~]#
root@wazuh-server ~]#
root@wazuh-server ~]# systemctl restart wazuh-manager.service
root@wazuh-server ~]#
root@wazuh-server ~]#
```

Figure 44 : Redémarrage du gestionnaire Wazuh

Évaluation des résultats

Il est possible d'effectuer deux opérations avec Mimikatz pour générer des alertes correspondant aux règles de la section précédente. La première consiste simplement à exécuter mimikatz.exe, qui crée un événement de création de processus, comme illustré dans l'image du journal des événements Windows ci-dessus. La seconde repose sur la récupération des informations d'identification du service SamSs, qui est le serveur d'authentification de sécurité local. Cette opération crée un thread distant, se connecte à l'API SAM et accède au domaine.

```
mimikatz 2.2.0 x64 (oe.eo)
mimikatz #

mimikatz # lsadump::lsa /inject
Domain : DESKTOP-54ASC73 / S-1-5-21-3758611782-3065873629-1090925074

RID  : 000001f4 (500)
User : Administrator

 * Primary
    NTLM :
    LM   :

RID  : 000001f7 (503)
User : DefaultAccount

 * Primary
    NTLM :
    LM   :

RID  : 000001f5 (501)
User : Guest

 * Primary
    NTLM :
    LM   :

RID  : 000003e9 (1001)
User : saliou

 * Primary
    NTLM : 84ba6d909266692517dc4bcc2906ae4e
    LM   :
  Hash NTLM: 84ba6d909266692517dc4bcc2906ae4e

RID  : 000001f8 (504)
User : WDAGUtilityAccount

 * Primary
    NTLM : 9ee4e2cae6f2a245087bce338451c9db
    LM   :
  Hash NTLM: 9ee4e2cae6f2a245087bce338451c9db

mimikatz #
```

Figure 45 : Injection d'un module dans le processus lsass.exe de Windows

Les événements générés à partir des actions effectuées sont enregistrés dans la section Sysmon du journal des événements :

Level	Date and Time	Source	Event ID	Task Category
Inf...	3/29/2023 11:13:59 AM	Sysmon	8	CreateRemoteThread detected (rule: CreateRemoteT...
Inf...	3/29/2023 11:13:59 AM	Sysmon	8	CreateRemoteThread detected (rule: CreateRemoteT...
Inf...	3/29/2023 11:13:59 AM	Sysmon	8	CreateRemoteThread detected (rule: CreateRemoteT...
Inf...	3/29/2023 11:13:59 AM	Sysmon	8	CreateRemoteThread detected (rule: CreateRemoteT...
Inf...	3/29/2023 11:13:59 AM	Sysmon	8	CreateRemoteThread detected (rule: CreateRemoteT...
Inf...	3/29/2023 11:13:59 AM	Sysmon	10	Process accessed (rule: ProcessAccess)
Inf...	3/29/2023 11:04:50 AM	Sysmon	1	Process Create (rule: ProcessCreate)

Figure 46 : Collecte des différents événements de sécurité

Les événements collectés par l'agent sont transmis au gestionnaire où ils sont traités par le décodeur Wazuh et évalués par rapport au moteur de règles. Ici, on peut voir les alertes générées du côté de l'interface utilisateur Wazuh.


```
{
  "_index": "wazuh-alerts-4.x-2023.03.29",
  "_type": "_doc",
  "_id": "wgGTLocBIOm1O9PJrDZD",
  "_version": 1,
  "_score": null,
  "_source": {
    "input": {
      "type": "log"
    },
    "agent": {
      "ip": "192.168.1.8",
      "name": "win10_dst",
      "id": "001"
    },
    "manager": {
      "name": "wazuh-server"
    },
    "data": {
      "win": {
        "eventdata": {
          "sourceThreadId": "68",
          "grantedAccess": "0x143a",
          "targetProcessGUID": "{03D086AD-A367-6424-0B00-000000004700}",
          "targetProcessId": "596",
          "utcTime": "2023-03-29 18:13:59.300",
          "sourceUser": "DESKTOP-54ASC73\\\\saliou",
          "sourceProcessId": "5152",
          "sourceImage": "C:\\\\Users\\\\saliou\\\\Desktop\\\\mimikatz_trunk\\\\x64\\\\mimikatz.exe",
          "targetImage": "C:\\\\Windows\\\\system32\\\\lsass.exe",
          "sourceProcessGUID": "{03D086AD-7DC2-6424-E002-000000004700}",
```


Figure 47 : Alerte générée au format JSON

Conclusion

En résumé, on a utilisé l'outil de menace Mimikatz pour tester la sécurité de Windows. Cet exemple peut servir de référence pour surveiller et signaler tout événement d'intérêt dans le format de journal EventChannel. Les stratégies d'audit peuvent être activées dans l'éditeur de stratégie de groupe pour surveiller des événements tels que l'arrêt d'un processus ou la modification des privilèges d'un fichier.

Les possibilités sont nombreuses et la surveillance du journal des événements Windows avec Wazuh est aussi simple que de configurer l'agent pour surveiller n'importe quel canal souhaité, comme le canal Sysmon, comme expliqué dans ce cas d'utilisation.

b) Détection des techniques courantes de persistance Linux avec Wazuh

Les **techniques de persistance** sont des mécanismes ou des configurations que les acteurs de la menace utilisent pour maintenir un accès illicite aux terminaux compromis après avoir obtenu l'accès initial. La persistance garantit que les attaquants ont accès aux points de terminaison, quels que soient les redémarrages du système, les informations d'identification modifiées ou d'autres interruptions susceptibles de mettre fin à un accès illégal.

Une fois les techniques de persistance mises en place, les pirates n'ont plus à effectuer d'étapes d'exploitation pour retrouver l'accès au terminal. Des exemples de techniques de persistance incluent l'utilisation de scripts de démarrage, la création de comptes d'utilisateurs et la modification de binaires existants.

Cet exemple couvre quelques techniques de persistance Linux courantes qu'un adversaire utilise pour établir un accès permanent aux terminaux compromis.

❖ **Techniques de persistance et détection MITRE ATT&CK**

Les techniques de persistance Linux suivantes sont couramment utilisées par les attaquants, qui se basent sur les modèles de comportement d'acteurs de menace du monde réel proposés par le cadre MITRE ATT&CK en matière de tactiques et de techniques d'adversaires.

- **T1098.004 – Manipulation de compte : clés SSH autorisées**
- **T1037.004 – Scripts d'initialisation de démarrage ou de connexion : Scripts RC**
- **T1136.001 – Créer un compte : compte local**
- **T1078.003 – Comptes valides : comptes locaux**
- **T1546.004 – Exécution déclenchée par un événement : modification de la configuration du shell Unix**
- **T1574.006 - Flux d'exécution de piratage : piratage de l'éditeur de liens dynamique**
- **T1053.003 – Tâche/Tâche planifiée : Temporisateurs Systemd**
- **T1505.003 – Composant logiciel serveur : Web Shell**

Nous avons mis en place les techniques de détection en utilisant Wazuh 4.3.10 et simulé des attaques contre un point de terminaison Ubuntu 22.04 LTS.

- **T1098.004 – Manipulation de compte : clés SSH autorisées**

Pour maintenir l'accès aux terminaux compromis, cette technique de persistance utilise l'authentification basée sur une clé SSH. SSH (*Secure Shell*) est un protocole de communication crypté qui permet une administration sécurisée et une communication avec des serveurs. SSH utilise un fichier nommé "***authorized_keys***" pour spécifier les clés SSH utilisées pour se connecter à un compte utilisateur. Pour permettre un accès permanent, il est nécessaire de configurer ce fichier pour chaque compte utilisateur qui nécessite l'utilisation de clés SSH. La configuration par défaut de la plupart des implémentations SSH autorise le déploiement de nouvelles clés autorisées.

Les attaquants peuvent utiliser cette technique pour importer leurs clés publiques dans le fichier "**~/.ssh/authorized_keys**", ce qui leur permet d'établir une communication avec des terminaux compromis à tout moment sans avoir besoin de spécifier un mot de passe. Avant de pouvoir exploiter cette technique, ils doivent vérifier que "**PubkeyAuthentication**" est activé dans le fichier de configuration SSH "**/etc/ssh/sshd_config**" et que "**PermitRootLogin**" est également activé lorsqu'ils se connectent en tant que root.

Pour détecter cette technique de persistance à l'aide de Wazuh, il convient de configurer le module de surveillance de l'intégrité des fichiers (**FIM**) pour surveiller la création et la modification des fichiers "**~/.ssh/authorized_keys**" et "**/etc/ssh/sshd_config**". Le module Wazuh FIM surveille les chemins de fichiers sélectionnés sur un système de fichiers et déclenche des alertes lorsque des fichiers sont créés, modifiés ou supprimés.

Configuration du point de terminaison Linux

- Ajoutons la configuration suivante au fichier **/var/ossec/etc/ossec.conf**

```
<ossec_config>
  <syscheck>
    <directories check_all="yes" realtime="yes">/root/.ssh/</directories>
    <directories check_all="yes" realtime="yes">/home/*/.ssh/</directories>
    <directories check_all="yes" realtime="yes">/var/*/.ssh/</directories>
    <directories check_all="yes" realtime="yes">/etc/ssh/sshd_config</directori>
  </syscheck>
</ossec_config>
```

Figure 48 : Configuration du endpoint Linux

- Redémarrons l'agent Wazuh pour appliquer les changements de configuration :

```
diouf@ubuntu:~$
diouf@ubuntu:~$
diouf@ubuntu:~$ systemctl restart wazuh-agent.service
diouf@ubuntu:~$
diouf@ubuntu:~$
```

Figure 49 : Redémarrage de l'agent Wazuh

Configuration du serveur Wazuh

- Créons un fichier de règle personnalisés nommé **comm_persist_tech_rules.xml** dans le répertoire **/var/ossec/etc/rules** et ajoutons les règles suivantes pour déclencher des alertes pour la technique de persistance des clés SSH autorisées.

  Pour cela on se connecte au serveur Wazuh en tant que superutilisateur avec **root/wazuh**

```
[wazuh-user@wazuh-server ~]$ sudo -i
[sudo] password for wazuh-user:
[root@wazuh-server ~]#
[root@wazuh-server ~]#
```

Figure 50 : Authentification en tant que superutilisateur sur le manager Wazuh

```
[root@wazuh-server ~]#
[root@wazuh-server ~]#
[root@wazuh-server ~]# touch /var/ossec/etc/rules/comm_persist_tech_rules.xml
```

Figure 51 : : Création du fichier de règle comm_persist_tech_rules.xml

```
<group name="common_persistence_techniques,sshd,">
  <rule id="100100" level="10">
    <if_sid>554</if_sid>
    <field name="file" type="pcre2">\/authorized_keys$</field>
    <description>SSH authorized_keys file "$(file)" has been added</description>
    <mitre>
      <id>T1098.004</id>
    </mitre>
  </rule>

  <rule id="100101" level="10">
    <if_sid>550</if_sid>
    <field name="file" type="pcre2">\/authorized_keys$</field>
    <description>SSH authorized_keys file "$(file)" has been modified</description>
    <mitre>
      <id>T1098.004</id>
    </mitre>
  </rule>

  <rule id="100102" level="10">
    <if_sid>550</if_sid>
    <field name="file" type="pcre2">\/sshd_config$</field>
    <description>SSH config file "$(file)" has been modified</description>
    <mitre>
      <id>T1098.004</id>
    </mitre>
  </rule>
</group>
```

Figure 52 : Création des règles de détection

Où :

- **L'ID de règle 100100** est déclenché lorsque le fichier **~/.ssh/authorized_keys** est ajouté au point de terminaison surveillé.
- **L'ID de règle 100101** est déclenché lorsque le fichier **~/.ssh/authorized_keys** est modifié sur le point de terminaison surveillé.

- **L'ID de règle 100102** est déclenché lorsque le fichier **/etc/sshd_config** est modifié sur le point de terminaison surveillé.

➢ Redémarrons le gestionnaire Wazuh pour prendre en charge les dernières configurations

```
[root@wazuh-server ~]#
[root@wazuh-server ~]#
[root@wazuh-server ~]# systemctl restart wazuh-manager.service
[root@wazuh-server ~]#
[root@wazuh-server ~]#
```

Figure 53 : Redémarrage du gestionnaire Wazuh

➢ Lorsque des modifications sont détectées dans les fichiers surveillés, le tableau de bord Wazuh génère des alertes correspondantes grâce à la fonctionnalité FIM.

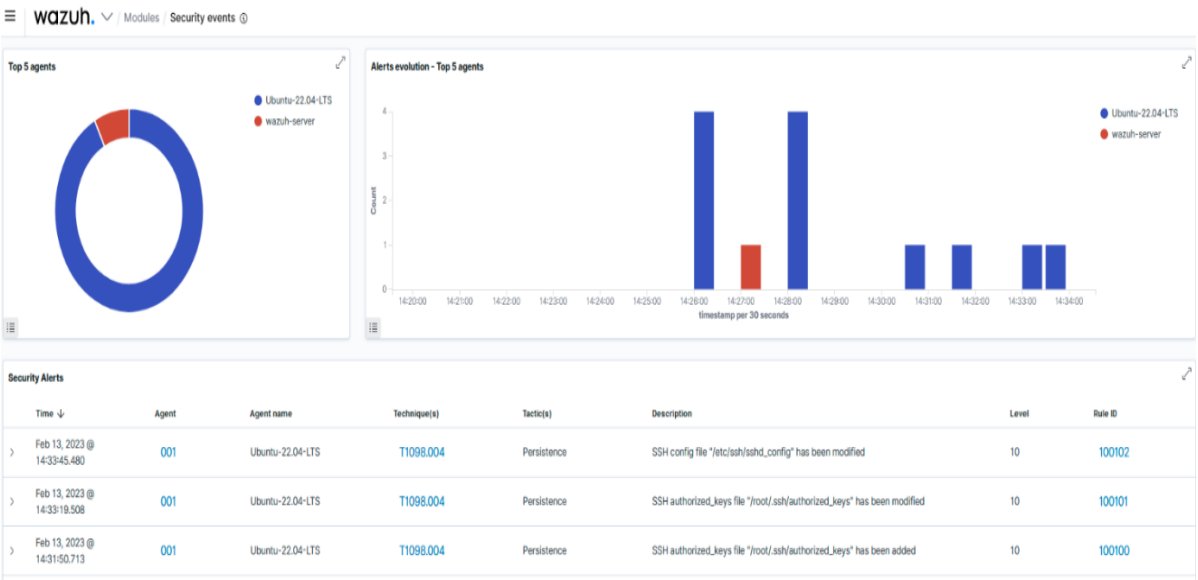

Figure 54 : Alertes générées par le tableau de bord Wazuh

Conclusion

Cet exemple présente une technique permettant d'établir la persistance sur les points de terminaison Linux compromis, en suivant le cadre d'attaque MITRE. Nous expliquons comment les acteurs de la cybercriminalité utilisent ces techniques pour maintenir une connexion continue avec les terminaux compromis.

On a pu détecter la présence d'activités de persistance sur les points de terminaison Linux en utilisant les fonctionnalités de surveillance des commandes et de FIM de Wazuh.

CONCLUSION ET PERSPECTIVES

Aux termes de ce travail, on peut retenir que les SIEM sont des outils de sécurité informatique essentiels pour la détection proactive et la réponse aux incidents de sécurité. Ils permettent de collecter, d'analyser et de corréler des données de sécurité provenant de différentes sources, telles que les journaux d'événements, les systèmes de détection d'intrusion et les systèmes de gestion des identités et des accès.

De part une gestion centralisée des logs et des événements de sécurité, les SIEM permettent aux organisations de détecter rapidement les menaces de sécurité et de prendre des mesures pour les contrer avant qu'elles ne causent des dommages. Ils sont également utiles pour améliorer la visibilité sur les activités du réseau et pour faciliter la mise en conformité avec les normes de sécurité.

Cependant, l'efficacité des SIEM dépend de plusieurs facteurs clés tels que la qualité des données collectées, la configuration et le paramétrage du système, ainsi que la capacité de l'organisation à gérer efficacement les événements et les alertes générés par le SIEM.

On peut donc conclure que pour optimiser la sécurité informatique au sein d'une organisation et maximiser les avantages des SIEM, il est important d'adopter une approche proactive en matière de sécurité, de disposer d'une stratégie de sécurité claire et cohérente, et de mettre en œuvre des pratiques de gestion des événements et des alertes efficaces. En investissant dans des SIEM et en les intégrant efficacement dans leur architecture de sécurité, les organisations peuvent améliorer considérablement leur posture de sécurité et se protéger contre les menaces de sécurité en constante évolution.

Comme perspectives à ce travail, on peut envisager la combinaison des SIEM avec les outils d'orchestration qui permettent d'automatiser et de gérer des tâches répétitives et les processus d'une infrastructure informatique. Ces processus peuvent inclure la gestion de conteneurs, la configuration de serveurs, la mise en place de pipelines de déploiement, etc… Dans le cadre d'une solution SIEM, les outils d'orchestration peuvent être utilisés pour automatiser certaines tâches liées à la détection et à la réponse aux incidents de sécurité. Par exemple, au cours du processus de collecte des données, le SIEM collecte des données provenant de différents systèmes de sécurité tels que les pare-feux, les systèmes de détection et de prévention des intrusions. Cependant, la configuration et la maintenance de ces sources de données peuvent être fastidieuses dans un environnement de production. Les outils d'orchestration peuvent aider à automatiser le processus de collecte de données en automatisant le déploiement, la configuration et la gestion de ces sources de données.

On peut également évoquer une façon de faciliter davantage la normalisation des logs et de réduire le nombre de faux-positifs, il pourrait être envisagé d'utiliser le Deep Learning pour l'analyse syntaxique, c'est-à-dire le parsing. Les technologies de reconnaissance d'images et de traitement du langage naturel (NLP) ont déjà prouvé leur efficacité dans ces domaines et pourraient être appliquées aux logs, ce qui permettrait aux experts de gagner un temps précieux.

BIBLIOGRAPHIE

B1. PILLOU, J-F & BAY, J-P (2016). *Tout sur la sécurité informatique (*4ème édition). Dunod. Paris

B2. BLOCH, L. & WOLFHUGEL, C (2013). *Sécurité Informatique ; principes et méthodes à l'usage des DSI, RSSI et administrateurs* (4ème édition). Eyrolles. Paris

WEBOGRAPHIE

W1. https://web.maths.unsw.edu.au/~lafaye/CCM/protect/firewall.htm (Consulté le 10 Février 2023).

W2. https://web.maths.unsw.edu.au/~lafaye/CCM/detection/ids.htm (Consulté le 10 Février 2023).

W3, W4, W5, W6, W7. https://www.crowdstrike.com/cybersecurity-101/observability/log-file-formats/ (Consulté le 16 Mars 2023).

W8. https://www.ibm.com/docs/en/qsip/7.4?topic=deployment-qradar-architecture-overview (Consulté le 24 Février 2023).

W9. https://docs.splunk.com/Documentation/Splunk/9.0.4/Installation/Splunksarchitectureandwhatgetsinstalled (Consulté le 16 Mars 2023).

W10. https://openclassrooms.com/fr/courses/1750566-optimisez-la-securite-informatique-grace-au-monitoring/7145268-decouvrez-la-stack-elk (Consulté le 16 Mars 2023).

W11. https://docs.logrhythm.com/docs/enterprise/understand-the-logrhythm-architecture (Consulté le 20 Mars 2023).

W12. https://go2docs.graylog.org/50/planning_your_deployment/planning_your_deployment.html (Consulté le 20 Mars 2023).

W13. https://cybersecurity.att.com/documentation/usm-appliance/system-overview/about-usm-architecture-components.htm (Consulté le 25 Mars 2023).

W14. https://documentation.wazuh.com/current/getting-started/architecture.html (Consulté le 25 Mars 2023).

W15. https://documentation.wazuh.com/current/quickstart.html (Consulté le 27 Mars 2023)

W16. https://documentation.wazuh.com/current/getting-started/components/wazuh-server.html (Consulté le 2 Avril 2023).

W17. https://documentation.wazuh.com/current/getting-started/components/wazuh-dashboard.html (Consulté le 2 Avril 2023).

W18. https://documentation.wazuh.com/current/getting-started/components/wazuh-agent.html (Consulté le 2 Avril 2023).